

EE6102

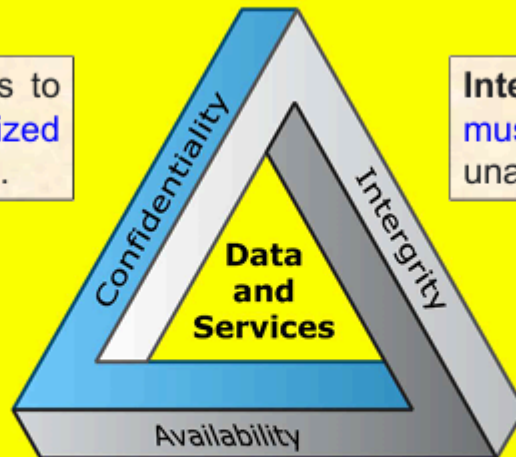
导论

CIA

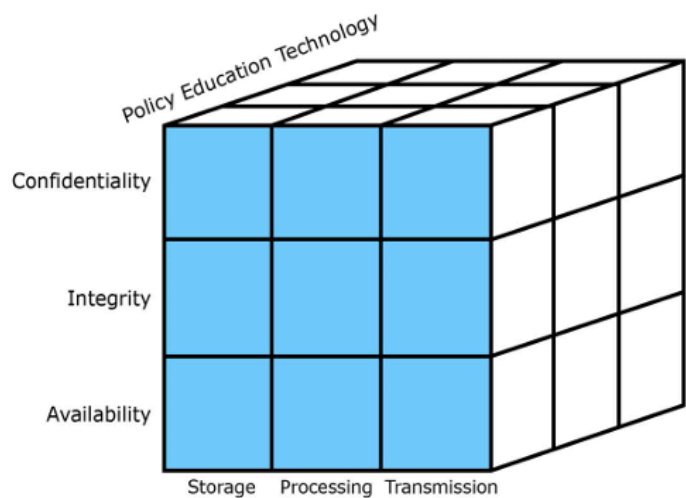
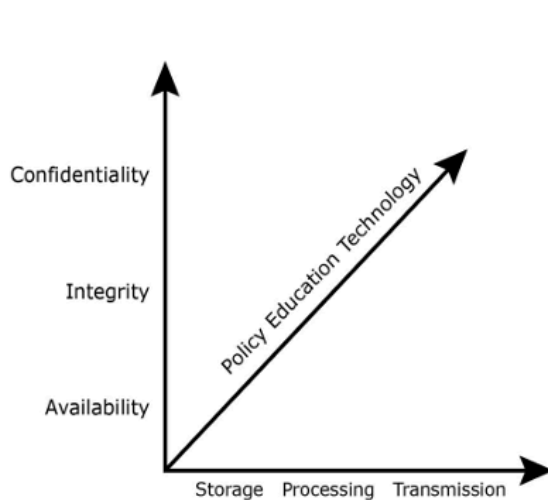
Confidentiality, integrity and availability, (known as CIA triad), are considered the **three most important concepts within cyber security**.

Confidentiality means to prevent the **unauthorized access/sharing of data**.

Integrity means data **must not be changed** by unauthorized people.



- **Availability** means information should be **consistently and readily accessible for authorized parties**.
- This involves **properly maintaining hardware, software, technical infrastructure and systems that hold and display the information**.



定义

安全 (SECURITY)

定义：免受危险或风险的状态。

网络安全 (CYBER-SECURITY)

定义：保护数字格式信息的任务。

目标：

确保防护措施得到正确实施。

保护对个人和组织有价值的**信息**。

信息的价值来源于其自身特性。

实现途径**PPP**：通过**产品 (Products)**、**人员 (People)** 和**流程 (Procedures)** 三者结合实现安全。

层级	描述
产品	设备、数据中心等周围的物理安全。可简单如门锁，也可复杂如专用软硬件。
人员	实施并正确使用安全产品的人员。
流程	组织为确保人员正确使用产品而制定的计划和政策。

成功的组织应建立多层安全架构**PPOCNC**：

物理安全 (Physical security) → 产品 (Products)

人员安全 (Personal security) → 人员 (People)

组织安全 (Organisation security) → 流程 (Procedure)

通信安全 (Communications security)

网络安全 (Network security)

网络安全 (Cyber security) → CIA三元组

为何需要网络安全

网络安全是组织通过网络进行电子化业务交易时，必须具备的**PPT政策、实践与技术**，以提供合理的安全保障。

数据资产 (Data assets)

知识资产 (Knowledge assets)

软件资产 (Software assets)

物理资产 (Physical assets)

货币或金融资产 (Monetary or financial assets)

员工资产 (Employee assets)

客户与合作伙伴资产 (Customer and partner assets)

商誉 (Goodwill)

术语

AUTHENTICATION

- ❑ Assurance that communicating entity is the one claimed.

ACCESS CONTROL

- ❑ Prevention of the unauthorized use of a resource.

DATA CONFIDENTIALITY

- ❑ Protection of data from unauthorized disclosure.

DATA INTEGRITY

- ❑ Assurance that data received is as sent by an authorized entity.

NON-REPUDIATION

- ❑ Protection against denial by one of the parties in a communication.

AVAILABILITY

- ❑ Resource accessible/usable.

SECURITY MECHANISM

- ❑ Feature designed to detect, prevent, or recover from a security attack.

攻击与攻击者

助长网络攻击的因素 (FACTORS AIDING CYBER ATTACKS)

互联网的三大特性为网络攻击提供了便利：

1. 自动化 (AUTOMATION)

计算机和网络的高速度使发动攻击成为可能。
数据挖掘/人工智能技术使发现目标变得容易。
例如：使用“挖矿”软件。

2. 远程行动 (ACTION AT A DISTANCE)

攻击者可远离目标，但仍能造成损害。
国际/国家间的法律差异会影响追责与执法。
例如：跨国洗钱、伪造电子货币。

3. 电子技术易于转移/复制 (ELECTRONIC TECHNIQUES EASILY TRANSFERABLE/DUPPLICATED)

攻击工具可由个人创建。
可根据需要快速修改。

不同类型的网络攻击

当**第三方未经授权访问系统**时，即构成**网络攻击**。执行攻击的人被称为**黑客或攻击者**。

常见攻击类型包括：

恶意软件攻击 (Malware Attack)

社会工程学攻击 (Social Engineering Attack)

中间人攻击 (Man in the Middle Attack)

拒绝服务攻击 (Denial of Service Attack)

SQL注入攻击 (SQL Injection Attack)

密码攻击 (Password Attack)

恶意软件攻击 (MALWARE ATTACK)

恶意软件是最常见的网络攻击形式之一。

“Malware”指所有恶意软件，包括病毒、蠕虫、间谍软件、勒索软件、广告软件、Rootkit 和木马。

病毒/蠕虫 (Virus/Worm):

通过感染文件或系统传播。

蠕虫无需宿主即可自我复制。

特洛伊木马 (Trojan Horses):

假装是合法软件，实则为恶意程序。

常用于安装后门或窃取数据。

勒索软件 (Ransomware):

加密用户关键数据，要求支付赎金以恢复访问。

有时即使支付也未必能恢复数据。

间谍软件 (Spyware):

在用户不知情下窃取个人信息（如密码、浏览记录）。

广告软件 (Adware):

显示广告内容，常伴随弹窗和浏览器重定向。

Rootkit:

允许攻击者获得系统最高控制权，隐藏自身行为，极难检测。

僵尸网络 (BOTNET):

由被植入恶意代码的计算机组成的网络（受“僵尸控制器”控制）。

黑客利用僵尸网络发动大规模攻击（如DDoS）。

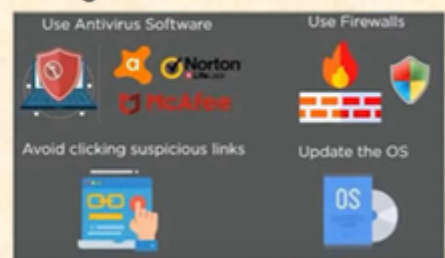
发送垃圾邮件而不易被追踪。

如何防范

AFAU

❑ How to prevent a malware attack

- ❑ Use **antivirus** software. It can protect your computer against malware.
- ❑ Use **firewalls**. Windows and Mac OS have their default **built-in firewalls**, named Windows Firewall and Mac Firewall.
- ❑ **Avoid clicking on suspicious links**.
- ❑ **Update your OS and browsers, regularly**.



社会工程学攻击 (SOCIAL ENGINEERING ATTACK)

定义：通过操纵**manipulating**人类心理，诱骗其泄露机密信息。

最普遍形式：钓鱼攻击 (Phishing):

攻击者伪装成可信实体（如银行、公司），通过邮件诱导受害者点击链接或提供凭证。

受害者常在不知情下打开附件或访问恶意网站，导致系统被感染或账户被盗。攻击者还可借此安装恶意软件或窃取财务信息。

钓鱼攻击类型 (TYPES OF PHISHING ATTACKS)

普通钓鱼 (Phishing Attack):

最基础形式，群发虚假邮件，诱导点击链接或填写表单。
通常冒充银行、电商平台等。

鱼叉式钓鱼 (Spear Phishing Attack):

针对特定个人或群体的精准攻击。
利用社交媒体、邮件等收集目标信息，提高欺骗性。

鲸钓攻击 (Whaling Phishing Attack):

针对公司高管、董事会成员等高价值目标。
攻击者常伪装成CEO或高级管理人员，要求转账或提供敏感数据。
由于目标警惕性高，攻击者需精心策划，成功率较低但危害巨大。

短信钓鱼 (Smishing): 网络罪犯发送**手机短信**，冒充公司或慈善机构。其运作方式与电子邮件钓鱼基本相同。

语音钓鱼 (Vishing): 网络罪犯通过**电话**联系目标，试图骗取账号凭据或信用卡详情等信息。

钓鱼式欺诈 (Angler phishing): 网络罪犯利用**社交媒体**获取信息，诱导目标访问虚假网站或下载恶意软件。

如何防范

审查邮件来源: 检查发件人地址、格式错误、可疑链接。

使用反钓鱼工具栏。

定期更新密码并启用多因素认证 (MFT)。

加强员工安全培训。

及时更新安全补丁与系统。

密码攻击 (PASSWORD ATTACK)

定义: 攻击者使用密码破解工具（如Aircrack, Cain, Abel, John the Ripper, Hashcat）尝试破解用户密码。

密码破解时间估算 (Brute Force Attack)

暴力破解

尝试所有可能的密码组合，直到找到正确密码。

成功与否取决于:

密码长度

字符集大小

尝试速度（每秒尝试次数）

如何防范

Listed below are a few ways to prevent password attacks:

Use strong alphanumeric passwords with special characters

Refrain from using the same password for multiple websites or accounts.

Update your passwords (advisable to change it every 90 days); this will limit your exposure to a password attack.

Do not have any password hints in the open.

Account lockout: Locks account after X failed tries (e.g., 5 attempts)

Rate limiting: Delays next login attempt after each failure

MFA (2FA): Adds a second step even if password is guessed

IP blacklisting: Detects and blocks suspicious IPs

中间人攻击 (MAN-IN-THE-MIDDLE ATTACK, MITM)

攻击者插入到客户端与服务器之间的通信链路中，截取或篡改双方数据。

也称为“窃听攻击”(eavesdropping attack)。

攻击者切断原始通信，使客户端和服务端误以为仍在直接通信。

如何防范

防护措施：

使用设备上的加密技术（如HTTPS、TLS）。

注意网站安全性（检查URL是否为 https:// ，是否有锁形图标）。

避免使用公共Wi-Fi网络进行敏感操作。

SQL注入攻击 (SQL INJECTION ATTACK)

定义：

攻击者通过在Web表单或URL参数中注入恶意SQL代码，操纵数据库查询语句。

目的：获取、修改或删除数据库中的数据，甚至获得管理员权限。

数据库暴露敏感信息（如用户凭证、财务数据）。

可能导致系统被完全控制。

如何防范

使用**入侵检测系统 (IDS)** 自动识别并阻止SQL注入行为。

对用户输入进行**验证与过滤**（如白名单机制、参数化查询）。

使用Web应用防火墙（WAF）。

拒绝服务攻击 (DENIAL-OF-SERVICE ATTACK, DoS/DDoS)

攻击者通过向目标系统发送大量流量或请求，使其资源耗尽，无法响应合法用户请求。

严重时可导致服务中断或系统崩溃。

分布式拒绝服务攻击 (DDoS)：利用多个被控主机（僵尸网络）同时发起攻击。

分类

VPA

类型	描述
容量型攻击 (Volume Based Attacks)	用海量流量淹没目标带宽，如Ping洪水、UDP洪水。
协议型攻击 (Protocol Attacks)	利用协议漏洞消耗服务器资源，如SYN洪水。
应用层攻击 (Application Layer Attacks)	针对Web服务器应用层，如HTTP Flood，模拟正常用户请求但不完成交互。

容量型DDoS攻击：Ping Flood

攻击者向目标主机发送大量ICMP Echo Request (ping) 包。
目标主机需回应每个请求，消耗其CPU和带宽资源。
易被识别（源IP地址暴露）。
现代网络通常禁用ICMP回显请求或限制速率。

解决方案

Defence Method	Description
Rate limiting	Limits ICMP replies per second
ICMP flood detection	Firewalls detect high volumes and block
Firewalls/ACLs	Drop all ICMP packets from untrusted sources
Intrusion Detection	Detect abnormal ICMP traffic volumes (Snort, Suricata, etc.)
Cloud Dos Protection	Use services like AWS Shields, Cloudflare, Akamai, etc.

协议层DDoS攻击：SYN Flood

TCP三次握手过程中，攻击者发送大量SYN包（伪造源IP），服务器回应SYN-ACK后等待ACK确认。
由于源IP是伪造的，ACK永远不会到达，服务器连接队列被占满，无法处理新连接。

解决方案

启用SYN Cookie机制。
设置连接超时时间。
使用防火墙或负载均衡器过滤异常流量。

应用层DDoS攻击：HTTP Flood

攻击者模拟大量真实用户访问Web服务器，发送GET/POST请求。
服务器需处理完整HTTP请求，消耗CPU、内存和数据库资源。
与传统流量型攻击不同，它更难被识别，因为流量看起来“正常”。

解决方案

使用CDN或WAF进行请求过滤。
设置速率限制和会话管理。
采用行为分析识别异常访问模式。

DNS洪水攻击 (DNS FLOOD ATTACK)

攻击者向目标域名的DNS服务器发送海量查询请求，使其无法响应合法请求。
常用于攻击高带宽设备（如DVR、摄像头）组成的僵尸网络。

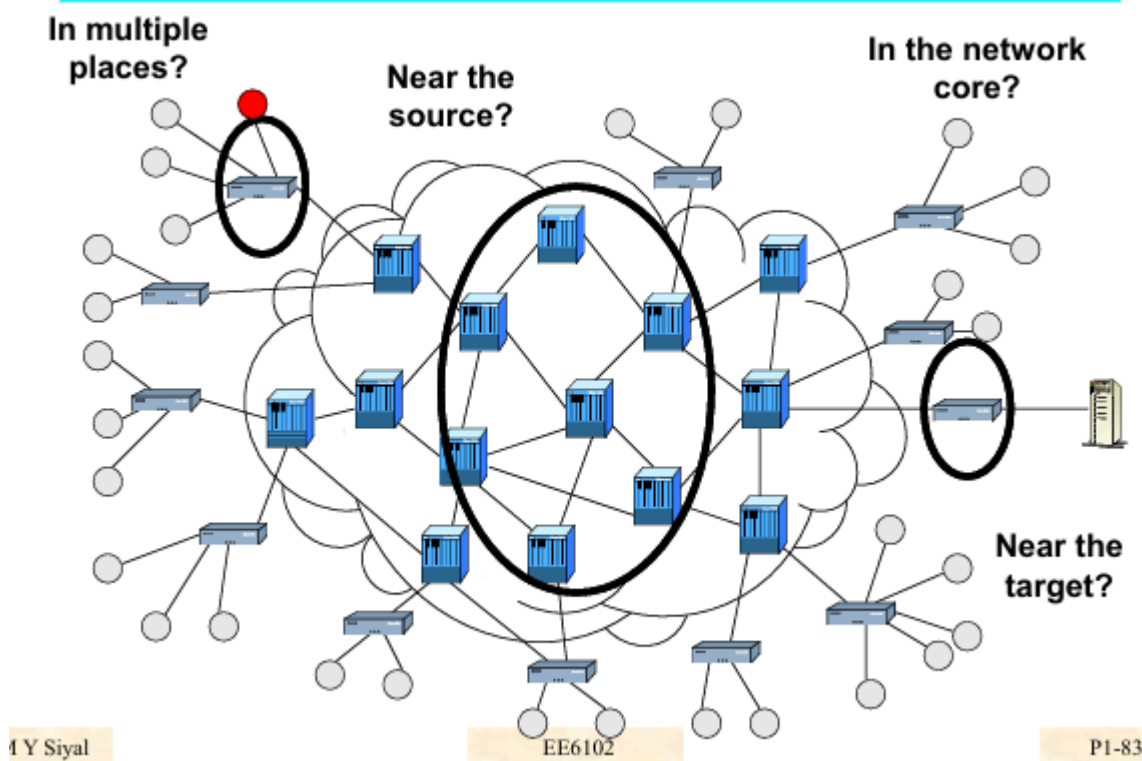
解决方案

使用分布式DNS解析服务。

部署DNS防火墙或Anycast网络分散流量。

限制每IP的查询频率。

DDoS攻击过滤位置选择 (WHERE DO YOU FILTER?)



如何防范

1. 运行流量分析：

监控网络流量，识别异常模式（如突发流量、大量重复请求）。

2. 理解预警信号：

如网站变慢、间歇性宕机、服务响应延迟等，可能是攻击前兆。

3. 制定应急响应计划：

建立检查清单，明确团队职责。

确保IT团队和数据中心能快速响应。

4. 外包DDoS防护：

使用云服务商提供的DDoS防护服务（如Cloudflare、Akamai、AWS Shield）。

利用其全球分布式网络吸收和清洗恶意流量。

内部威胁 (INSIDER THREAT)

指由组织内部人员（员工、承包商、合作伙伴等）发起的安全威胁。

攻击者熟悉系统架构和安全措施，破坏力极大。

难以预测和检测。

动机多样：贪婪、恶意、疏忽、报复等。

如何防范

- 1. **建立安全文化：**
全员参与安全意识培训。
强调数据保密与合规操作。
- 2. **权限最小化原则：**
根据岗位职责分配访问权限，避免过度授权。
- 3. **员工培训与监控：**
定期开展安全培训。
对敏感操作进行日志审计和行为分析。
- 4. **建立举报SPOT机制：**
鼓励员工报告可疑行为。

加密劫持 (CRYPTO JACKING)

攻击者在受害者计算机或服务器上植入加密货币挖矿脚本，利用其计算资源进行挖矿。
用户通常无感知，仅表现为设备性能下降或电费增加。
通过恶意网站、广告、链接或漏洞利用传播。
挖矿代码在后台运行，不干扰用户正常操作。

如何防范

- 1. **更新软件与安全补丁：**
保持操作系统、浏览器和插件为最新版本。
- 2. **安装广告拦截器：**
阻止恶意广告和脚本加载。
- 3. **部署安全工具：**
使用如MinerBlock等扩展程序识别并阻止挖矿脚本。
- 4. **员工安全意识培训：**
教育员工识别可疑链接和网站。

黑客

黑客是指拥有高超技术能力，能够发现并利用计算机网络漏洞的个人。

分类

类型	描述
白帽黑客 (White Hat)	伦理黑客，帮助发现并修复漏洞，通常受雇于企业或政府。
黑帽黑客 (Black Hat)	恶意黑客，窃取数据、金钱或信用卡信息，从事非法活动。
灰帽黑客 (Gray Hat)	介于黑白之间，发现漏洞后通知所有者，有时会要求报酬。

类型	描述
脚本小子 (Script Kiddies)	缺乏技术能力，依赖现成工具发动攻击，常为炫耀或恶作剧。
国家支持黑客 (Nation Sponsored Hackers)	代表国家进行网络战、情报收集或破坏活动。
黑客行动主义者 (Hacktivist)	为政治、社会或意识形态目的发起攻击，如 Anonymous 组织。

为何需要伦理黑客？ (NEED FOR ETHICAL HACKERS)

1. 防止外部入侵：
伦理黑客主动测试系统安全性，提前发现并修补漏洞。
2. 发现被忽略的系统弱点：
内部安全团队可能遗漏某些风险，伦理黑客提供独立视角。
3. 优化安全策略：
分析现有安全措施的有效性，提出改进建议。
4. 保护客户数据：
在数据泄露发生前加固系统，保障用户隐私与企业声誉。

攻击动机 (WHY DO HACKERS HACK?)

GOVERNMENT SPONSORED HACKING

- Cyber Warfare
- Cyber Terrorism
- Espionage

INDUSTRIAL ESPIONAGE

- Attacks on confidentiality
- Public information gathering
- Trade secret espionage

ELITE HACKERS

- Publicize vulnerabilities
- Hacking- Challenge
- Financial gains

SCRIPT KIDDIES – Gain Respect

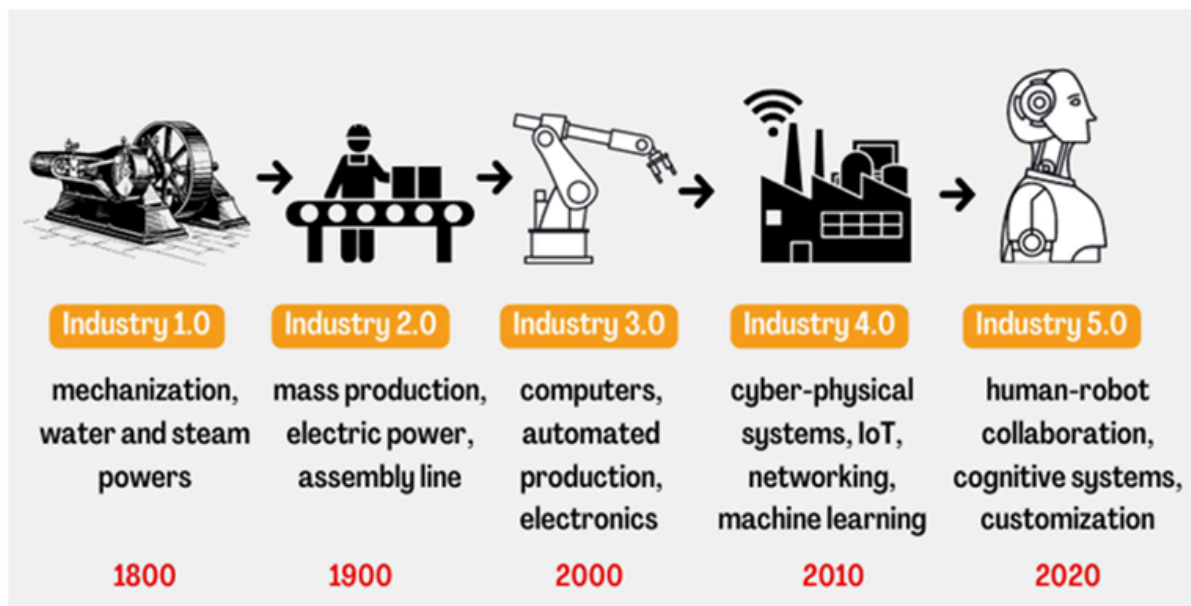
INSIDERS – Revenge







工业4.0/5.0与网络安全



IOT&云计算 (Cloud Computing)

IoT，物联网，强调万物互联

云计算

技术本质：基于互联网的远程服务器集群，按需提供计算、存储、网络等资源。

核心优势：

按需付费 (Pay-as-you-go)

弹性伸缩 (Elasticity)

高可用性与灾备能力

免运维 (Infrastructure-as-a-Service)

大数据与人工智能 (AI & Big Data)

$$\text{AI Performance} \propto \log(\text{Data Volume}) \times \text{Data Quality}$$

数字孪生

定义：物理实体（设备、产线、工厂）的实时动态虚拟映射。

组成要素：

传感器数据流 (Physical → Digital)

AI模型（仿真、预测、优化）

可视化界面 (Dashboard & AR/VR)

虚拟化 (Virtualization)

定义：创建物理资源（CPU、内存、存储、网络）的逻辑抽象层。

在工业中的作用：

实现“智能工厂”的软硬件解耦；

支持边缘计算节点快速部署；

为AI模型训练提供隔离沙箱环境。

主要挑战：

物理资产与虚拟表示间的信息交换安全（需加密通信）

虚拟系统被入侵后可能导致物理设备误操作（如PLC被篡改）

网络物理系统（Cyber-Physical Systems, CPS） / “智能系统”

定义：

新一代集成计算、通信与物理能力的系统，可与人类进行多模态交互。

典型应用领域：

智能汽车（自动驾驶、V2X通信）

医疗监测系统（可穿戴+AI诊断）

工业机器人 + 自动导引车（AGV）

智慧电网、智能楼宇

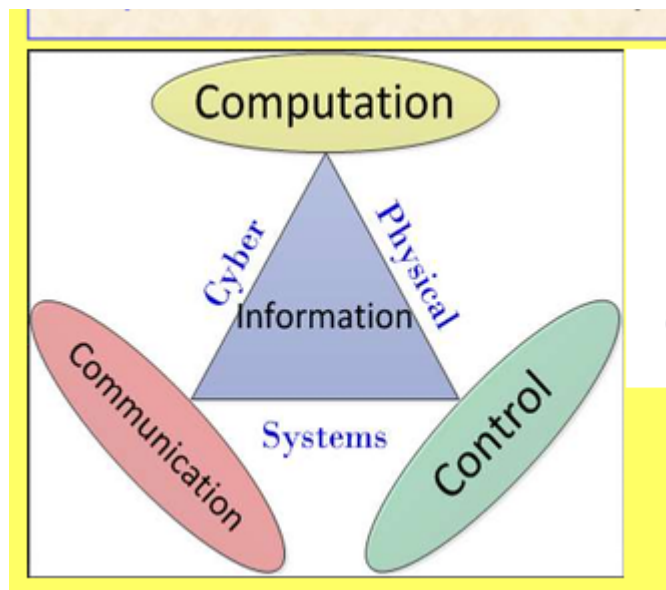
安全挑战：

CPS是最复杂的网络安全对象之一；

若未严肃对待其安全防护，极易成为网络攻击入口（如Stuxnet攻击伊朗离心机）；

安全需贯穿“计算-通信-控制-信息”四维闭环：

CCCI



智能工厂（SMART FACTORIES）

核心特征：

高度数字化：制造全流程由IoT、AI、云平台驱动；

人机协同：工人与机器人/AR眼镜协作完成复杂装配；

柔性生产：支持小批量、个性化定制（如按订单3D打印零件）；

自主优化：基于实时数据动态调整工艺参数。

核心挑战：IoT与AI技术的脆弱性耦合

Industry 4.0/5.0 的本质是“万物互联”，但：

设备间高度依赖（一环失效 → 全链瘫痪）；

数据流不可见（攻击者可在中间层注入虚假数据）；

安全责任边界模糊（OT团队不懂IT安全，IT团队不熟悉PLC协议）。

⚠️ 结论：

“更低的成本与更高的效率”必然伴随“更大的风险”；

Industry 4.0/5.0 不仅是技术升级，更是**安全范式的重构**——它既是机遇，也是网络犯罪的新温床

网络安全教育、意识和合规

人为因素在网络安全的核心地位（HUMAN FACTORS IN CYBER SECURITY）

研究表明：**员工的恶意或疏忽行为**是导致数据泄露、系统妥协的主因。

主要问题包括：

操作失误（Errors）

故意违规（Omissions）

骗局受骗（Fraud）

未经授权的行动（Actions by disgruntled employees）

安全意识、培训与教育的作用

可显著降低人为失误引发的安全事件；

有助于提升员工对“责任归属accountability”与“潜在后果”的认知；

但需注意：

员工常难以分辨哪些政策可申诉、哪些必须遵守；

仅靠培训不足——需配合技术控制（如MFA）与管理监督。

安全意识（AWARENESS）的价值与实施

核心收益

- 明确责任边界**：员工理解自身在保护数据中的角色，并主动履职；
- 提升组织整体安全韧性**：全员参与构建“人防”屏障；
- 建立安全文化**：政策文档需面向全员公开，而非仅IT部门知晓。

实施要点

为**每位新员工**提供入职安全意识培训；

将意识活动纳入**周期性计划**（如季度演练、钓鱼模拟）；

明确划分各层级人员职责

培训（TRAINING）

角色层级	培训目标	关键内容
通用用户	掌握基础安全技能	- 密码管理 - 识别钓鱼邮件 - 公共Wi-Fi风险

角色层级	培训目标	关键内容
程序员/开发/运维	构建安全开发生命周期（SDL）	- 安全编码规范（OWASP Top 10） - 依赖库漏洞扫描 - CI/CD中集成SAST/DAST
管理层/决策者	风险治理与战略对齐	- 网络风险量化（如FAIR模型） - 合规成本 vs. 违规代价 - 安全投资ROI评估

社会工程学的本质：干扰与误导（Distraction & Misdirection）

定义：通过心理操纵诱导受害者执行非本意操作（如点击链接、透露密码）。

典型手法：

- 冒充权威（“我是IT支持，请重置密码”）
- 制造紧迫感（“账户将在5分钟内锁定！”）
- 利用同理心（“我妈妈生病了，急需转账”）
- 虚构故障场景（“您的机器需要维修，请提供凭证”）

鱼叉式钓鱼（Spear Phishing）

- 特点：**高度定制化，针对特定个人/部门；
- 手段：**利用LinkedIn、Facebook等收集目标信息（职位、项目、同事名）；

语音钓鱼（Vishing）

- 通过电话冒充银行/客服，诱骗提供验证码或账户信息；
- 利用**来电显示欺骗**（Spoofing）使号码显示为“Bank of America”等可信机构。

短信钓鱼（Smishing）

- 通过短信发送虚假链接（如“您的包裹已滞留”）；
- 比邮件更易触发即时响应（手机用户习惯快速点击）。

搜索引擎钓鱼（Google Search Scams）

- 攻击者优化恶意网站SEO，使其出现在Google前排；
- 用户搜索“login”“reset password”时点击高排名假链接；
- 常见于仿冒银行、云服务、政府网站。

社交媒体钓鱼

- 伪造好友账号私信：“快看这个视频！” + 恶意链接；
- 或利用“点赞抽奖”“问卷调查”诱导下载木马APP。

QR码钓鱼

- 在餐厅、广告牌贴伪造QR码，扫码后跳转至钓鱼页面；
- 用户无意识扫描 → 输入凭证 → 账号被盗。

邮件钓鱼 (Email Phishing)

最经典形式：伪造发件人地址（如 support@amazon.com）；

伪造登录页、紧急警报、发票附件（含宏病毒）；

关键识别线索：

发件人邮箱域名拼写错误；

要求“立即行动”却无具体上下文；

链接hover后显示真实URL与声称不符；

附件为 .exe, .scr, .zip 等可执行格式。

如何防范钓鱼攻击？ (What Helps Protect You)

紧急时刻：

！ *Don't let emotions cloud your judgment* —— 拒绝“恐慌驱动决策”。

验证身份：

电话回拨官方号码（非邮件中提供的），确认对方身份。

检查细节：

邮件地址、URL拼写（paypa1.com ≠ paypal.com）

语法错误、格式异常（正规机构极少用感叹号堆砌）

启用多因素认证 (MFA)：

即使密码泄露，攻击者仍难登录。

审视消息风格：

正规机构邮件语气专业、无错别字；钓鱼邮件常有“urgent!”、“immediately!”等情绪词。

主动提问：

“您能告诉我上次登录IP吗？” “这个请求是否已走审批流程？”

勒索软件 (Ransomware)

1. 初始入侵（钓鱼邮件 / RDP爆破）
2. 横向移动（窃取凭证、提升权限）
3. 数据加密 + 勒索信
4. 威胁公开数据（双重勒索）

不从不可信网站下载文件（尤其.exe/.js/.vbs）

警惕带附件的邮件（即使来自“同事”）

绝不使用公司邮箱/密码处理私人事务

密码勿存文本/Excel（改用密码管理器）

定期离线备份（3-2原则：3份副本，2种介质，1份离线）

USB设备安全使用指南

避免使用公共充电站（USB端口可能植入恶意固件，即“Juice Jacking”）；

不插入来源不明的U盘（可能含AutoRun病毒）；

使用只读USB设备或硬件加密U盘；

对重要数据**加密存储**（如 VeraCrypt, BitLocker）；
插入前先用杀毒软件扫描

员工网络安全意识（CYBER SECURITY AWARENESS FOR EMPLOYEES）

核心认知：

数据泄露与知识产权窃取威胁始终存在；
仅靠技术防护不足——**员工是第一道防线**；
全员需具备“可疑即报”意识：若察觉异常，应立即上报而非自行处理。

关键行动要求：

了解公司安全政策与自身责任；
熟悉常见攻击手法（钓鱼、Vishing、Smishing等）；
掌握基本防护技能（MFA、密码管理、URL验证）；
参与年度安全培训与模拟演练（如钓鱼邮件测试）。

网络安全合规（CYBER SECURITY COMPLIANCE）

合规：组织主动遵守法律法规、行业标准与内部政策的行为。

驱动力：

法律强制（如 GDPR、CCPA、HIPAA、中国《数据安全法》）；
合同义务（客户/供应商要求）；
市场竞争力（合规=信任背书）。

是组织**韧性（resilience）**的基石；
中小企业（SMBs）常因合规缺失成为攻击首选目标；
合规失败可导致：
巨额罚款（GDPR最高达全球营收4%）；
声誉崩塌与客户流失；
法律诉讼与监管禁令。

构建网络安全合规计划

CRSCM

组建合规团队

IT部门牵头，联合法务、HR、业务线负责人；
明确角色与问责制（RACI矩阵）。

开展风险分析（Risk Analysis Process）

四步循环：

- 识别（Identify）：**盘点资产、系统、数据流；
- 评估（Assess）：**量化威胁可能性 × 影响程度 × 资产价值；

- 3. 分析 (Analyze)：计算风险值；
- 4. 设定容忍度 (Set Tolerance)：决定接受、转移、缓解或拒绝风险。

设置安全控制 (Setting Controls)

控制类型	示例
技术控制	加密、防火墙、EDR、MFA、补丁管理
物理控制	门禁、监控摄像头、机房访问日志
管理控制	安全策略、员工培训、incident response plan
行政控制	访问审批流程、第三方尽调、合同条款

制定政策 (Creating Policies)

政策须由IT、法务、管理层共同审定；
内容涵盖：密码使用、远程办公、数据分类、第三方管理、BYOD等；
必须明确谁负责、何时执行、如何审计。

持续监控与快速响应 (Monitoring & Quick Response)

实时日志分析 (SIEM)、异常行为检测 (UEBA)；
定期红蓝对抗演练；
建立“黄金1小时”响应机制：发现→隔离→溯源→恢复。

风险评估计算 (RISK ASSESSMENT CALCULATION)

$$\text{Risk} = \text{Threat Likelihood} \times \text{Vulnerability} \times \text{Asset Value}$$

评分标准 (1–5分)：
Threat Likelihood：1 (极低) → 5 (极高)
Vulnerability：1 (已修补) → 5 (严重未修复)
Asset Value：1 (低价值) → 5 (核心资产，如客户数据库)
风险等级参考：
≤20：低风险 (可接受)
21–60：中风险 (需缓解)

>60: 高风险（必须立即处置）

- ❑ **Compliance Risk Assessment**
- ❑ **Formula:** Risk = Threat × Vulnerability × Asset Value
- ❑ Each component is rated on a scale (e.g., 1–5). The higher the score, the higher the risk.
- ❑ **Risk Assessment Calculation**
- ❑ **Scenario:** A hospital assesses one of its systems and assign the below values:
 - ❑ Threat Likelihood = 4
 - ❑ Vulnerability Level = 3
 - ❑ Asset Value = 5
- ❑ Calculate the risk score?
- ❑ **Solution:**
- ❑ Risk=Threat × Vulnerability × Asset
- ❑ Value=4×3×5= **60 (48%), so medium level risk**

网络安全规划与政策

网络安全规划是防御攻击与缓解风险的**中心环节**；
是一份**书面文档**，涵盖组织的安全目标、策略、程序与技术措施；
规划需围绕**关键资产**（如客户数据、知识产权、核心系统）展开。

关键目标（Key Objectives）

PMEM

保护 **机密性、完整性、可用性（CIA三元组）**
管理**网络风险**（识别、评估、缓解）
确保**业务连续性**（防中断、快速恢复）
满足**法律与监管要求**（GDPR、HIPAA、等保2.0等）

收益

风险认知提升（Better Understanding of Risks）

组织广泛采用云、IoT、移动设备等新技术 → 攻击面扩大；
计划帮助识别新型威胁（如供应链攻击、AI滥用），推动**主动防护**而非被动响应。

实现“主动防护”（Enabling Proactive Protection）

将安全前置：通过漏洞扫描、渗透测试、红队演练提前发现弱点；
建立**最坏情况预案**（如勒索软件爆发、数据中心断电）；
使组织从“救火模式”转向“韧性构建”。

快速响应能力（Response Promptly）

“100% 安全”不存在，但计划确保：
攻击发生时能**快速隔离**（如网段分段）；
数据可**恢复**（备份+异地容灾）；
业务可**降级运行**（BCP/DRP支持）。

合规与竞争优势（Necessary Compliance Requirements）

满足法规要求（如《个人信息保护法》《数据安全法》）；
提升客户信任：合规 = 可信度背书；
避免罚款与声誉损失（例：某企业因未落实密码策略被罚千万）。

抑制内部威胁（Prevent Inside Threats）

通过权限最小化、行为审计、员工培训，降低疏忽或恶意行为风险；
安全文化建设是长期防线。

网络安全的两大维度（DIMENSIONS OF CYBER SECURITY）

维度	重点内容
技术层面 (TECHNICAL)	• 加密技术 • 防火墙/IDS/IPS • 生物识别与零信任架构 • 硬件/软件/网络层防护工具
管理层面 (MANAGERIAL)	• 安全政策与流程制定 • 人员角色与责任分配 • 风险管理与合规审计 • 领导层承诺与资源投入

网络安全政策类型与示例

Access control policy	Physical security policy
Network security policy	Disaster recovery and business continuity policy
Data security policy	Data classification policy
Password policy	Data retention policy
Acceptable use policy	Incident response policy

Policy Type	Description
Acceptable Use Policy (AUP)	Defines permitted uses of systems and data
Access Control Policy	Details how access is granted and managed
Incident Response Policy	Guides handling of cybersecurity incidents
Data Classification Policy	Specifies how data is labeled and protected
Encryption Policy	Dictates when and how data must be encrypted
Password Policy	Sets requirements for password strength
Remote Access Policy	Controls secure access from outside networks

如何实施网络安全政策？ (HOW TO IMPLEMENT A CYBER-SECURITY POLICY?)

网络安全策略可以通过以下方式实施：

Identifying risks
Learning from others
Conforming to legal requirements
Including staff in policy development
Training employees
Setting clear penalties
Enforcing policies
Installing required tools

如何执行安全政策？ (HOW TO ENFORCE A SECURITY POLICY?)

在组织内部执行网络安全策略的一些方法包括：

沟通 (Communication)： 向所有员工清晰地传达安全策略，确保他们了解自己在维护组织安全方面的职责。提供培训和资源对于帮助员工理解并遵守策略至关重要。

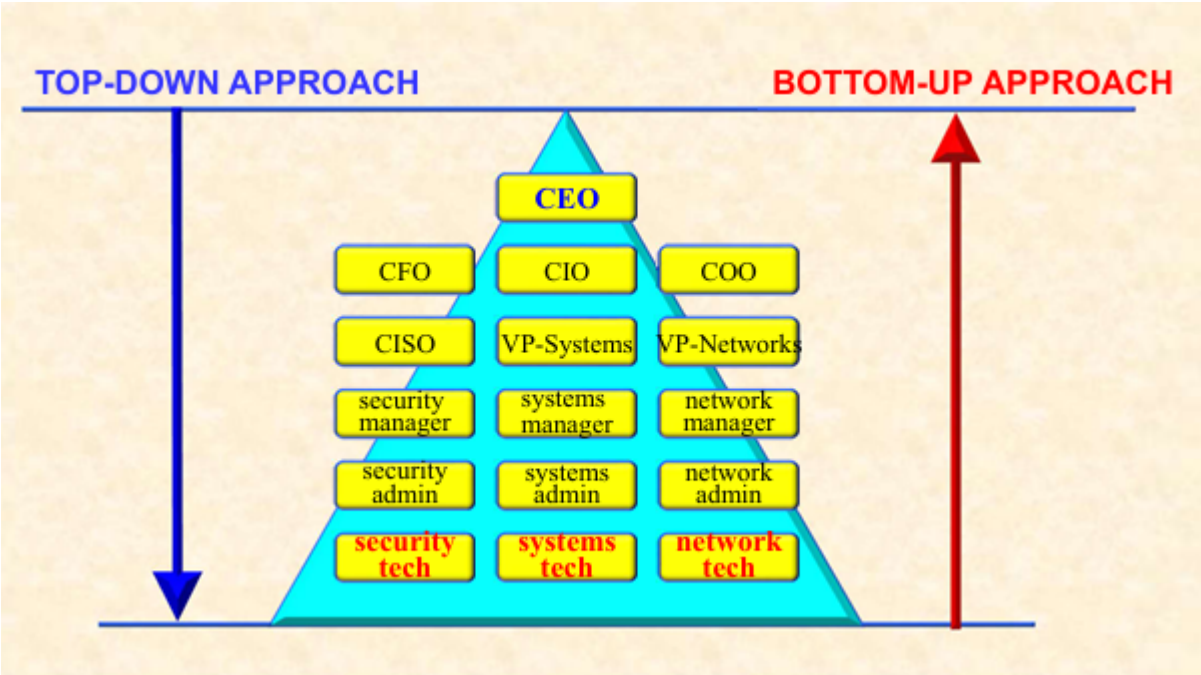
访问控制 (Access Controls)： 通过将系统和数据的访问权限限制为**仅授权用户**，来强制执行安全策略。这包括用户身份验证、授权或多重身份验证 (MFA) 等流程。

监控与审计 (Monitoring and Auditing)： 定期对系统进行监控和审计，有助于发现违反策略

的行为，并识别需要额外控制的领域。

后果 (Consequences): 违反策略必须承担后果。如果没有一定的惩罚措施，员工会一直认为即使违规也不会受到惩处。

网络安全方法论



方法	特点	优势	劣势
自上而下 (Top-Down)	由高管发起，基于业务目标制定安全策略	战略对齐、资源保障强	依赖管理层理解力；易脱离实操
自下而上 (Bottom-Up)	由IT团队从技术问题反推策略	贴近实际、快速见效	缺乏全局视野；难获高层支持

网络安全策略

数字责任管理（DLM: Digital Liability Management）

定义：在政策与技术交汇处，明确**谁对什么负责**；

目标：

范漏洞 → 识别、检测、响应、恢复；

保护关键资产（IP、客户数据、源代码）；

为事故追责提供依据。

TIER 1	Senior management commitment and support
TIER 2	Acceptable-use policies and other statements of practice
TIER 3	Secure-use procedures
TIER 4	Hardware, software and network security tools

层级	内容	作用
Tier 1	高管层承诺与支持	提供资源、设定文化基调
Tier 2	可接受使用政策、行为规范	约束员工行为，明确红线
Tier 3	安全操作规程（SOP）	指导日常安全动作（如补丁、备份）
Tier 4	硬件/软件/网络工具	技术执行层（防火墙、EDR、加密）

零信任安全（Zero Trust Security）

原则：

never trust, always verify

默认拒绝所有访问请求；

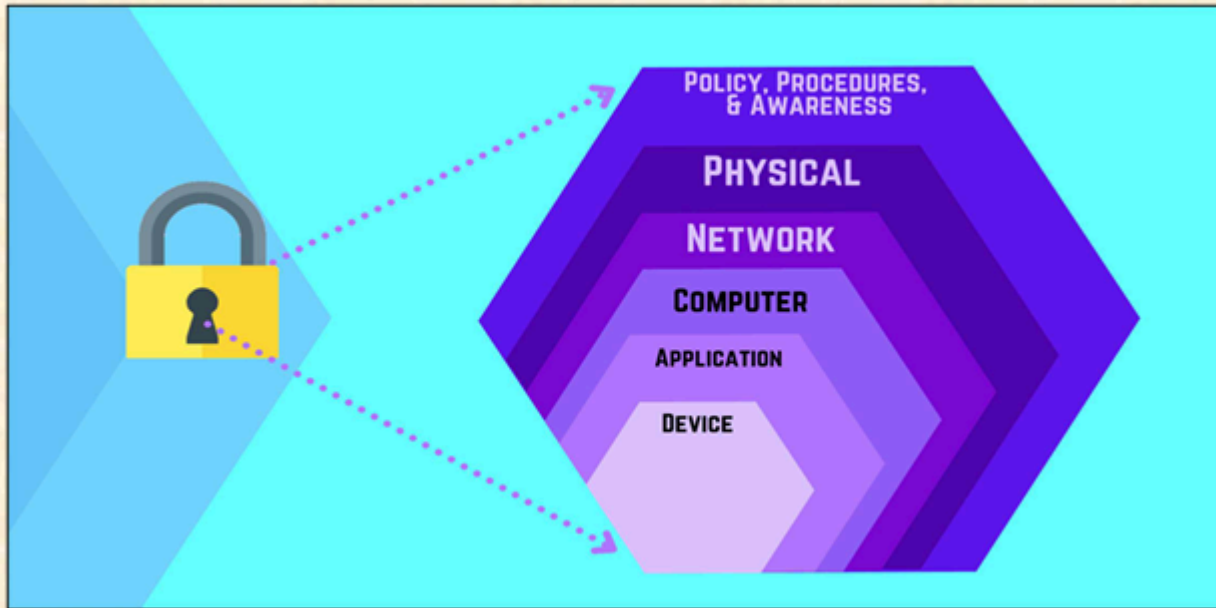
每次访问需动态认证（身份+设备+上下文）；

最小权限原则（Just-in-Time Access）。

深度防御（Defense in Depth）

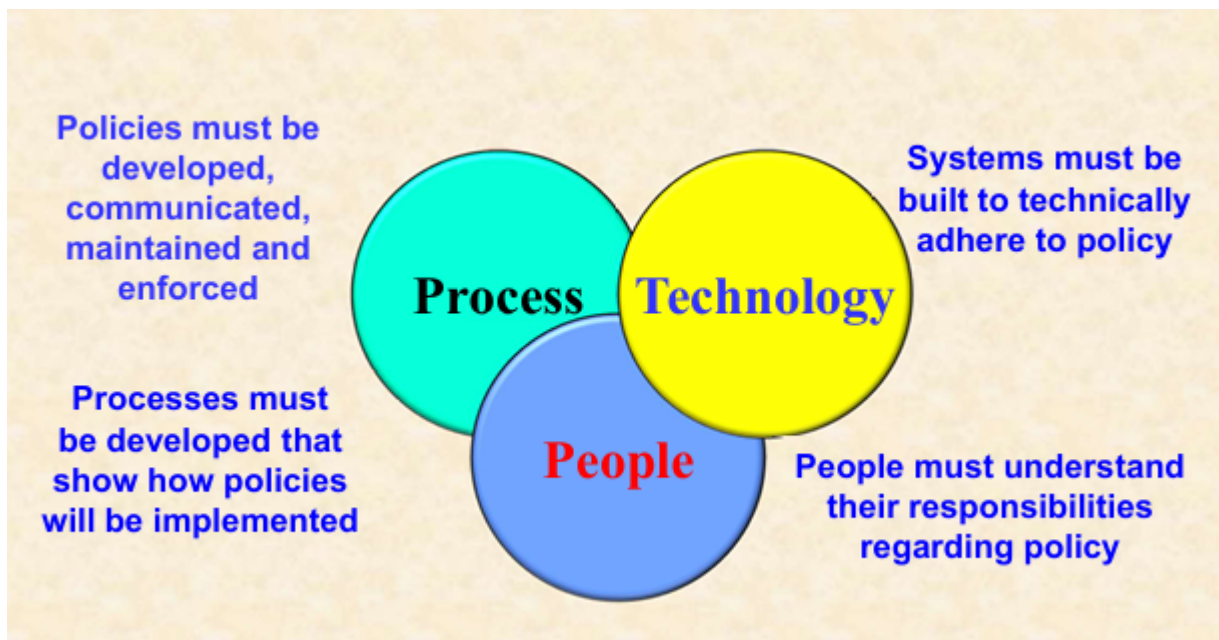
❑ Defense In-depth Strategy

- ❑ The goal of implementing this strategy encompasses the layering of security defenses.



网络安全依赖

PPT



人 (People): 理解政策、遵守流程、具备安全意识;
技术 (Technology): 工具需与策略匹配, 且持续更新;
流程 (Process): 政策必须可执行、可审计、可改进;
三者缺一不可

生物特征认证

认证形式 (Forms of Authentication)

证明“你是你”的三种方式：

Something you have：令牌（token）、智能卡

Something you know：PIN、密码

Something you are：生物特征（Biometric）

什么是生物特征（Biometrics）

指利用个体独特的生理或行为特征来识别与验证身份。

两种基本判定方式：

- 1. **Identification（识别）**：确定“你是谁？” → 一对多比对
 - 2. **Verification（验证）**：确认“你是否是你声称的那个人？” → 一对一比对
- 流程：
- Enrolment（注册/录入）**：采集特征 → 转为参考模板 → 存入活动目录（Active Directory）
 - Authentication（认证）**：实时扫描 → 生成新模板 → 与存储模板比对 → 决策（Pass/Fail）

类型

类型	描述
生理特征（Physiological）	基于身体结构
Fingerprint	指纹脊线与谷线的独特模式
Iris	瞳孔周围彩色环的复杂纹理
Retina	眼底血管分布图案
Face Recognition	面部特征形状与距离
Hand Geometry	手指/手掌的尺寸与长度
DNA	高安全级基因编码
行为特征（Behavioral）	基于动作习惯
Voice Recognition	语音频谱与音高
Keystroke Dynamics	键盘敲击节奏、速度、压力
Gait Recognition	步态与身体运动模式
Signature Analysis	签名笔顺、压力、时序

应用

应用场景	技术实现
访问控制（Access Control）	设备/建筑登录（如指纹门禁）
身份认证（Authentication）	多因子/单因子（如 Apple Face ID / Touch ID）

应用场景	技术实现
边境安全 (Border Security)	机场 e-Gates、护照指纹/虹膜核验
移动安全 (Mobile Security)	银行 App、KYC (客户身份验证)
数字身份验证 (Digital Identity)	e-KYC、银行远程开户
考勤系统 (Time & Attendance)	指纹/人脸打卡

优势与挑战

优势	解释
Convenient	无需记忆密码
Hard to Forge	生物特征难以复制 (理想情况下)
Always Available	随身携带, 不会遗忘/丢失
Faster Access	即时认证 (如解锁手机)
Non-transferable	身份绑定个体, 不可转借

问题	描述
Privacy Concerns	敏感个人数据泄露风险
Spoofing	可被伪造 (如硅胶指纹、照片攻击)
Non-revocability	特征无法“重置”(密码可改, 指纹不行)
Injuries/Illness	创伤/疾病影响识别 (如割伤手指、白内障)
Cost	初始硬件与系统部署成本高

认证流程

- Enrolment (注册)**: 采集用户生物特征 → 生成并存储模板
- Capture (采集)**: 认证时实时扫描特征
- Comparison (比对)**: 新模板 vs 存储模板
- Decision (决策)**: 匹配成功 → 授权; 否则拒绝

指纹识别 (Fingerprint Recognition)

基于脊线Ridges与谷线Valleys的独特排列

minutiae points细节点: 脊线端点endings与分叉点bifurcations, 共约 30–60 个关键点
最广泛使用的生物特征 (易用、低成本、成熟)

工作流程

- 图像采集**: 光学/电容/超声波扫描仪

2. 预处理：

噪声抑制、归一化

二值化（灰度→黑白）

细化（Thinning）：将脊线压缩至单像素宽

3. 特征提取：

检测 minutiae 点与脊线流向

分析奇异点（core, delta）

4. 匹配：

算法：ridge correlation, minutiae-based matching, pattern-based matching

5. 决策：基于匹配得分与阈值判断通过/拒绝

关键算法与挑战

类型	说明
Minutiae-Based Matching	主流方法；比对细节点位置与方向
Correlation-Based Matching	对齐脊线后计算相似性；计算密集
Deep Learning Models	CNNs 提取鲁棒特征；抗噪声与形变能力强
挑战	图像质量差（污渍/ cuts） 伪造攻击（gelatin 假指纹） 环境变量（压力、角度、湿度）

优缺点

优点	缺点
低成本、快速 易集成、非侵入 成熟可靠	易被窃取/复制（接触式） 高质量副本可伪造 环境影响大（湿手/干裂） 需定期校准以维持性能

未来趋势

多模态生物特征：指纹 + 虹膜/声纹融合

AI/ML 增强：提升特征提取与防伪能力

活体检测（Liveness Detection）：区分真实活体与假体

虹膜识别（Iris Recognition）

测量瞳孔周围有色环iris的纹理模式

因其高唯一性（ 2^{266} 种可能组合）与稳定性（出生18个月后终生不变），被视为最精准生物特征

可在 1–3 英尺距离无接触识别（如遥控器红外光照射）

工作流程

- 1. **图像采集**：专用近红外（NIR）相机拍摄高清虹膜图像
- 2. **预处理**：
 - 分割：分离虹膜区域（剔除巩膜、瞳孔、睫毛、眼睑）
 - 归一化：将圆形虹膜映射为矩形块（rubber-sheet model）
 - 增强：提升对比度、降噪
- 3. **特征提取**：
 - Gabor 小波编码（Daugman 算法核心）
 - 提取相位/频率/空间细节
- 4. **匹配**：
 - 计算汉明距离（Hamming Distance）
 - 阈值判定（通常 < 0.32 为匹配）
- 5. **决策**：接受 / 拒绝

关键算法

Daugman’s Algorithm：主流商用方案，Gabor 滤波器 + 相位编码
Wavelet-Based：分析频率与方向性
CNN/深度学习：应对遮挡、低质量图像等挑战

优缺点

优点	缺点
极高准确率（误拒率/误识率极低） 非接触、远距识别 纹理终身稳定	使用复杂（需配合 NIR 光） 成本高 用户需配合（静止+注视） 眼镜/隐形眼镜/白内障干扰 户外光照变化影响性能

视网膜识别（Retinal Recognition）

基于**眼底血管网络**的独特模式（位于视网膜后部）
被认为是最**安全、最准确**的生物特征之一，但**非主流**（因需贴近设备）

工作流程

- 1. **图像捕获**：低强度红外光照射眼底 → CCD 摄像头采集血管图
- 2. **模式提取**：血管分支、交叉点、曲率等编码为模板
- 3. **匹配**：与数据库模板比对验证

优缺点

优点	缺点
极高精度（误识率 $\approx 10^{-7}$ ） 内部特征难伪造 不受表面污染影响	需用户高度配合（固定数秒） 设备昂贵且笨重 健康顾虑（部分人不适） 佩戴眼镜/白内障严重影响 不适用于户外/移动场景

人脸识别（Face Recognition）

人类面部提供距离与角度的2D/3D测量特征，用于身份判定

非接触、自然交互（无需用户主动配合），易被大众接受

Holistic 方法：分析整脸模式；**Feature-based 方法**：分离关键区域（如眼距、鼻宽、jawline）再匹配

优势：可远距操作、兼容现有摄像头、用户体验友好

局限：受光照、姿态、表情、遮挡（口罩/墨镜）、化妆显著影响

工作流程

- 图像采集**：2D 或 3D 相机捕获人脸图像
- 预处理**：
检测并定位人脸（Haar cascades, HOG, Deep learning）
对齐与归一化（旋转、缩放至标准姿态）
- 特征提取**（三大主流技术）：
Eigenfaces (PCA)：统计建模，降维至低维空间
Local Binary Patterns (LBP)：纹理特征，对光照鲁棒
Deep Learning Models (CNNs)：如 FaceNet、VGGFace、ArcFace —— 提取高维、鲁棒特征向量
- 匹配**：
计算相似度（余弦相似度、欧氏距离、汉明距离）
与数据库模板比对
- 决策**：
若相似度 $\geq$ 阈值 $\rightarrow$ 接受（Verification）或识别（Identification）
否则拒绝

关键算法

算法	核心思想	优点	缺点
PCA / Eigenfaces	将人脸投影到主成分空间（协方差矩阵特征向量）	计算高效；适合小数据集	对光照/姿态敏感；仅捕获全局变化
LDA / Fisherfaces	最大化类间散度、最小化类内散度	比 PCA 更抗干扰	仍依赖线性假设；需标签数据

算法	核心思想	优点	缺点
HOG	捕获边缘与梯度方向直方图	对 cluttered 背景鲁棒；常用于早期检测	无法建模复杂纹理；精度有限
LBP	局部邻域像素比较生成二进制码	计算快；光照不变性较好	忽略全局结构；对噪声敏感
CNNs (e.g., FaceNet, ArcFace)	端到端学习判别性特征嵌入 (embedding)	SOTA 准确率；强泛化能力；支持大规模训练	需大量标注数据；计算资源高；黑盒性

FaceNet：三元组损失 (Triplet Loss) → 学习紧凑嵌入空间，使同类距离小、异类距离大

ArcFace：Additive Angular Margin Loss → 在角度空间增强类间间隔，提升边界清晰度

Deep Metric Learning：将人脸映射为向量，同类近、异类远

Fisher Faces + LDA：结合 PCA 与 LDA 构建更鲁棒分类器

3D人脸识别 (3D Face Recognition)

原理：使用结构光/ToF/立体视觉传感器获取面部**深度图** (shape + texture)

优势：

不受光照影响 (依赖几何形状而非灰度)

可识别侧脸、部分遮挡场景

支持活体检测 (微表情/深度变化)

流程：

- Detection**：3D 扫描获取点云或深度图
- Alignment**：将人脸对齐至标准坐标系 (90°正视)
- Measurement**：亚毫米级精确测量曲面 (如鼻梁高度、颧骨凸度)
- Matching**：3D 模板 vs 数据库 → 若匹配成功 → 创建认证模板
- Verification/Identification**：基于 3D 形状匹配 (可融合 2D 纹理提升精度)

生物特征系统误差与风险

三大核心错误率

错误类型	定义	公式/说明
False Rejection Rate (FRR)	Type I Error: 合法用户被拒 (“真用户失败”)	$FRR = \frac{\text{合法用户被拒绝次数}}{\text{总合法尝试次数}}$
False Acceptance Rate (FAR)	Type II Error: 非法用户通过 (“假用户成功”)	$FAR = \frac{\text{非法用户被接受次数}}{\text{总非法尝试次数}}$
Crossover Error Rate (CER)	FRR = FAR 时的错误率 → 系统 整体性能指标	CER 越低，系统越优；典型指纹系统 CER ≈ 0.1%~1%

影响错误率的因素

- 传感器质量（分辨率、噪声）
- 环境条件（光照、湿度、角度）
- 用户状态（受伤、老化、化妆）
- 算法鲁棒性（是否含活体检测）
- 数据库规模（越大，FAR 易上升）

生物特征攻击方式与防御

攻击方式	描述	防御措施
Presentation Attack	使用伪造物（照片、面具、硅胶指纹）欺骗传感器	活体检测（Liveness Detection）：眨眼、微表情、3D深度、红外反射
Sensor Output Interception	截获参考模板并重放	加密传输 + 安全芯片（TEE/SE）存储模板
Reference/Database Compromise	窃取模板数据库用于批量伪造	模板保护技术： Cancelable Biometrics （可撤销变换）、 BioHashing 、 Homomorphic Encryption
Insider Threats	内部人员滥用权限 + 外部协同攻击	权限最小化 + 多因子审计 + 行为监控

生物特征 vs 密码

因素	生物特征	密码
安全性	高（难窃取，但非绝对）	低（易猜、易撞库、易钓鱼）
便利性	极高（无记忆负担）	低（需记忆/管理多密码）
可撤销性	不可撤销	可随时重置
防伪性	中（依赖活检技术）	低（纯文本易复制）
成本	中~高（硬件+算法）	极低
适用场景	物理门禁、移动设备、高安全系统	Web登录、基础账户

未来趋势与前沿方向

技术演进

- Contactless Biometrics**：后疫情时代爆发（人脸、虹膜、步态无感采集）
- AI/ML in Biometrics**：
 - 自监督/半监督学习 → 减少标注依赖
 - 联邦学习 → 保护隐私前提下联合建模
 - 生成对抗网络（GANs）→ 合成数据增强 + 防伪检测

Behavioral Biometrics: 持续认证（如打字节奏、握持手机姿态）
Biometric Blockchain: 去中心化存储模板哈希，防止单点泄露

安全增强方向

Skin Texture & Face Anti-Spoofing: 检测皮肤毛孔、微血管反射（NIR + multispectral imaging）
Multimodal Fusion: 人脸 + 声纹 + 步态 → 提升 CER 至 < 0.01%
Explainable AI for Biometrics: 可解释决策 → 满足 GDPR/合规审计需求

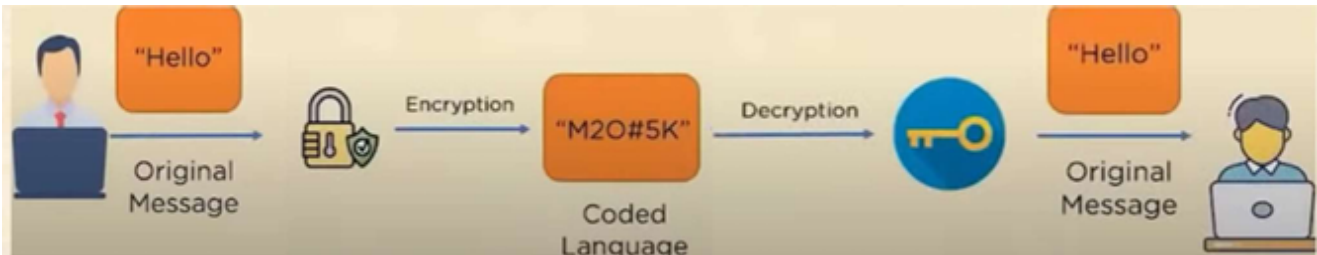
密码学

定义与目标

密码学 (*kryptós* = hidden, *graphein* = to write)
是利用数学技术保护通信与信息机密性的科学与艺术。
核心目标：确保通信中
机密性 (Confidentiality)：仅授权方能读取
完整性 (Integrity)：数据未被篡改
认证性 (Authentication)：确认发送者身份
不可否认性 (Non-repudiation)：发送者无法抵赖

基本术语定义

术语	定义
Plaintext (P)	原始可读消息（如 "HELLO"）
Ciphertext (C)	加密后的不可读数据（如 "XJ#94@K"）
Cipher / Encryption Algorithm	数学函数 $E_K(P) = C$ ，将明文→密文
Key (K)	控制加密/解密的密钥（秘密参数）
Encryption	$P \xrightarrow{E_K} C$ （明文 → 密文）
Decryption	$C \xrightarrow{D_K} P$ （密文 → 明文）



密码学类型 (Three Main Types)

类型	密钥机制	特点	典型算法
对称加密 (Symmetric Encryption)	单一密钥 (Secret Key) 用于加/解密	高速、适合大数据；密钥分发难	AES, DES, 3DES, RC4
非对称加密 (Asymmetric Encryption)	一对密钥：公钥 (Public) 加密，私钥 (Private) 解密	解决密钥分发问题；速度慢；支持数字签名	RSA, ECC, ElGamal
哈希 (Hashing)	无密钥；单向压缩函数	生成固定长度摘要；不可逆；用于完整性校验	SHA-256, SHA-3, MD5 (已弃用)

加密模式与算法细节

类型	说明	示例
Substitution Cipher	字符替换 (如 Caesar 移位)	ROT13, Vigenère
Transposition Cipher	字符重排 (位置变换)	Rail Fence, Columnar
Product Cipher	多轮组合：替换 + 置换 + 模运算	DES (16轮 Feistel)、AES (SubBytes + ShiftRows + MixColumns + AddRoundKey)

密钥长度

$$\text{Security} = \text{Strength of Algorithm} + \text{Length of Key}$$

算法再强，短密钥仍可被暴力破解；长密钥可补偿中等强度算法的不足。

密钥长度	组合数	暴力破解难度 (假设 10^6 keys/sec)
8 bits	$2^8 = 256$	≈ 0.000256 秒 (极 trivial)
56 bits (DES)	$2^{56} \approx 7.2 \times 10^{16}$	$\approx$ 2285 年 (单机) → 实际：专用硬件 (如 EFF Deep Crack) 可在 56 小时内 破解
64 bits	$2^{64} \approx 1.8 \times 10^{19}$	$\approx$ 585,000 年 (单机)
128 bits (AES-128)	$2^{128} \approx 3.4 \times 10^{38}$	$>$ 宇宙年龄 (138亿年) 的 10^{20} 倍 → 计算不可行
256 bits (AES-256)	$2^{256} \approx 1.1 \times 10^{77}$	量子计算机下 Grover 算法仅将复杂度降至 2^{128} ，仍安全

加密方法

Bit Stream Cipher (流密码)

原理：明文按位 (bit) 或字节 (byte) 逐位加密

实现：生成密钥流 K_i ，与明文异或：

$$C_i = P_i \oplus K_i$$

优点：实时性强、适合流数据（如 VoIP、无线通信）

代表：RC4（已不推荐）、ChaCha20（现代 TLS 首选）

Block Cipher（分组密码）

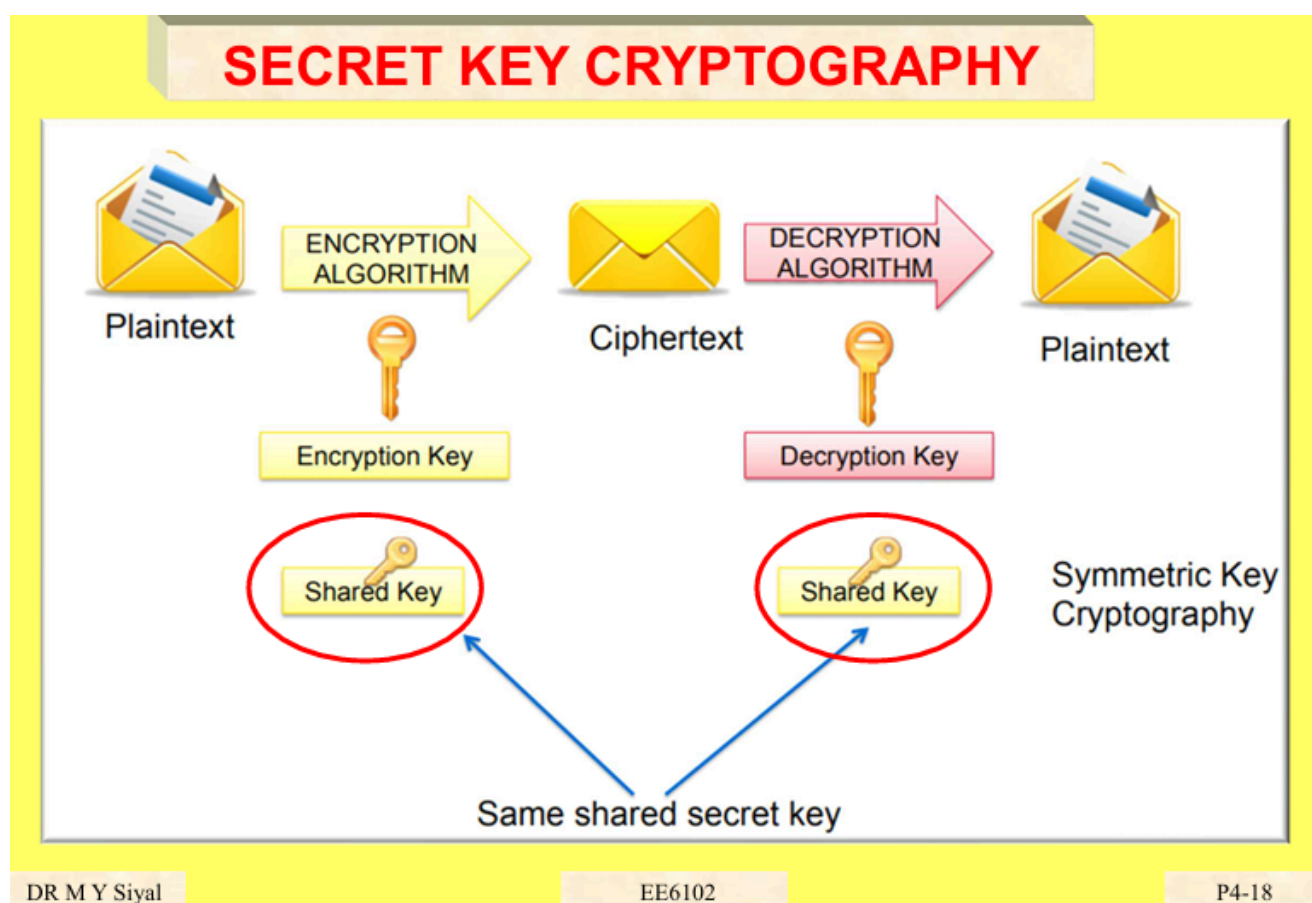
原理：明文分块（如 AES 为 128-bit 块），每块独立加密

典型结构：Feistel 网络（DES）或 Substitution-Permutation Network（AES）

ECB每个块独立加密

CBC下一个输入依赖上一个输出

秘密密钥密码学 (Secret Key Cryptography, SKC)



定义：使用**单个密钥**（Shared Key）同时进行加密和解密的消息传递方式，也称为**对称密钥密码学**。

核心问题：密钥分发（Key Distribution）。发送方和接收方必须在没有窃听者发现的情况下就密钥达成一致。

优缺点分析

优点 (Advantages):

速度 (Speed): 计算效率高，适合加密大量数据。

简单性 (Simplicity): 相比非对称密码学更容易实现。

广泛采用 (Wide Adoption): 用于 SSL/TLS、磁盘加密、文件加密等现实世界应用。

缺点 (Disadvantages):

密钥分发: 安全地共享密钥是一个主要挑战。

可扩展性 (Scalability): 在多用户网络中，管理每对用户之间的唯一密钥变得不切实际 (N 个用户需要 $N(N-1)/2$ 个密钥)。

流行算法

DES, 3DES, AES, CAST, RC系列 (Rivest), Blowfish, IDEA 等。

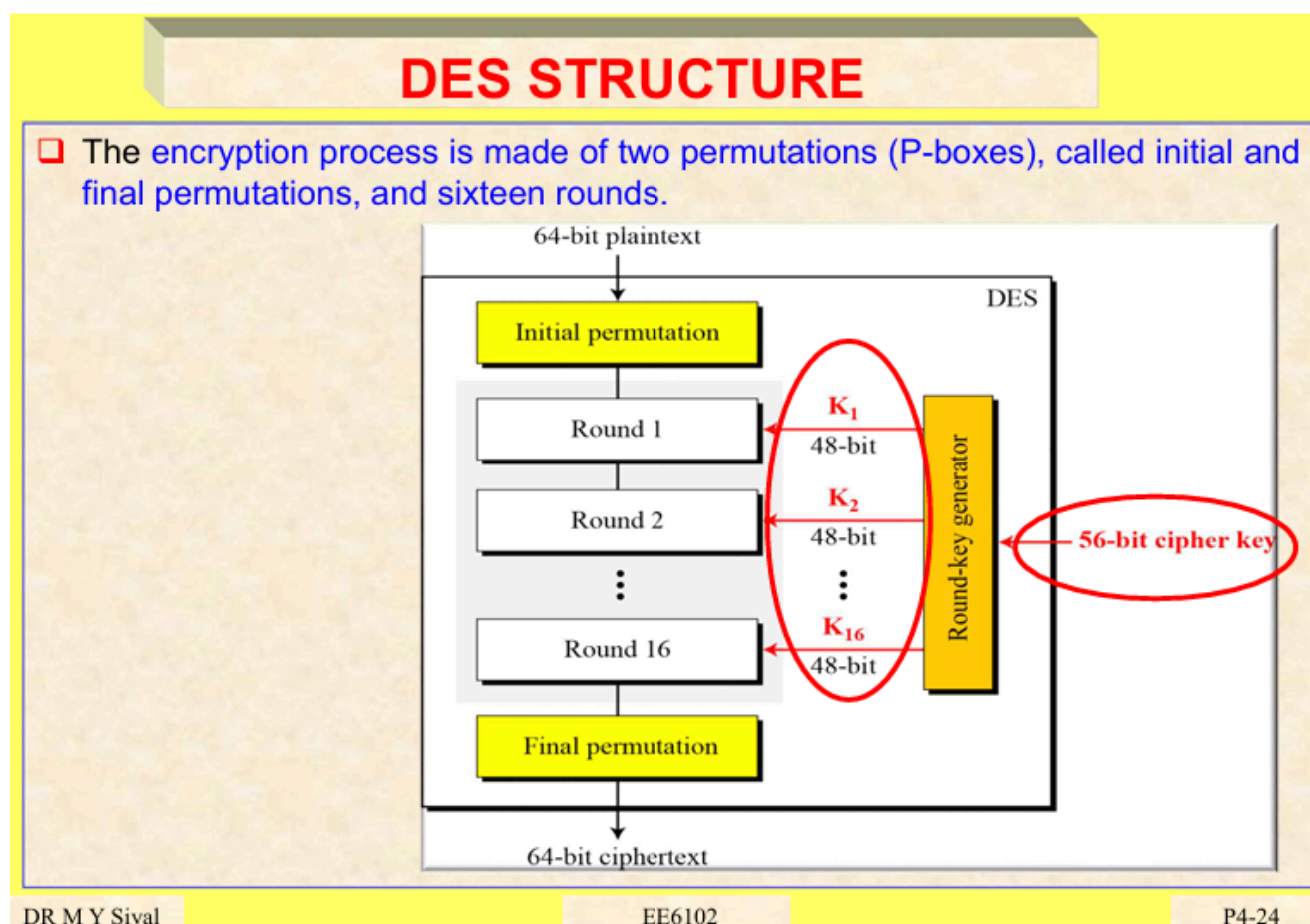
地位:

DES: 第一个用于商业应用的对称密钥算法。

3DES: DES 的临时替代方案。

AES: 当前的“黄金标准”，广泛用于商业和政府应用。

数据加密标准 (Data Encryption Standard, DES)



类型: 分组密码 (Block Cipher)。

分组大小: 64 位 (64 bits of plaintext $\rightarrow$ 64 bits of ciphertext)。

密钥长度: 56 位 (输入64位，其中8位用于奇偶校验，实际有效密钥为56位)。

结构:

基于密钥进行替换 (Substitution) 和置换 (Permutation/Transposition)。

对每个 64 位分组执行 **16 轮**操作。

包含初始置换 (Initial Permutation) 和最终置换 (Final Permutation)。

优缺点与现状

优点:

软硬件实现简单高效。

研究透彻，是密码学很好的教学工具。

缺点:

密钥太短 (56 bits): 容易受到暴力破解 (Brute-force) 攻击。

历史事件: 1998年，电子前沿基金会 (EFF) 建造了一台机器，在 **56 小时内**破解了 DES。

现状: 已过时，被 AES 取代。不再被认为对大多数应用是安全的，仅用于遗留系统或教育目的。

DES 争议

设计变更: 原始 Lucifer 算法密钥和分组均为 128 位。DES 将密钥降为 56 位，分组降为 64 位。

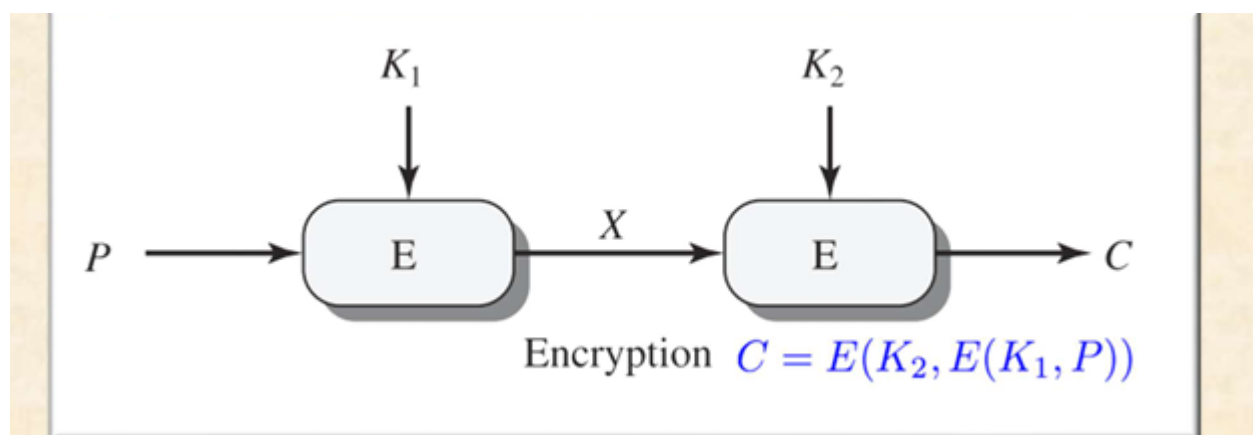
NSA 的介入:

美国政府声称缩短密钥是为了确保 DES 能被工业界（如金融服务）快速采用，因为这些领域当时对强加密的需求不高。

怀疑: 许多安全专家担心 56 位密钥长度不足，且怀疑 NSA 在 S 盒 (S-boxes) 设计中引入了“陷阱门” (Trapdoor)，使得 NSA 可以在不知道密钥的情况下解密数据。

结果: 后来的分析表明 S 盒的设计实际上是为了抵抗差分密码分析（当时未公开的技术），而非后门。

双重 DES (Double DES / 2DES)



原理: 使用 DES 两次，配合两个密钥 (K_1, K_2)。

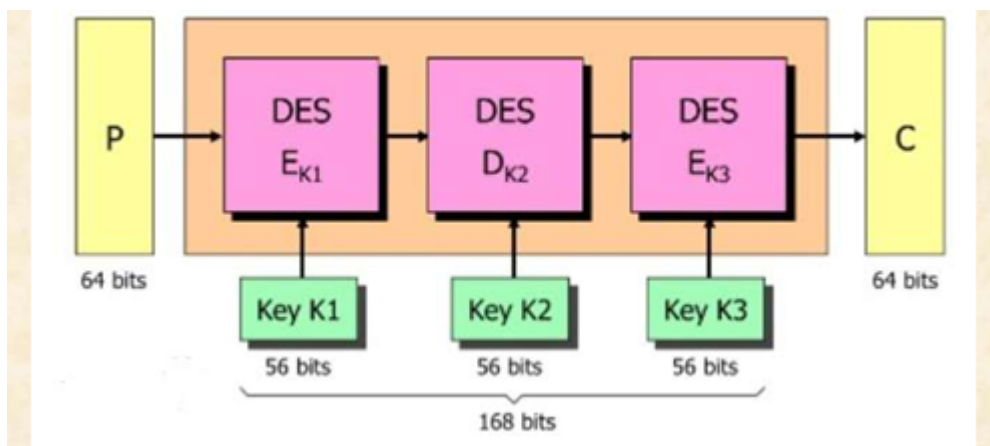
$$\text{总密钥长度} = 2 \times 56 = 112 \text{ bits}$$

$$C = E(K_2, E(K_1, P))$$

问题:

中间人攻击 (Meet-in-the-middle attack): 利用已知的明文/密文对，可以以极高的置信度猜测密钥对。其计算复杂度并没有显著高于破解单次 DES。

三重 DES (Triple DES / 3DES)



原理：DES 的变体，通过 DES 算法三次。

流程：加密 → 解密 → 加密 (E-D-E)。

$$C = E_{K3}(D_{K2}(E_{K1}(P)))$$

特点：

速度是普通 DES 的 3 倍慢，但安全性提高了数十亿倍（如果使用得当）。

比 DES 更能抵抗暴力破解。

是 AES 出现之前的良好过渡标准。

密钥配置：

通常使用 3 个密钥 (K_1, K_2, K_3)，总长 168 位（有效 112 或 168 位，取决于实现）。

常见配置： $K_1 = K_3$ 。这样如果 $K_1 = K_2 = K_3$ ，则退化为普通 DES（兼容性）。

现状：虽然比 DES 强，但也有弱点，正逐渐被 AES 取代。

高级加密标准 (Advanced Encryption Standard, AES)

类型：对称分组密码。

分组大小 (Block Size)：固定为 128 bits。

密钥大小 (Key Size)：支持 128, 192, 或 256 bits。

轮数 (Rounds)：取决于密钥长度。

128 位密钥 → 10 轮

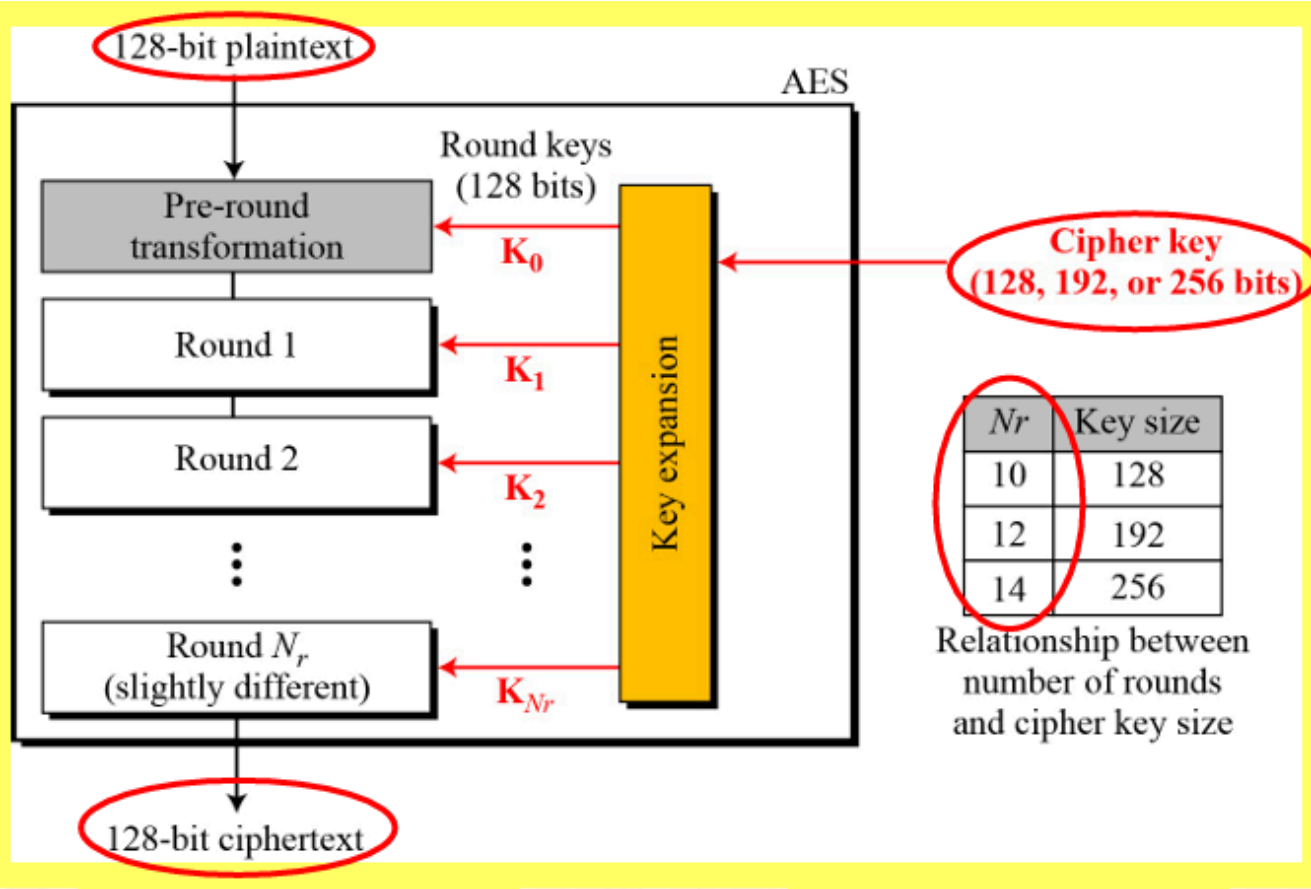
192 位密钥 → 12 轮

256 位密钥 → 14 轮

与 DES 不同，AES 不仅仅使用替换和置换。

多轮操作：每一轮包含多个步骤：

1. **SubBytes** (替换字节)
2. **ShiftRows** (行移位)
3. **MixColumns** (列混合)
4. **AddRoundKey** (轮密钥加)



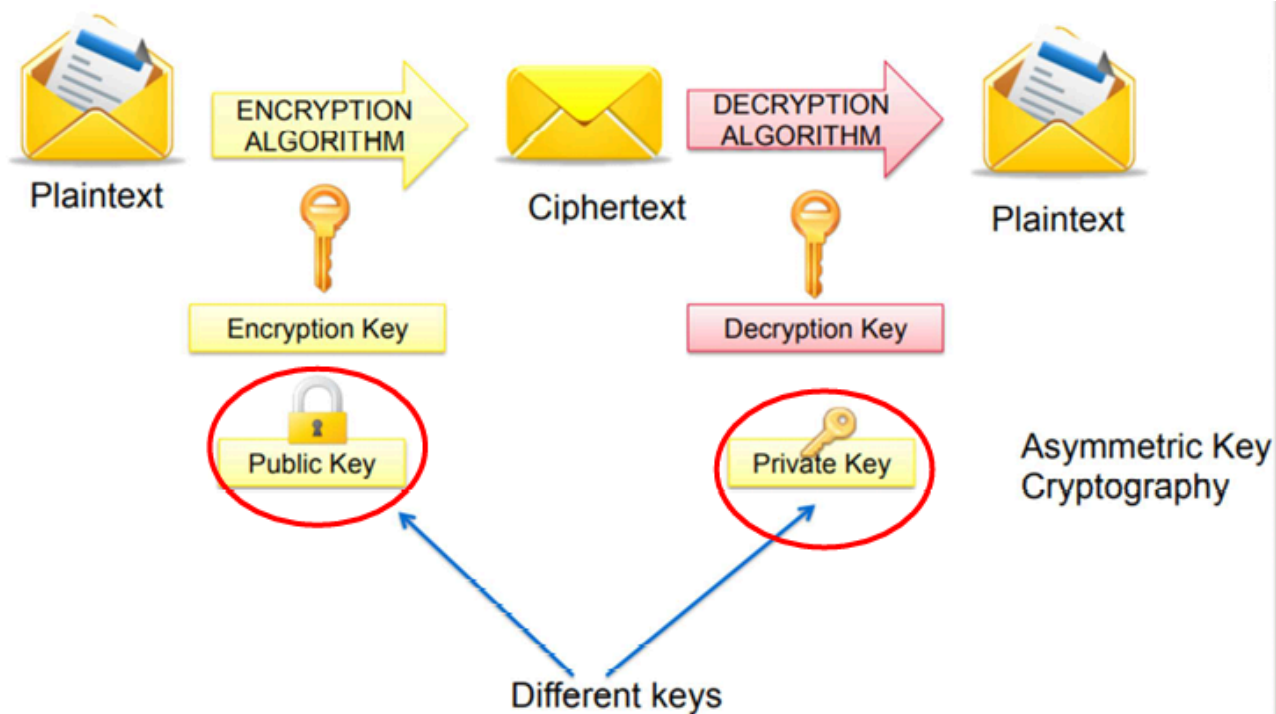
抗暴力破解：AES-128 有 2^{128} 种可能的密钥（约 3.4×10^{38} ），以目前的计算机能力是不可能破解的。

现状：目前没有实际的攻击能破解 AES，它仍然是安全的。

算法对比：DES vs AES vs Rijndael

特性	DES	AES	Rijndael (原始算法)
分组大小 (Block Size)	64 bits	128 bits (固定)	可选 (128, 160, 192, 224, 256 bits)
密钥大小 (Key Size)	56 bits (有效)	128, 192, 256 bits	可选 (同分组大小)
安全性	已过时 (Obsolete)	极高 (Current Standard)	高
结构	Feistel 网络 (16 轮)	替换-置换网络 (SPN)	替换-置换网络 (SPN)

公钥密码学 (Public Key Cryptography)



对称算法的局限性

优点：速度快，计算需求少。

主要弱点：

地理上分散的双方必须拥有完全匹配的密钥。

安全密钥交换 (Secure key exchange) 是一个问题。

概念

定义：使用两个不同但相关的密钥。

机制：

任一密钥都可以加密或解密消息。

如果 密钥 A 加密，只有 密钥 B 能解密。

一个密钥作为私钥 (Private Key) 保密，另一个作为公钥 (Public Key) 公开。

常见算法：Diffie-Hellman, El-Gamal, RSA, 椭圆曲线 (Elliptic Curve)。

详解

两个密钥：

公钥 (Public-Key)：任何人都可以知道。用于加密消息和验证签名。

私钥 (Private-Key)：只有接收者知道。用于解密消息和创建 (签署) 签名。

数学关系：密钥在数学上是相关的，但从公钥推导出私钥在计算上是不可行的。

主要用途

1. 公钥加密 (Public Key Encryption)：

用接收者的公钥加密消息。

只有拥有匹配私钥的人才能解密。

目的：确保机密性 (Confidentiality)。

2. 数字签名 (Digital Signatures):

用发送者的**私钥**对消息进行签名（加密）。

任何拥有发送者**公钥**的人都可以验证签名。

目的：确保消息来自该公钥的持有者，且未被篡改（完整性与认证）。

问题：如何证明某个公钥是正确的且未被篡改？

解决方案：使用公钥基础设施 (PKI)，其中一方或多方第三方（称为**证书颁发机构 CA**）认证密钥对的所有权。

Diffie-Hellman

定义：一种仅用于密钥交换的公钥算法，不用于加密或解密消息本身。

地位：当今最常用的加密协议之一。

用途：

安全套接字层 (SSL) 协议的电子密钥交换方法。

使两个以前没有联系过的人能够共享一个秘密密钥。

安全性基础：离散对数问题 (Discrete Log Problem)。

函数： $y = f(x) = g^x \pmod{p}$

容易：已知 g, x, p ，计算 y 很容易。

困难：已知 y, g, p ，计算 x 非常困难。

素数 p 的**原根 (primitive root)** 是指其幂次能生成从 1 到 $p - 1$ 的所有整数的数。

步骤 1：全局公共元素 (Global Public Elements)

选择任意素数： q

选择 q 的原根： a (满足 $a < q$)

步骤 2：用户 A 的密钥生成 (Key Generation by User A)

选择一个随机数作为私钥 X_A ，其中 $X_A < q$

计算公钥 Y_A ：

$$Y_A = a^{X_A} \pmod{q}$$

步骤 3：用户 B 的密钥生成 (Key Generation by User B)

选择一个随机数作为私钥 X_B ，其中 $X_B < q$

计算公钥 Y_B ：

$$Y_B = a^{X_B} \pmod{q}$$

步骤 4：交换公钥 (Exchange Public Keys)

用户 A 将公钥 Y_A 发送给用户 B

用户 B 将公钥 Y_B 发送给用户 A

步骤 5：用户 A 生成共享密钥 (Key Generation by User A)

计算共享密钥 K_A ：

$$K_A = (Y_B)^{X_A} \pmod{q}$$

步骤 6：用户 B 生成共享密钥 (Key Generation by User B)

计算共享密钥 K_B ：

$$K_B = (Y_A)^{X_B} \mod q$$

注意：最终计算出的密钥是相同的，即 $K_A = K_B$ 。

RSA

安全性基础：基于大数分解的困难性 (difficulty of factoring large numbers)。

每个用户通过随机选择两个大素数来生成公钥/私钥对： p, q 。

1. 计算乘积 (模数):

$$N = p \times q$$

2. 计算欧拉函数 (z 或 $\phi(N)$):

$$z = (p - 1)(q - 1)$$

(这也称为 $\phi(N)$)

3. 选择加密密钥 (公钥 e):

随机选择 e ，满足 $1 < e < \phi(N)$ 且 $\gcd(e, \phi(N)) = 1$ 。

$0 < e < \phi(n)$ (在 1 和 $\phi(n)$ 之间)

e 应该是一个素数

e 和 $(p - 1)$ 以及 $(q - 1)$ 不应该有公因数

4. 计算解密密钥 (私钥 d): 求解方程找到 d :

$$e \cdot d \equiv 1 \mod \phi(N)$$

且 $0 < d < \phi(N)$ 。

这意味着 $e \times d = k \cdot \phi(n) + 1$

或者 $d = (k \cdot \phi(n) + 1) / e$ (寻找整数 k 使得结果无余数)

5. 发布与保密:

公钥 (Public Key): (e, N)

私钥 (Private Key): (d, N) (注意：通常只说 d 是私钥，但 N 也是必需的)

加密消息 (Encrypt): 发送者获取接收者的公钥 (e)。

$$C = M^e \mod N$$

(其中 $0 \leq M < N$)

解密密文 (Decrypt): 所有者使用其私钥 (d)。

$$M = C^d \mod N$$

注意：消息 M 必须小于模数 N 。

其他公钥算法 (Other Public Key Algorithms)

ElGamal

设计者：Taher Elgamal (1985)。

基础：基于 Diffie-Hellman 的原始思想。

安全性: 基于离散对数问题的困难性 (assumed difficulty of discrete log)。

组成: 包含加密和签名算法。

特点:

密文大小是明文的两倍 (Cipher text is twice the size of plain text)。

速度较慢 (It is slow)。

椭圆曲线密码学 (Elliptic Curve Cryptography, ECC)

提出者: Neal Koblitz 和 Victor Miller (1985)，但在 2005 年才广泛使用。

对比 RSA:

RSA (D-H) 使用大数，给密钥和消息的存储及处理带来巨大负担。

ECC 使用椭圆曲线，以**更小的位数 (smaller bit sizes)** 提供相同的安全性。

现状: 尽管 RSA 仍被广泛使用，但 ECC 变得越来越流行，特别是在**加密货币 (crypto currencies)** 中。

等效安全性的密钥大小比较 (Comparable Key Sizes)

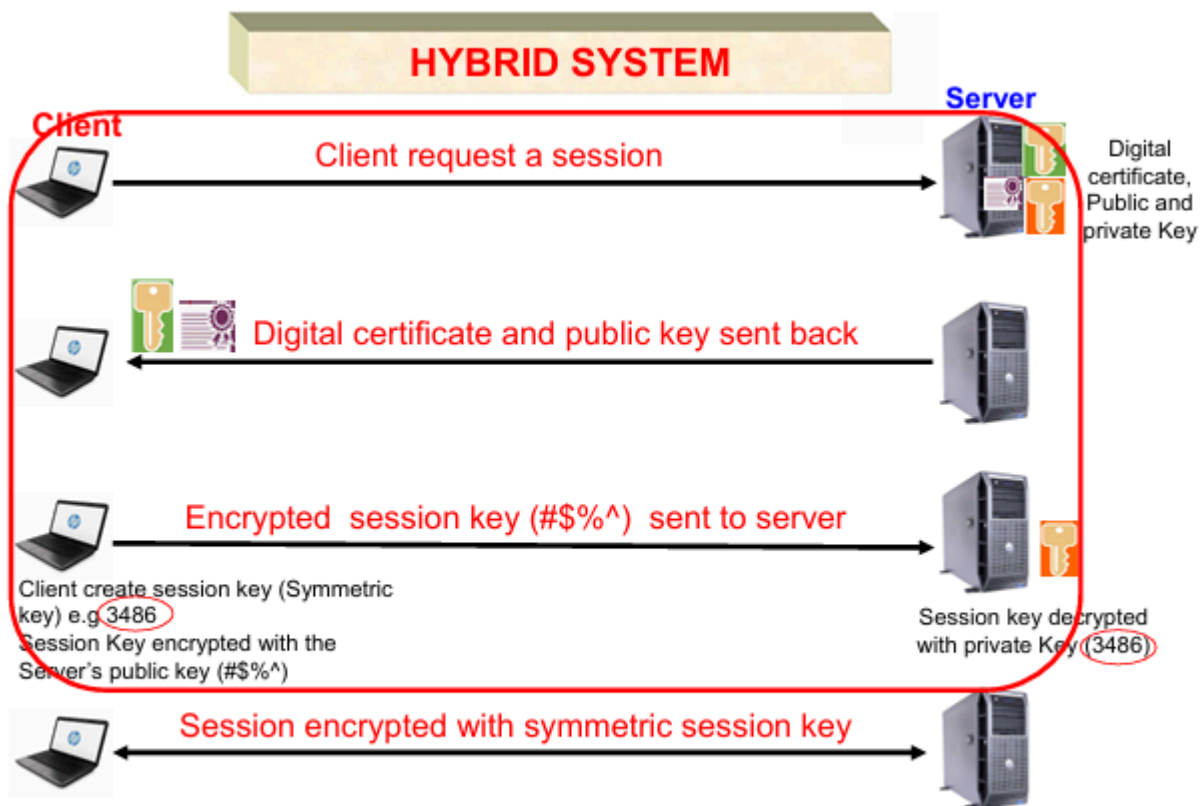
为了达到相同的安全级别，不同算法需要的密钥长度差异巨大：

Symmetric scheme	ECC-based scheme	RSA
56	112	512
80	160	1024
112	224	2048
128	256	3072
192	384	7680
256	512	15360

公钥 + 对称加密 (混合系统) (Public Key + Symmetric / Hybrid System)

问题: 公钥系统功能强大但**慢 (slow)**；对称系统**快 (fast)** 但密钥分发困难

解决方案: 混合系统 (Hybrid system)。



DR M Y Siyal

EE6102

P4-99

1. 发送方生成一个随机的**对称会话密钥 (symmetric session key)**。
2. 发送方使用**公钥加密 (PK crypto)** 加密这个会话密钥。
3. 发送方使用**会话密钥**加密实际消息 (使用对称密码)。
4. **结果:** 一个快速、灵活的系统。
结合了对称和非对称密码的优点。
拥有对称密码的吞吐量 (Throughput)。
拥有非对称密码的密钥管理 (Key management)。
- 两步法 (Two-stage approach):**
5. 使用公钥密码学**共享会话密钥**。
6. 随后, 使用该会话密钥**加密实际消息**。

数字签名与证书 (Digital Signature and Certificates)

在当今的数字世界中, 通过不安全的通道发送文件时需要**真实性 (Authenticity)**。
有了真实性, 我们可以保护自己免受试图利用他人身份的恶意第三方的侵害。

手写签名 vs. 数字签名

特性	手写签名 (Hand-Written)	数字签名 (Digital)
物理部分	文件的物理部分 (Physical part)	无物理部分 (No physical part)
验证方式	通过与真实签名比较来验证	通过 publicly known algorithm (公开已知算法) 验证

特性	手写签名 (Hand-Written)	数字签名 (Digital)
伪造难度	容易伪造 (Easy to forge)	难以伪造 (Hard to forge)

数字签名的用途：提供信任，证明内容来自声称的源且未被篡改。

基本特征：

1. 签名算法 (A signing algorithm)
2. 验证算法 (A verification algorithm)

数字签名 (Digital Signatures)

定义：数字签名（“数字指纹”）是一种用于以加密方式签署消息的消息摘要 (message digest)。

基础：依赖于**非对称 (公钥) 密码学**。

创建过程：使用你的**私钥 (Private Key)** 签署消息。

两个主要效果：

1. **完整性 (Integrity)：**由于消息摘要算法的特性，消息的任何更改都可以被检测到。
2. **不可抵赖性 (Non-repudiation)：**你无法否认签署了消息，因为它是用你的私钥签署的。

应用：

电子商务应用的有用组件。

用于所有电子通信。

它是附加到文档上的电子印章或标记。

确保文档在传输过程中保持不变。

属性 (Properties)

只有**私钥持有者**可以计算签名。

任何持有匹配**公钥**的人都可以验证签名。

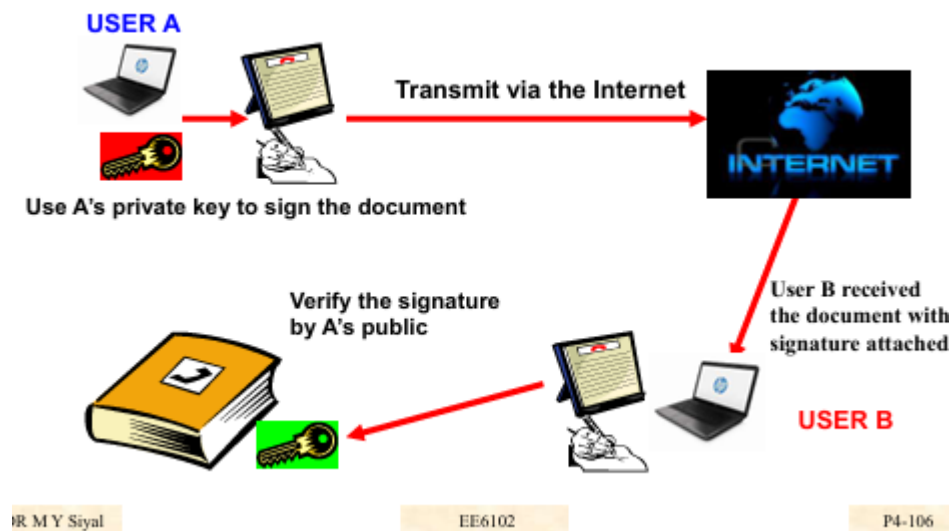
两个主要步骤：

1. 准备消息代表 (Prepare a message representative)。
2. 应用签名变换 (Apply a signature transform)。
通用验证方法 (通常类似于签名方法)：
3. 撤销签名变换 (Undo the signature transformation)。
4. 检查消息摘要是否有问题 (Check the message digest for any issues)。

如何工作？ (How Does Digital Signing Work?)

1. 我们使用**哈希函数 (Hash Function)** 从消息中提取一个值（二进制串）。
2. 我们使用**数字签名算法**和**私钥**从哈希值生成签名。
3. 现在可以使用**公钥**和签名对消息进行认证。
4. **用户 A (发送者)：**使用 A 的私钥签署文档。

5. **传输**：通过互联网传输。
6. **用户 B (接收者)**：收到带有附加签名的文档。
7. **验证**：使用 A 的公钥验证签名。



数字签名方案 (Digital Signature Scheme)

包含两个组件：

1. **私有签名算法**：允许用户安全地签署消息。
2. **公共验证算法**：允许任何人验证签名是真实的。

哈希 (Hashing) 的作用

哈希算法应用于任何长度的位串。

设计使得消息中的每一位都对生成的消息摘要产生影响。

消息摘要作为输入进入数字签名算法 (DSA)，生成或验证签名。

流程：

任意长度的位串 $\xrightarrow{\text{哈希算法}}$ 哈希：小固定长度的位串

属性 (Properties)

1. **任意大小**：可应用于任何大小的数据块。
2. **固定长度输出**：产生固定长度的输出 (Produces a fixed-length output)。
3. **易计算**：对于任何给定的 x ，计算 $H(x)$ 相对容易。
4. **单向性 (One-way / Pre-image resistant)**：
计算上不可行找到 x 使得 $H(x) = h$ 。
5. **抗碰撞性 (Collision resistant)**：
计算上不可行找到 $y \neq x$ 使得 $H(y) = H(x)$ 。

详解 (Hashing Details)

定义：执行单向加密的特殊数学函数。

特性：

一旦处理，无法使用密文恢复明文。
无法生成两个计算出相同哈希值的不同明文。

流行算法：

SHA (Secure Hash Algorithm) 系列。

MD (Message Digest) 系列。

SHA 版本：

SHA-1：已被发现易受碰撞攻击 (vulnerable to a collision attack)。

SHA-2：更新版本，包括 SHA-256, SHA-384, SHA-512。

具有更长的哈希结果，更难成功攻击。
需要更多的处理能力。

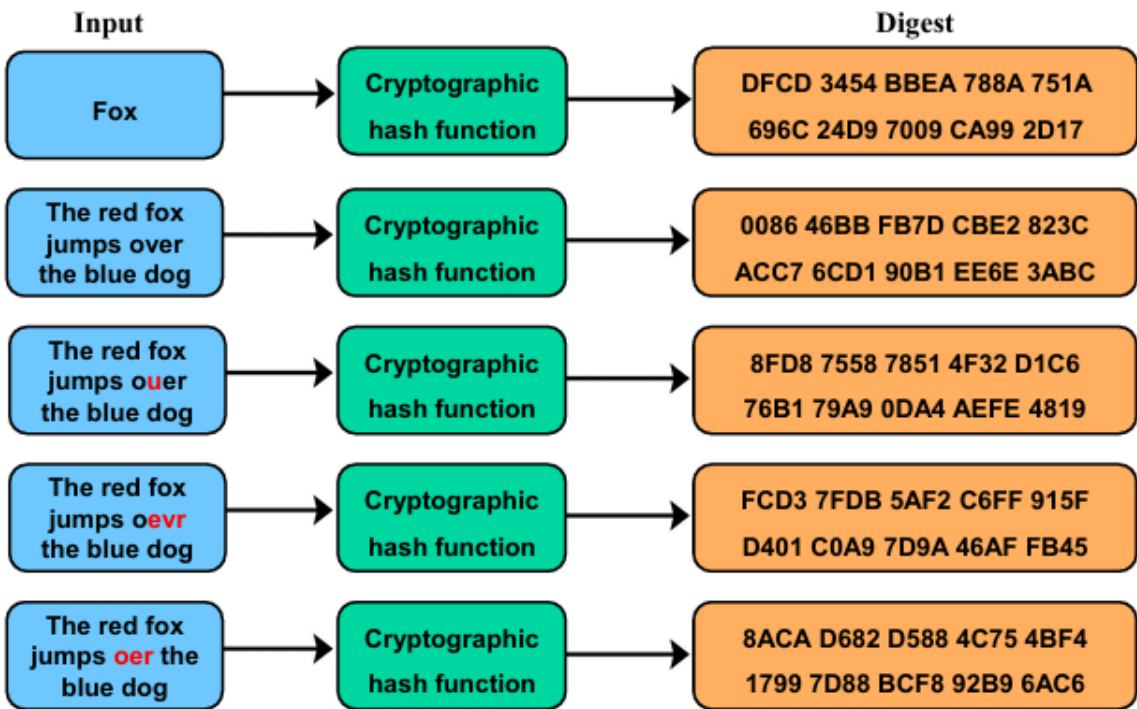
加密 vs. 哈希 (Encryption vs. Hashing)

特征	加密 (Encryption)	哈希 (Hashing)
结果长度	与明文长度大致相同	短固定长度，无论消息长度如何
可逆?	是 (解密)	否 (无法从短哈希恢复长原始消息)

雪崩效应 (Avalanche Effect)

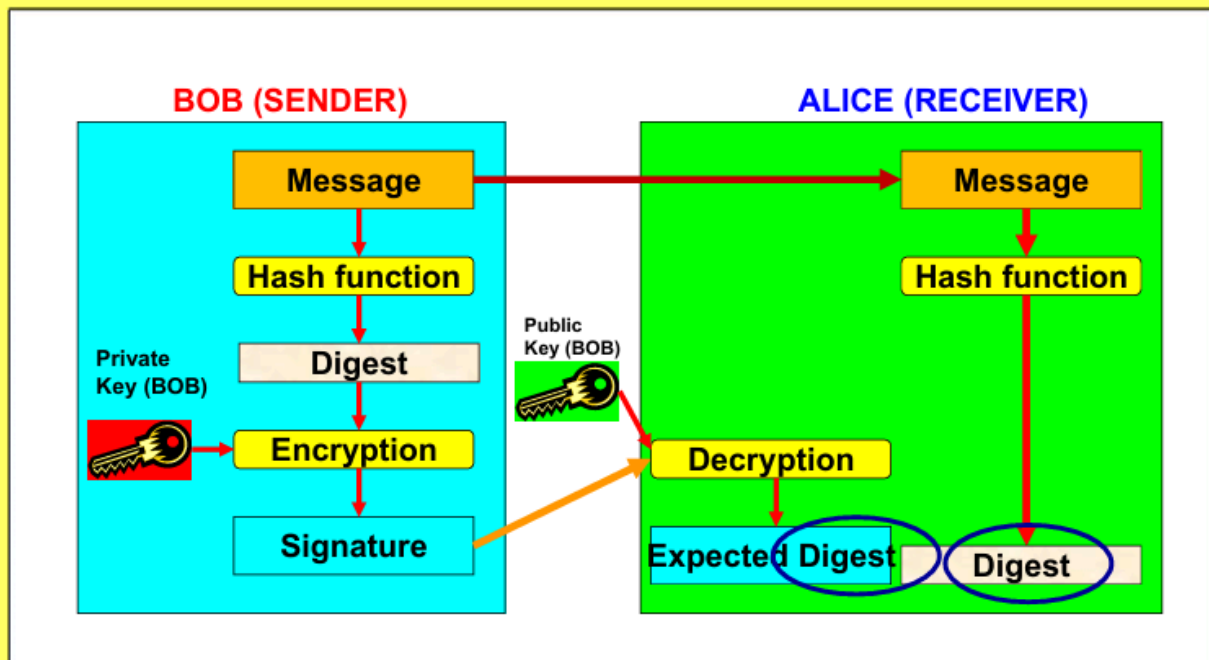
即使源输入发生微小变化（例如单词 "over" 改为 "occur"），也会导致输出发生剧烈变化。

over) drastically change the resulting output.



数字签名流程图 (Digital Signature Diagrams)

DIGITAL SIGNATURE (WITHOUT MESSAGE PROTECTION)

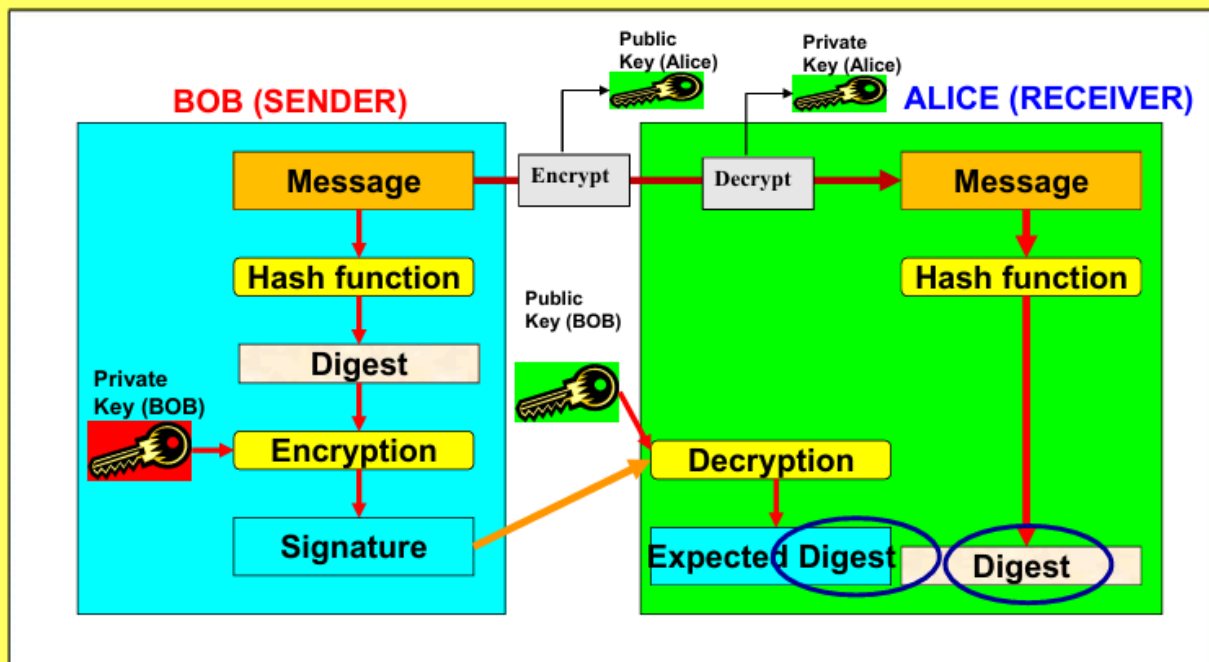


DR M Y Siyal

EE6102

P4-112

DIGITAL SIGNATURE (WITH MESSAGE PROTECTION)



DR M Y Siyal

EE6102

P4-113

寻找真实方的公钥 (Finding the True Party's Public Key)

不能直接使用发送者的公钥，因为它总是能“验证”发送者的数字签名（如果是伪造的公钥）。
通常需要一个**数字证书 (Digital Certificate)**。
文件由**认证机构 (Certificate Authority, CA)** 提供。
认证机构必须是可信的。
数字证书的作用：提供主体（真实方）的名称和公钥。

持有公钥的实体信息（名称、地址、生日、邮箱等）。
包含由 CA 私钥签名的 SHA-1 哈希值。

数字证书与认证机构 (Digital Certificates & Certificate Authorities)

数字证书：一种电子文档，类似于数字签名，附加在文件上，证明该文件来自其声称的组织，且自原始格式以来未被修改。
认证机构 (CA)：管理证书颁发并作为电子公证人验证其价值和完整性的机构。
作用：对于数字签名，需要一个受信任的第三方（即 CA）来签发数字证书，以认证用户和组织的电子身份。

X.509 数字证书字段 (X.509 Digital Certificate Fields)

X.509 是定义公钥证书格式的标准。

字段 (Field)	描述 (Description)
版本号 (Version Number)	X.509 标准的版本号。大多数证书遵循 版本 3 。不同版本有不同的字段。
颁发者 (Issuer)	证书颁发机构 (CA) 的名称。
序列号 (Serial Number)	由 CA 设置的 唯一序列号 。序列号允许接收者检查证书是否已被 CA 撤销。
主体 (Subject) (True Party)	证书颁发给的个人、组织、计算机或程序的名称。这是 真实方 。
公钥 (Public Key)	主体（ 真实方 ）的公钥。证书提供了真实方的公钥。
公钥算法 (Public Key Algorithm)	主体用于签名消息的算法。
数字签名 (Digital Signature)	证书的数字签名，由 CA 使用其自己的私钥签名。用于测试证书的真实性和完整性。用户必须独立知道 CA 的公钥。
签名算法标识符 (Signature Algorithm Identifier)	CA 用于签署其证书的数字签名算法。
其他字段 (Other Fields)	...

注意：CA 使用自己的私钥对证书进行签名，以便可以检查证书的有效性是否被篡改。

验证数字证书 (Verifying the Digital Certificate)

验证过程包括三个主要步骤：

1. 测试数字签名 (Testing the Digital Signature):

数字证书拥有自己的数字签名。

使用**证书颁发机构 (CA) 的私钥**签名。

必须使用 CA 的众所周知的**公钥**进行测试。

如果测试通过，证书是真实且未修改的。

2. 检查有效期 (Checking the Valid Period):

证书仅在数字证书内的有效期内有效。

如果当前时间不在有效期内，拒绝该数字证书。

3. 检查撤销 (Checking for Revocation):

证书可能因行为不当或其他原因被撤销。

必须测试撤销状态。

不能仅通过查看证书内的字段来完成（需要查询 CRL 或 OCSP）。

接收者必须与 **CA** 检查。

如何获取数字证书 (How to Obtain a Digital Certificate)

1. Generate Key-pair

2. User-A requests CA Certificate

3. CA responds with its CA Certificate including its Public Key

4. Gather information

5. Request the Certificate which has User-A's identity and Public Key

6. CA verifies the identity of User-A

7. Issue the Certificate for User-A

1. **生成密钥对**：用户生成公钥/私钥对。

2. **请求证书**：用户 A 向 CA 请求证书。

3. **CA 响应**：CA 回复其 CA 证书（包含其公钥）。

4. **收集信息**：用户 A 准备身份信息。

5. **提交请求**：请求包含用户 A 身份和公钥的证书。

6. **验证身份**：CA 验证用户 A 的身份。

7. **颁发证书**：CA 向用户 A 颁发证书。

Web 安全 (Web Security)

Web 被广泛使用，但互联网和 Web 很脆弱，因为它使用 **HTTP (Hyper Text Transfer Protocol)**。

HTTP 是一个运行在 TCP/IP 之上的简单无状态客户端/服务器应用程序。

1. **完整性 (Integrity)**：数据修改、插入。

- 2. 机密性 (Confidentiality): 网络窃听 (Eavesdropping)、从服务器机器窃取。
- 3. 认证 (Authentication): 冒充、数据伪造。
- 4. 拒绝服务 (Denial of Service): 被黑的 Web 服务器。

HTTP 与 HTTPS (HTTP and HTTPS)

HTTP 方法

- GET: 检索数据。
- POST: 发送数据 (如表单提交)。
- PUT: 更新数据。
- DELETE: 删除数据。
- HEAD: 仅检索头部。

HTTPS (HTTP Secure)

- 它是超文本传输协议的安全扩展。
- 加密方式: 由 TLS/SSL 加密。
- 公式: `HTTPS = HTTP + TLS`
- 端口:
 - HTTP 使用端口 **80** (无加密, 不安全)。
 - HTTPS 使用端口 **443** (使用加密, 安全)。

对比表

特性 (Feature)	HTTP	HTTPS
安全性 (Security)	未加密 (Unencrypted)	加密 (TLS/SSL)
认证 (Authentication)	无认证	验证服务器身份
数据完整性 (Data Integrity)	数据可被修改	数据不能被篡改
性能 (Performance)	更快 (无加密开销)	稍慢 (TLS 握手)

SSL/TLS (Secure Socket Layer / Transport Layer Security)

- Web 和电子邮件是 99% 成功漏洞攻击的关键点。
- SSL (Secure Socket Layer): 由 Netscape 设计, 专为 Web 安全设计。
- TLS (Transport Layer Security): SSL 的继任者。
- 安全 HTTP 协议: `HTTP + TLS/SSL`
- 浏览器标识: 锁形图标 (🔒) 和 `https://` 前缀表示连接安全。

SSL 历史

- SSLv1: Netscape 内部设计 (1994), 因安全问题未发布。
- SSLv2: 随 Navigator 1.0 发布 (1994), 易受中间人攻击。

SSLv3: 由 **Netscape** 和 **Paul Kocher** 设计 (1996)，使用公钥/私钥对。
SSL 易于应用和使用，因为它内置于所有主要 Web 浏览器和服务端中。

TLS 发展

1990 年代末，Netscape 将 SSL 移交给 **IETF (Internet Engineering Task Force)**。
IETF 将 SSL 3 重命名为 **TLS 1.0** (1999)，并使 SSL 在 2015 年过时。

TLS 1.3 (2018) 是最新版本。

尽管大多数服务已切换到仅支持 TLS，但许多人仍将 Web 加密称为 SSL。

密钥大小 (Key Size for SSL/TLS)

SSL/TLS 使用两种不同类型的加密速率：

公钥/私钥 (Public/Private Key)

512 位 被认为很弱，可以被破解。

1024 位 被认为是脆弱的，可能会被破解。

大多数提供商鼓励生成 **2048 位** 的密钥。

会话密钥 (Session Key)

每次有人连接到网站时，在 SSL/TLS 握手过程中生成。

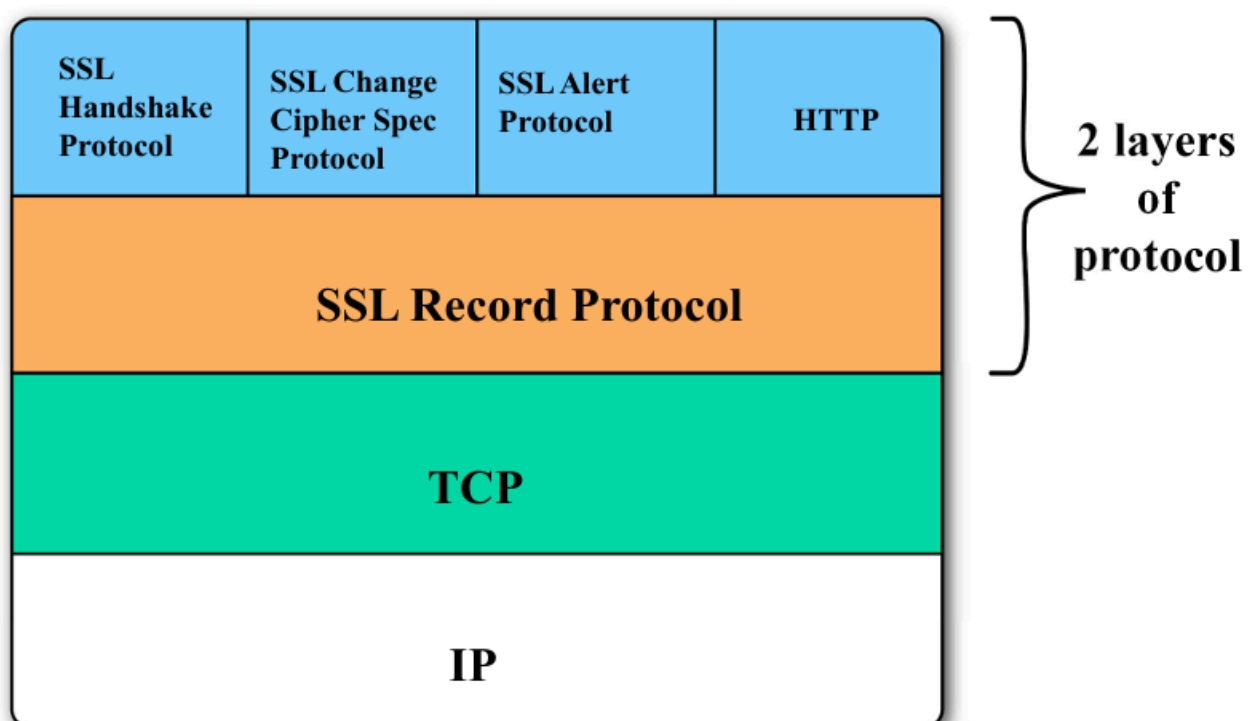
它比公钥/私钥短，因为只有一个会话的数据面临风险，且这减轻了服务器的负载。

如果浏览器支持 256 位但 Web 服务器仅支持 128 位，则 SSL 连接将为 **128 位**。

会话密钥通常在 **40 位到 256 位** 之间。

任何低于 **128 位** 的密钥都被认为是不安全的。

架构 (SSL/TLS Architecture)



会话 (Session)

客户端和服务端之间的关联。

由**握手协议 (Handshake Protocol)** 创建。

定义安全加密参数。

可以被多个连接共享。

连接 (Connection)

端到端的可靠安全通信。

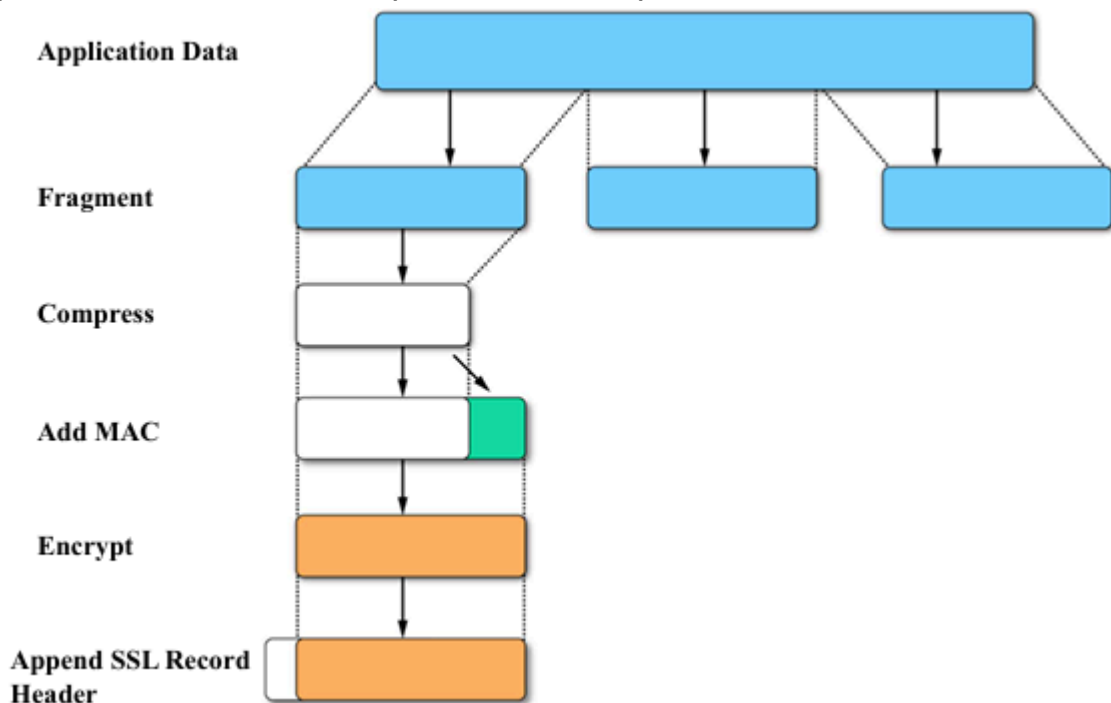
每个连接都与一个会话相关联。

SSL 记录协议 (SSL Record Protocol)

使用握手协议建立的共享密钥提供**机密性 (Confidentiality)** 和 **消息完整性 (Message Integrity)**。

处理应用数据的步骤如下：

1. **Fragment (分片)**: 将数据分成可管理的块。
2. **Compress (压缩)**: 可选的压缩步骤。
3. **Add MAC (添加消息认证码)**: 用于完整性验证。
4. **Encrypt (加密)**: 使用会话密钥加密。
5. **Append SSL Record Header (添加 SSL 记录头)**: 添加头部信息以便传输。



更改密码规范协议 (Change Cipher Spec Protocol)

一个非常简单的协议，使用记录协议。

导致待定状态变为当前状态，从而更新正在使用的密码套件。

警报协议 (Alert Protocol)

向对等方发送 SSL/TLS 相关警报。

警报消息被压缩和加密。

消息结构: 两个字节，一个定义致命/警告，另一个定义警报代码。

意外消息 (Unexpected message): 错误的 MAC，解压失败。

握手失败 (Handshake failure): 无共同点，非法参数。

证书问题: 无证书，坏证书，不支持的证书，证书被撤销，证书过期，证书未知。

SSL 握手协议 (SSL Handshake Protocol)

这是 SSL 中最复杂的部分，允许服务器和客户端：
相互认证。
协商加密和 MAC 算法。
协商要使用的加密密钥。
建立状态。

1. 建立安全能力 (Establish Security Capabilities)。
2. 服务器认证和密钥交换 (Server Authentication and Key Exchange)。
3. 客户端认证和密钥交换 (Client Authentication and Key Exchange)。
4. 完成 (Finish)。

发送者 (Sender)	消息名称 (Name)	语义/含义 (Semantics)
Client	Client Hello	客户端请求安全连接。列出支持的密码套件。
Server	Server Hello	服务器表示愿意继续。选择一个要在会话中使用的密码套件。
Server	Certificate	服务器发送包含其公钥的数字证书。
Server	ServerHello Done	服务器表示其部分已完成。
Client	ClientKey Exchange	客户端生成一个随机对称会话密钥。用服务器的公钥加密它。服务器使用会话密钥解密。双方现在拥有会话密钥。
Client	Change Cipher Spec	客户端将选定的密码套件从待用状态更改为活动状态。
Client	Finish	客户端表示其初始介绍部分已完成。

TLS 密钥交换 (TLS Key Exchange)

TLS 基于混合 (hybrid) 密码系统。

公钥密码学用于安全地交换密钥（双方共享），然后用于加密/解密交换的数据。

RSA 密钥交换 (RSA Key Exchange)

在 TLS RSA 密钥交换中，共享秘密由**客户端**决定。

客户端使用从证书中提取的**服务器公钥**对其进行加密，并将其发送给服务器。

Diffie-Hellman 密钥协议 (Diffie-Hellman Key Agreement)

客户端和服务器都通过创建公钥和私钥对开始。

然后他们将公钥部分发送给另一方。

当每一方收到另一方的公钥共享部分时，他们将其与自己的私钥结合，最终得到相同的值：**预主密钥 (pre-master secret)**。

服务器使用数字签名来确保交换未被篡改。

这种密钥交换称为"临时" (ephemeral)：如果客户端和服务器都选择为每次交换使用新的密钥对。

TLS 1.3 密钥交换 (TLS 1.3 Key Exchange)

RSA 模式的缺点

RSA 模式有一个严重的缺点：**它不是前向保密 (not forward secret)**。

这意味着如果有人记录了加密的对话，然后获得了服务器的 RSA 私钥，他们就可以解密对话。

即使对话是在过去记录的，而密钥是很久以后才获得的，这也适用。

TLS 1.3 的改进

为了降低风险，RSA 加密已从 TLS 1.3 中移除。

留下了**临时 Diffie-Hellman (Ephemeral Diffie-Hellman)** 作为唯一的密钥交换机制。

TLS 1.3 握手阶段 (TLS 1.3 Handshaking Phase)

TLS 1.3 握手比其前身显著缩短。

1. **Client Hello**: 启动握手。TLS 1.3 将支持的密码套件从 37 个减少到 5 个。这意味着客户端可以猜测将使用哪种密钥协议/交换协议，并直接从该协议发送其密钥共享。
2. **Server Hello**: 服务器响应自己的密钥共享部分，计算会话密钥，并以服务器完成消息结束。
3. **认证**: 客户端将验证 SSL 证书并使用两个密钥共享来计算其自己的会话密钥副本。完成后，它发送自己的 Finished 消息。

密钥是使用 **临时 Diffie-Hellman (EDH 或 DHE)** 生成/共享的。

允许的三种主要签名算法是：**RSA (签名仅)**，**椭圆曲线数字签名算法 (ECDSA)**，和 **Edwards 曲线数字签名算法 (EdDSA)**。

TLS 1.2: 需要更多的往返 (Round Trips) 来完成握手 (通常是 2-RTT)。

TLS 1.3: 优化为 1-RTT (甚至 0-RTT 恢复)，显著减少了延迟。

TLS 1.3 带来的安全性提升 (Improved Security with TLS 1.3)

虽然如果配置正确，TLS 1.2 是安全的，但不当的配置会让网站容易受到网络攻击。

为了提供更好的保护，版本 1.3 摒弃了许多具有已知漏洞的过时功能，包括：

3DES
DES
MD5
RC4
SHA-1

因为新协议已被简化，管理员不太可能犯错，这是 TLS 1.2 的主要问题，也是导致网站在配置期间容易受到攻击的原因。

SSL/TLS 总结 (SSL/TLS: Summary)

版本 (Version)	状态 (Status)	关键特性 (Key Features)
SSL 2.0	过时 (Obsolete)	弱加密，1995年已弃用
SSL 3.0	已弃用 (Deprecated)	易受 POODLE 攻击
TLS 1.0	已弃用 (Deprecated)	易受降级攻击 (Downgrade attacks)
TLS 1.1	已弃用 (Deprecated)	安全性有所改进但已过时
TLS 1.2	安全 (Secure)	支持 AES-GCM, SHA-256，更好的安全性
TLS 1.3	最安全 (Most Secure)	移除弱密码，更快的握手，改进的加密

常见的 SSL/TLS 攻击与缓解措施 (Common SSL/TLS Attacks & Mitigations)

攻击 (Attack)	描述 (Description)	缓解措施 (Mitigation)
MITM (中间人攻击)	攻击者拦截通信	使用 HTTPS，验证证书
降级攻击 (Downgrade Attack)	强制使用旧的 insecure TLS/SSL 版本	禁用 TLS 1.0/1.1，强制使用 TLS 1.2 或 1.3
BEAST 攻击	利用 TLS 1.0 中的弱点	升级到 TLS 1.2 或 1.3
POODLE 攻击	SSL 3.0 的漏洞	禁用 SSL 3.0，使用 TLS 1.2 或 1.3
心脏滴血 (Heartbleed)	OpenSSL 漏洞导致内存泄露	更新 OpenSSL 补丁
DROWN 攻击	利用配置错误的 SSLv2	禁用 SSLv2 和弱密码

传输层安全 (TLS) 最佳实践 (Transport Layer Security Best Practices)

服务器端

使用 TLS 1.2 或 1.3（禁用旧版本）。
使用强密码套件 (如 AES, ChaCha20)。
启用完美前向保密 (PFS)。

启用 HSTS (HTTP Strict Transport Security)。

使用 OCSP Stapling 检查证书有效性。

定期更新 OpenSSL, TLS 库。

客户端

连接前验证 SSL/TLS 证书。

使用证书锁定 (Certificate pinning) 防止 MITM 攻击。

在浏览器中禁用弱协议和密码。

SSL/TLS 的问题与局限 (Issues with SSL/TLS)

性能： 它会减慢服务器速度。

范围： 它保护传输中的数据，但不保护数据库中的数据。

SSL/TLS 无法做到：

认证计算机的实际操作员。

认证在线商店的所有者 (商家)。

认证实际的在线消费者。

认证在线支付系统中涉及的其他方。

完全保护在线信用卡的使用。

成本： SSL/TLS 证书的成本 (取决于类型，价格可能很高)。

协议性质： SSL 是一个**两方协议** (unlike SET)。

SET (安全电子交易) (SET - Secure Electronic Transaction)

SET 是由 MasterCard, Visa, Microsoft, IBM, Netscape 等公司于 1996 年专门设计的一种**消息协议**，用于保护开放网络上的银行卡交易。

它不是一个支付系统，而是一套安全协议和格式。

并未广泛部署。

SET 对卡支付中涉及的所有参与者 (购买者、商家、银行)、它们之间的信任关系以及数字签名的法律含义进行了建模。

功能特点

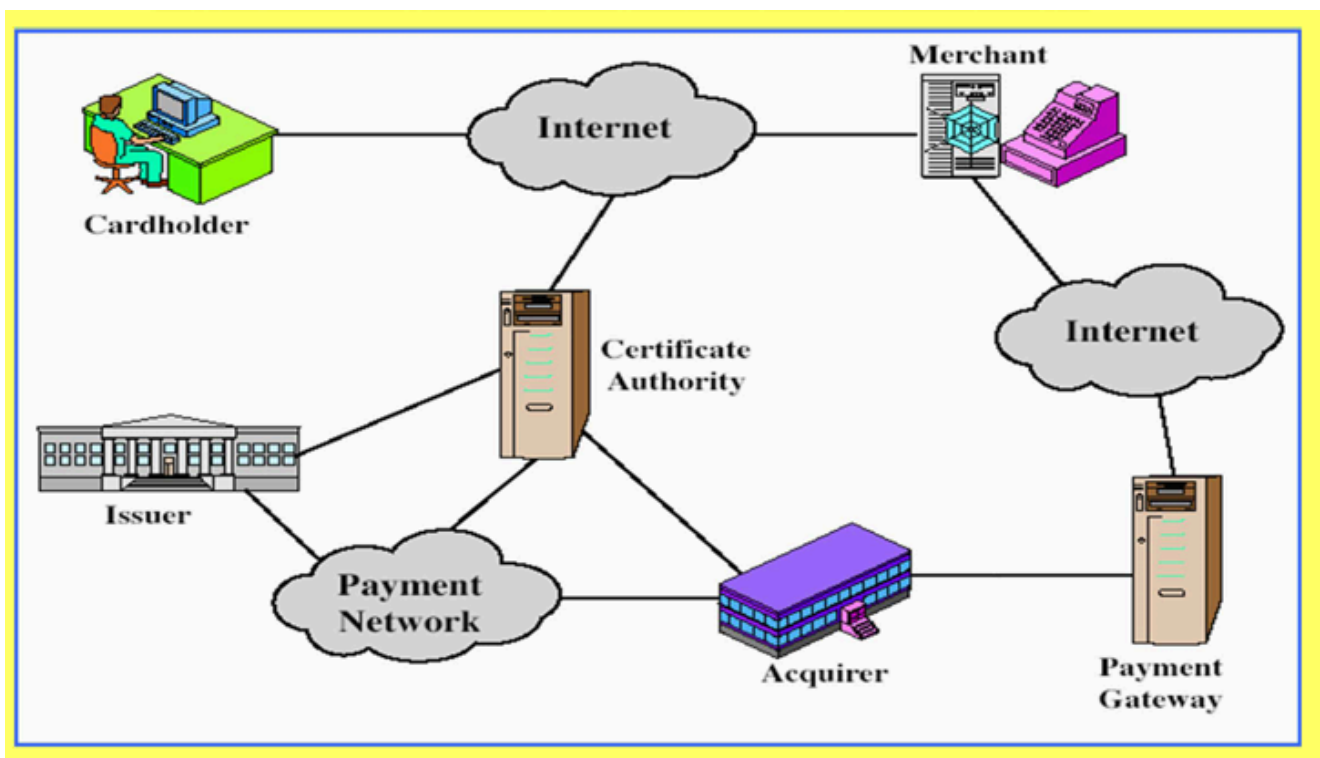
提供涉及的传统银行网络中每个实体的加密身份认证 (多方安全)。

使用**消息加密**而非通道加密。

每个 SET 持卡人都会被颁发一个**数字签名**。加上与 SET 电子钱包对话的软件，构成了 SET 的核心。

SET 消息本质上与多年来在传统银行网络中使用的消息相同。

SET 组件 (SET Components)



持卡人 (Cardholder)

发卡行 (Issuer)

支付网络 (Payment Network)

认证机构 (Certificate Authority)

收单行 (Acquirer)

支付网关 (Payment Gateway)

商家 (Merchant)

互联网 (Internet)

SET 的工作流程与优劣势

流程：允许所有组件在不安全的互联网上流动。定义了银行、商家、持卡人之间所有必要的通信。

对比 SSL：SSL 在两台计算机之间创建安全连接；SET 提供商家保证（持卡人不会说“这不是我买的”），并向持卡人保证商家是合法的。

劣势：要求银行网络、商家位置和消费者计算机上安装适当的软件。

优势：商家无法访问客户的账户信息（财务数据的隐私）。

系统完整性：提供完整的卡支付系统（支付传输、确认和查询）。

加密技术：

机密性：对称密钥加密 (Symmetric Key Cryptography)

认证：公钥加密 RSA (Public Key Cryptography RSA)

完整性：哈希 (Hashing)

SET 交易步骤 (SET Transaction)

1. 客户开设账户。
2. 客户接收证书。
3. 商家拥有自己的证书。

4. 客户下订单。
5. 验证商家。
6. 发送订单和付款信息。
7. 商家请求支付授权。
8. 商家确认订单。
9. 商家提供商品或服务。
10. 商家请求付款。

SSL 与 SET 的对比 (SET vs. SSL/TLS)

SSL 无法提供不可否认性 (irrefutability), 仅提供服务器端认证。
SET 使用数字证书认证持卡人和商家, 使得拒付 (chargebacks) 变得困难。
使用 SET, 商家可以确信收到的订单未被篡改。

SET 会取代 SSL/TLS 吗? 不会, 两者除了都使用加密和数字证书外, 几乎没有技术相似之处。
SET 死了吗? 没有, 但完全没有被使用。
SSL 对电子商务足够好吗? 不, 但因为没有其他选择, 所以正在被使用。
SSL 商家知道客户是谁吗? 不知道。

问题 (Issue)	安全套接层 (SSL)	安全电子交易 (SET)
主要目标	以加密形式交换数据	电子商务相关的支付机制
认证	双方交换认证	所有参与方必须由第三方认证
认证强度	机制到位但不是很强	SET 中有由第三方参与的强机制
商家欺诈风险	可能, 因为客户将财务详细信息给了商家	不太可能, 因为财务详细信息给了支付网关
客户欺诈风险	可能, 因为没有机制防止客户后来拒绝付款	客户必须 digitally sign (数字签名) 支付指令
客户欺诈时的责任	商家负责	支付网关负责
实际使用	高 (High)	不多 (Not much)

防火墙

定义: 防火墙是一种网络安全设备或软件, 它根据组织预先建立的安全策略, 监控并过滤进出的网络流量。
本质: 它是位于私有内部网络 (Private Internal Network) 和 公共互联网 (Public Internet) 之间的屏障。
主要目的:
允许非威胁性流量进入。
阻止危险流量进入。
过滤流量, 只允许符合规则的数据包通过。

防火墙可以是硬件、软件，或者是两者的结合。

硬件防火墙 (Hardware Firewalls)

保护范围: 保护整个网络。

部署位置: 通常实施在路由器层级。

特点: 通常更昂贵，配置难度较大。

软件防火墙 (Software Firewalls)

保护范围: 保护单台计算机。

特点: 通常较便宜，配置更容易。

工作原理:

检查数据到达计算机任一侧时的每一个独立“数据包 (packet)”。

无论是入站 (Inbound) 还是出站 (Outbound) 流量都会被检查。

决定数据包是应该被**允许通过 (Allowed)** 还是被**阻止 (Blocked)**。

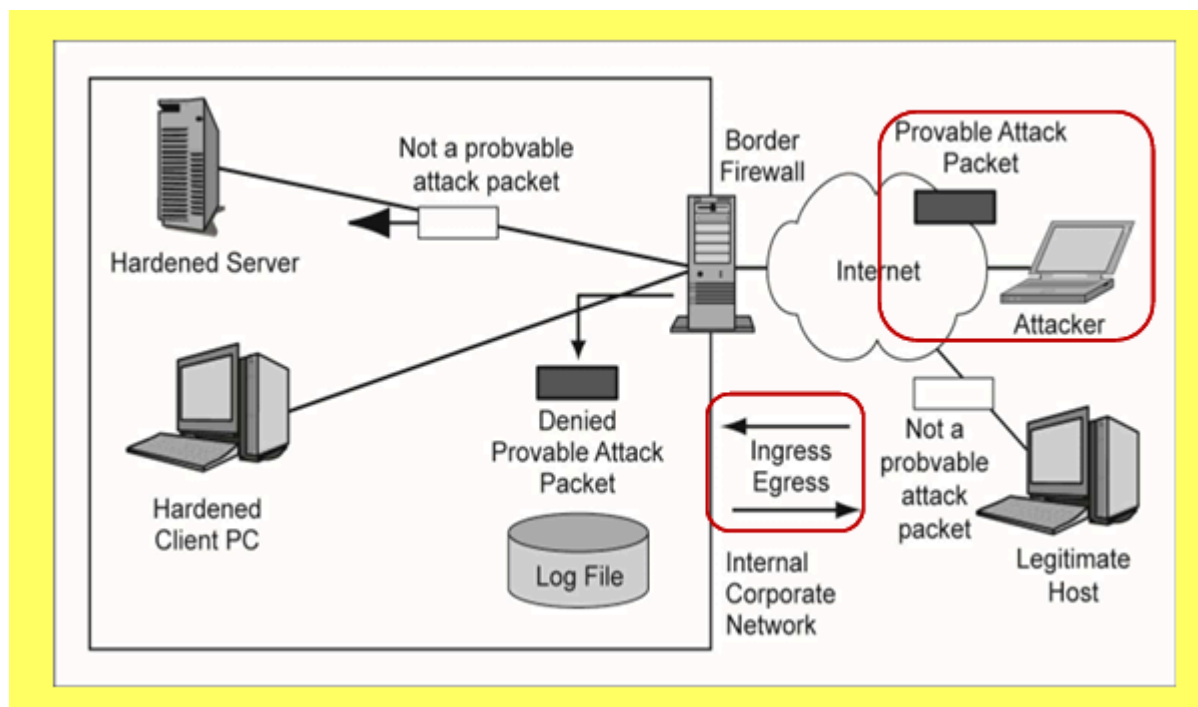
基本工作原理与概念 (Basic Operation & Concepts)

代理/伪装: 当你从互联网请求内容时，防火墙表现得像是它发出了请求，而不是你的计算机。

隐藏身份: 互联网永远看不到你的计算机，因此蠕虫或黑客无法探测或攻击除防火墙以外的目标。

“哑盒” (Dumb Box): 防火墙对外就像一个没有内部信息的盒子。

基本操作流程



入站 (Ingress): 数据包进入站点。

出站 (Egress): 数据包离开站点。

日志记录 (Logging): 防火墙会丢弃并记录可证明的攻击数据包 (Provable Attack Packets)。

非可证明攻击: 防火墙除非确定是攻击包，否则不会丢弃。这意味着一些非典型的攻击包可能会穿过防火墙。

防火墙策略 (Firewall Policies)

防火墙根据一组预定义的规则（称为防火墙策略）来过滤流量。

规则匹配

IP 地址 = 房子 (House): 只有受信任的人（源地址）才被允许进入房子（目标地址）。

端口号 = 房间 (Room): 进入房子的人只被允许访问特定的房间（目标端口），这取决于他们是房主、孩子还是客人。

房主可能被允许进入任何房间。

客人只被允许进入特定的房间集合（特定端口）。

规则匹配示例 (Rule Matching Example)

防火墙按顺序检查规则，一旦匹配成功即执行动作。

Rule No.	Source IP	Destination IP	Port	Action
1	192.168.1.0/24	Any	80	Allow
2	Any	10.0.0.5	22	Deny
3	Any	Any	Any	Deny

❑ **Example Query 1**

- ❑ Packet: Src = 192.168.1.25, Dst = 8.8.8.8, Port = 80
- ❑ Rule 1 matches → Allow. ✓

❑ **Example Query 2**

- ❑ Packet: Src = 172.16.5.10, Dst = 10.0.0.5, Port = 22
- ❑ Matches Rule 2 → Deny. ✗

❑ **Example Query 3**

- ❑ Packet: Src = 192.168.1.30, Dst = 10.0.0.5, Port = 443
- ❑ Rule 1 does not match (port mismatch).
- ❑ Rule 2 does not match (port mismatch).
- ❑ Rule 3 matches → Deny. ✗

DR M Y SiyalEE6102P5-52

个人防火墙 (Personal Firewall)

一种用于保护连接到互联网的**单台计算机**免受入侵的软件应用程序。

能做什么 (Can Do):

阻止黑客访问你的计算机。

保护你的个人信息。

阻止“弹出式”广告和某些 Cookie。

决定哪些程序可以访问互联网。

不能做什么 (Cannot Do):

不能阻止电子邮件病毒（这需要防病毒产品配合更新的定义库）。

不能“设置后即不管” (Set and forget)：防火墙需要定期更新规则集和软件本身。

优点

增强安全性: 阻止未经授权的访问和网络攻击。

流量过滤: 控制哪些数据包可以进入网络。

日志与警报: 为管理员提供可疑活动的日志。

缺点

性能影响: 由于流量检查，可能会减慢网络速度。

配置复杂: 需要专业知识来有效设置和维护。

无法防御内部威胁: 防火墙无法阻止来自内部的攻击。

绕过风险: 攻击者可能使用隧道技术或加密技术来逃避检测。

对高级攻击防御有限: 无法防御社会工程学或零日漏洞利用 (Zero-day exploits)。

主要类型 (Types of Firewall)

1. 包过滤防火墙 (Packet Filtering Firewall):

根据源 IP、目标 IP、端口检查单个数据包的头部。

优点: 快速、高效。

缺点: 缺乏深度检查能力，无状态 (Stateless)，没有之前数据包的上下文。

2. 状态检测防火墙 (Stateful Inspection Firewall):

监控活动连接并跟踪网络流量的状态。

比包过滤更安全，但需要更多资源。

3. 代理防火墙 (Proxy Firewall):

充当用户和互联网之间的中介。

提供强大的安全性，但可能会减慢网络性能。

4. 下一代防火墙 (Next-Generation Firewall, NGFW):

包含传统防火墙功能，外加入侵防御、深度包检测 (DPI) 和应用程序感知。

更先进但也更昂贵。

5. 云防火墙 (Cloud-Based Firewall):

托管在云基础设施上，为远程用户提供可扩展的保护。

减少对本地硬件的依赖，但依赖第三方服务。

6. Web 应用防火墙 (Web Application Firewall, WAF):

保护 Web 应用程序免受 SQL 注入和跨站脚本 (XSS) 等威胁。

专注于应用安全而非通用网络安全。

包过滤 (Packet Filtering Details)

静态过滤 (Static Filtering):

如果数据包匹配过滤器的规则集，防火墙将丢弃或接受它。

这是最早的过滤机制，一次检查一个数据包，相互隔离。

无法阻止许多类型的攻击（如伪造 IP 地址）。

不再作为边界防火墙的主要过滤机制，常作为辅助机制。

动态过滤 (Dynamic Filtering):

允许防火墙对突发事件做出反应，或根据需要创建/更新规则。

基于对协议功能的理解以及数据包头部中的信息。

状态检测 (Stateful Inspection):

使用**状态表 (State Table)** 跟踪内部和外部系统之间的每个网络连接。

状态包检测 (SPI - Stateful Packet Inspection)

原理: 审查相同的数据包信息，但也记录关于 **TCP 连接** 的信息。

状态表: 维护包含每个活动连接信息的表 (IP 地址、端口、序列号)。

工作机制:

通过记录哪个站点发送了哪个数据包以及何时发送，来跟踪对话中的每个数据包的状态和上下文。

可以判断数据包是否是源自受信任网络的合法会话的一部分。

利用这些表，SPI 防火墙只允许那些作为对内部网络发起的连接的响应而入站的 **TCP 数据包**。

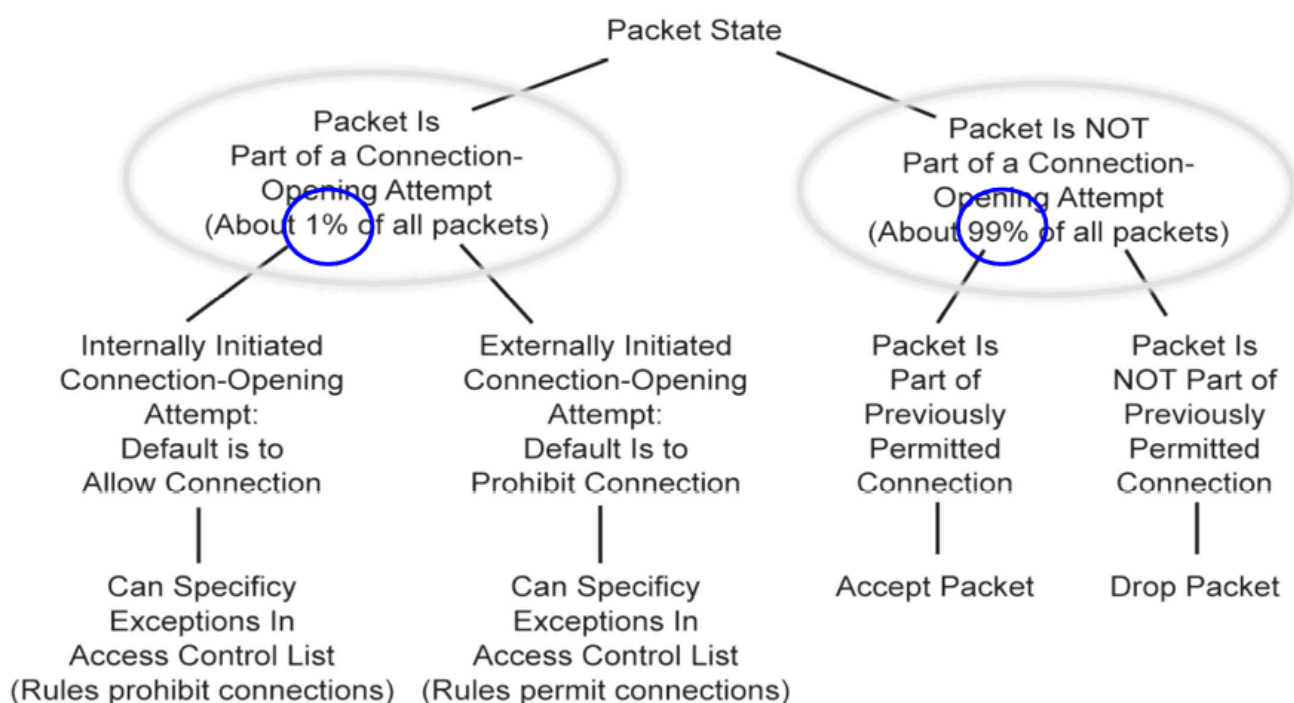
主要缺点: 管理状态表和验证数据包所需的额外处理要求可能会使系统暴露在 **DoS (拒绝服务)** 攻击之下。

连接中的状态 (States in Connection)

连接有不同的状态或阶段，不同的状态面临不同的攻击，因此 SPI 防火墙对不同的状态使用不同的过滤规则。

1. 连接建立状态 (Connection Opening State)
2. 持续通信状态 (Ongoing Communication State)
3. 连接关闭状态 (Connection Closing State)

双状态 SPI 规则示例



低成本 (Low Cost):

大多数数据包不属于连接建立尝试。

这些数据包可以通过非常简单且廉价的方式处理。

连接建立尝试的处理成本较高，但这种情况很少见。

安全性 (Safety):

除了应用层攻击外，其他攻击通常无法通过 SPI 防火墙。

必要时，SPI 防火墙可以使用其他形式的过滤。

主导地位 (Dominance):

高安全性和低成本的结合使得 SPI 防火墙极其流行。

几乎所有主要的边界防火墙都使用状态包检测。

应用网关/代理服务器 (Application Gateway/Proxy Servers)

定义: 通常安装在专用计算机上，也称为代理服务器。

位置: 由于代理服务器通常位于网络的不安全区域（如 DMZ），它暴露在较高风险中，因此比 Web 服务器本身受到更严密的保护。

充当外部世界的网关，而不是 Web 服务器。

可以实施额外的过滤规则。

配置为 Web 代理时，不允许 FTP、Gopher 或其他流量通过（除非特别配置）。

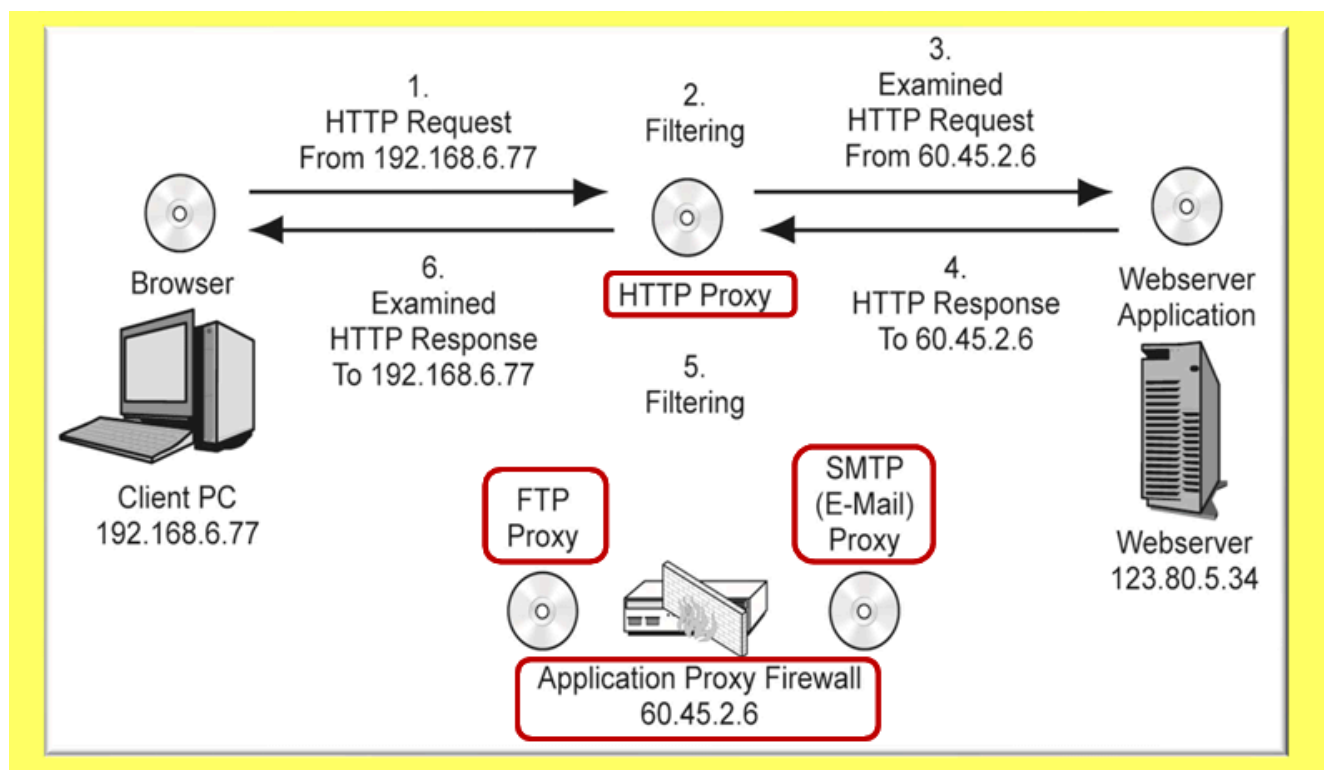
无完全访问权: 用户无法直接访问代理后面的服务。

验证: 将用户请求作为合法请求进行验证。

安全性: 往往比包过滤器更安全，但需要定制少量可用的应用程序。

审计: 易于记录和审计所有传入流量。

操作流程



性能比较 (General Performance)

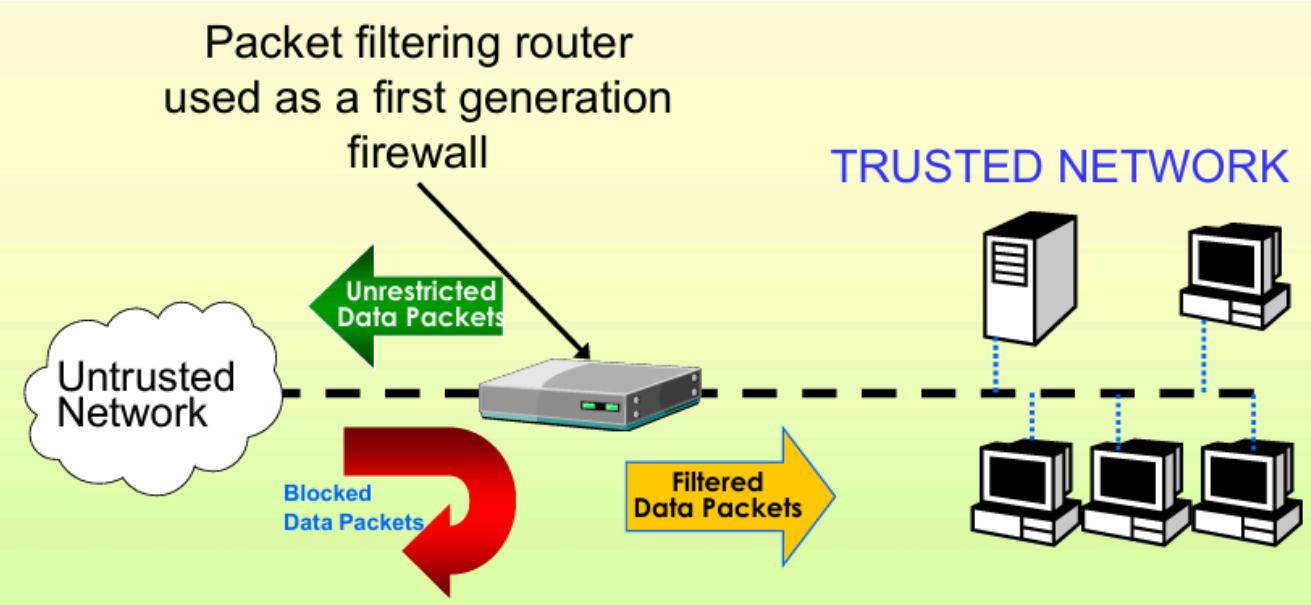
技术 (Technology)	速度 (Speed)	灵活性 (Flexibility)	智能 (Intelligence)
包过滤 (Packet Filtering)	非常好 (V Good)	好 (Good)	低 (Low)
应用代理 (Application Proxy)	低 (Low)	低 (Low)	非常好 (V Good)
状态检测 (Stateful Inspection)	好 (Good)	好 (Good)	好 (Good)

安全性与性能排名 (数值越低越好)

类型	安全性排名 (Security)	性能排名 (Performance)
包过滤器 (Packet Filter)	3 (较差)	1 (最快)
SPI	2 (中等)	2 (中等)
应用网关 (App. GW)	1 (最安全)	4 (最慢)

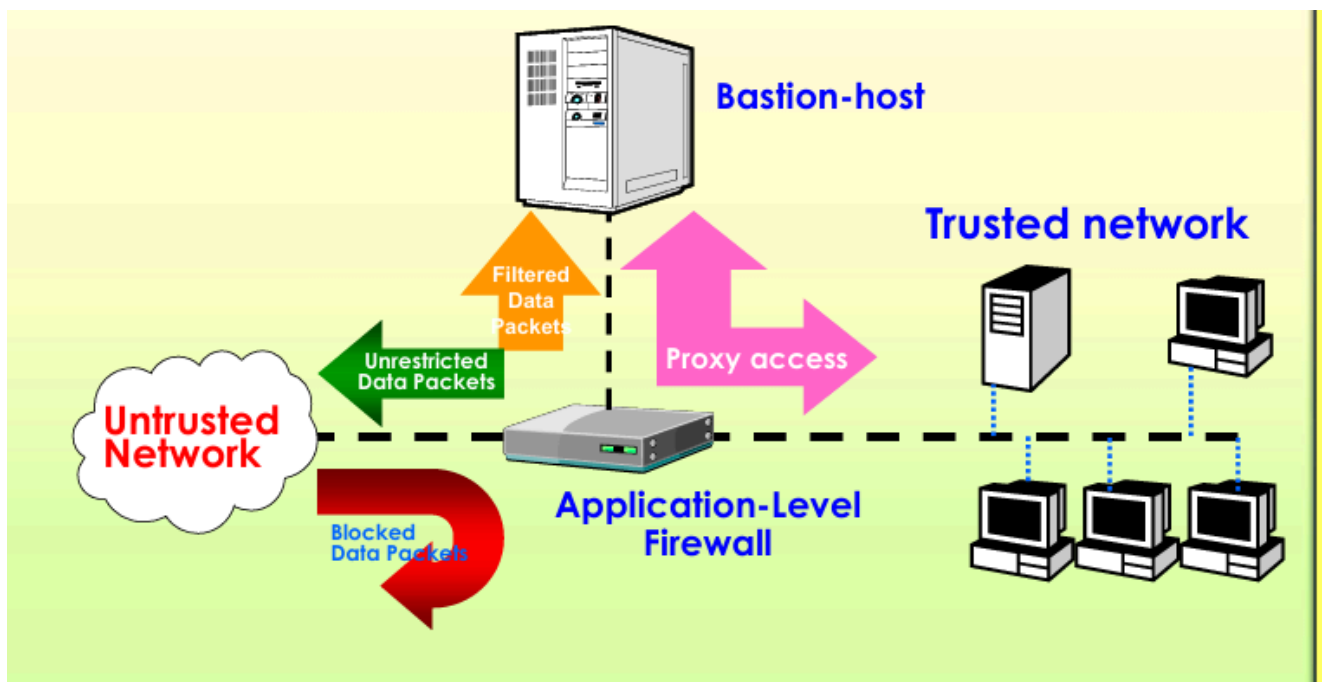
防火墙架构 (Firewall Architectures)

包过滤路由器 (Packet Filtering Routers)



大多数拥有互联网连接的组织使用路由器作为互联网接口。
许多路由器可以配置为拒绝未允许进入网络的数据包。
缺点： 缺乏审计功能且认证能力不强。

屏蔽主机架构 (Screened Host Architecture)

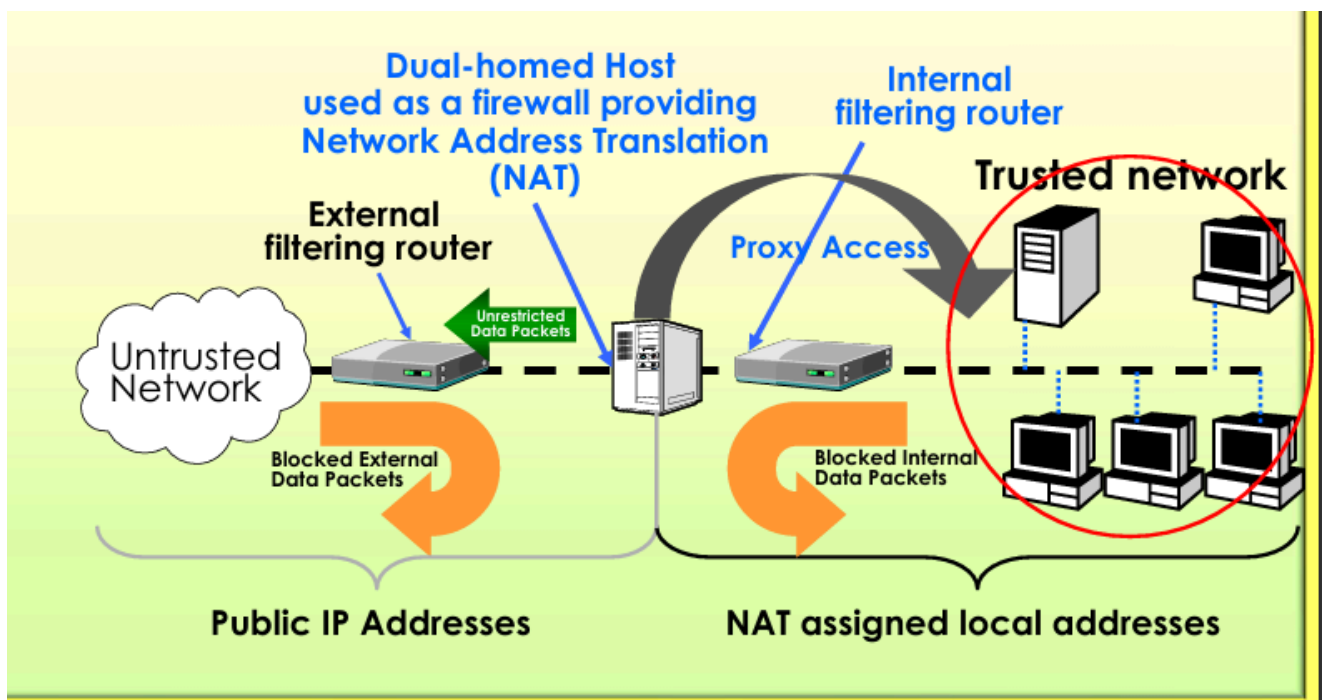


单主机架构 (Single Host Architecture):

单个防火墙放置在内部网络和互联网之间。

简单，但如果防火墙被攻破则非常脆弱。

堡垒主机 (Bastion Host/Sacrificial Host): 单独的主机，作为对外部攻击的屏障，必须非常安全。

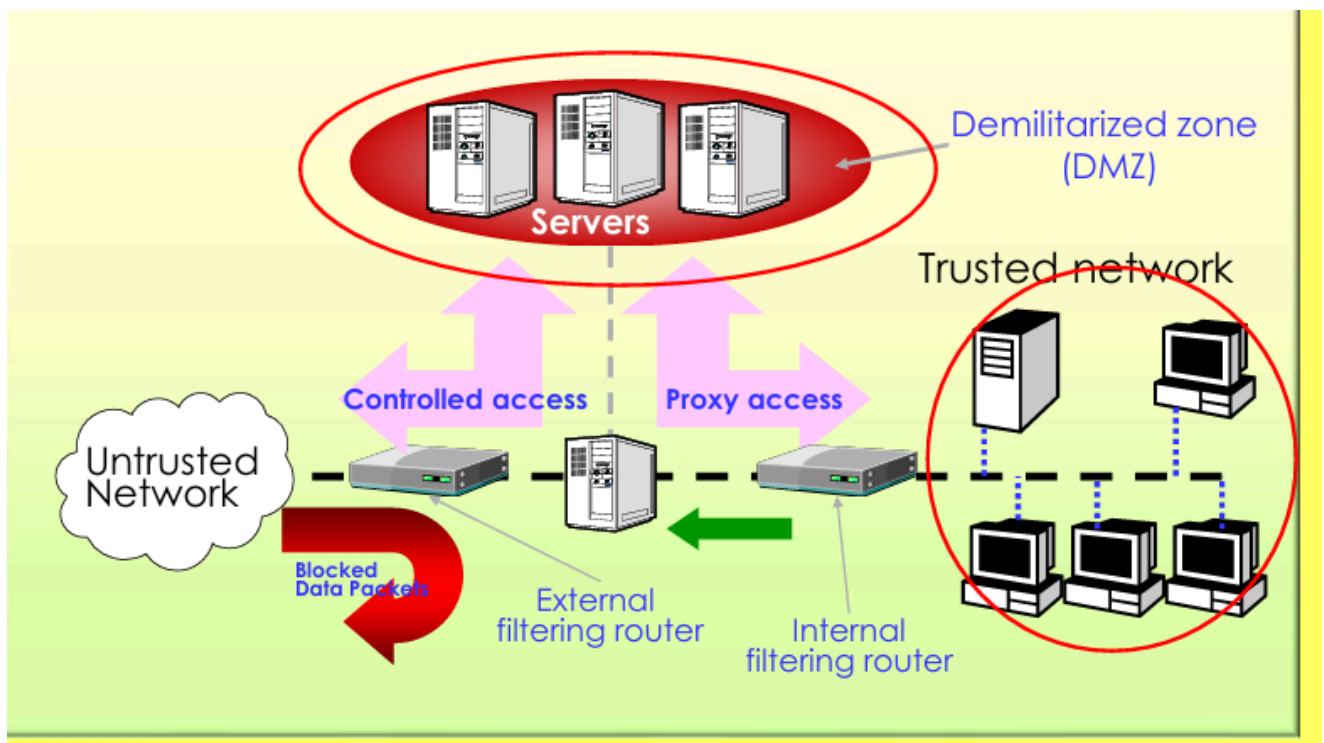


双宿主机架构 (Dual-Homed Host Architecture):

防火墙有两个网络接口：一个连接互联网，另一个连接内部网络。

比屏蔽主机更安全，但仍然是单点故障。

屏蔽子网防火墙 (Screened-Subnet Firewalls / DMZ)



使用两个防火墙创建一个**非军事区 (DMZ)**，公共-facing 服务（如 Web 服务器）放置在此处。通过隔离内部系统，提供额外的安全层。

优势：

提供三层防御（外部路由器、内部路由器、堡垒主机）。

外部路由器只向互联网通告屏蔽子网的存在；内部网络对互联网不可见。

内部路由器只向内部子网通告屏蔽子网的存在；内部系统无法直接构建通往互联网的路由。

防火墙边界安全的终结 (The Death of the Perimeter)

传统的基于边界的防火墙安全模型正在失效，原因如下：

1. **云计算 (Cloud Computing)**：组织现在将数据存储在云端 (AWS, Azure, Google Cloud)，而不是本地服务器。员工访问企业资源，绕过传统防火墙。
2. **远程办公与 BYOD**：员工使用个人设备和家庭网络访问企业数据。传统防火墙无法在远程用户身上有效执行安全策略。
3. **零信任安全模型 (Zero Trust Security Model)**：
“永不信任，始终验证” (Never trust, always verify) 取代了旧的基于信任的模型。
访问是基于身份、上下文和最小特权授予的，而不是基于网络位置。
4. **加密流量增加 (Increased Use of Encrypted Traffic)**：
许多网络攻击使用加密，使得防火墙难以检查流量。
攻击者利用 SSL/TLS 隧道绕过传统防火墙。
5. **复杂威胁的兴起**：
攻击者和黑客通过钓鱼、内部威胁和受损凭证渗透网络。
攻击者经常已经潜伏在网络内部，使得基于边界的防火墙无效。

我们还需要防火墙吗？ (Do We Still Need a Firewall?)

边界已转移，未消失 (The Perimeter Has Shifted, Not Disappeared)：

网络边界并没有“死亡”，而是变得**动态化和去中心化**。

这意味着仅在网络边缘设置单个防火墙已不足以保护企业资产。

防火墙正在演变 (Firewalls Are Evolving, Not Dying):

防火墙仍然是网络安全的关键部分，但不再是唯一的防线。

组织不应放弃防火墙，而应将其与现代安全策略（如零信任、端点安全、云安全）集成。

边界已从固定位置转移到流动的、基于身份的模型，访问和安全策略跟随用户、设备和数据，而不是绑定在物理网络上。

现代防火墙类型

下一代防火墙 (NGFWs): 提供深度包检测 (DPI)、入侵防御 (IPS)、应用层过滤和机器学习驱动的威胁检测。

云防火墙 (Cloud-Based Firewalls / FWaaS): 保护云工作负载和远程用户，无需本地硬件。

网络分段 (Network Segmentation): 组织将网络划分为更小的隔离区域。如果攻击者攻破一个网段，他们无法自由跨越整个网络。

选择与配置防火墙 (Selecting and Configuring)

允许来自受信任网络的所有**出站 (out)** 流量。

防火墙设备应**始终无法**直接从公共网络访问。

允许简单邮件传输协议 (SMTP) 数据通过防火墙，但确保其**路由**到配置良好的 SMTP 网关以安全地过滤和路由消息流量。

所有互联网控制消息协议 (ICMP) 数据应被**拒绝 (denied)**。

阻止 Telnet (终端仿真) 访问来自公共网络的所有内部服务器。

当在防火墙外提供 Web 服务时，通过使用某种形式的**代理访问 (proxy access)** 或 DMZ 架构，拒绝 HTTP 流量到达内部网络。

权衡 (Tradeoff): 与外部世界的通信程度 vs. 安全级别！记住，许多受到高度保护的站点仍然遭受攻击。

入侵检测系统

定义: 入侵检测系统 (IDS) 是一种安全机制，旨在监控网络或系统活动以发现恶意行为。

优势 (Advantages)

早期威胁检测 (Early Threat Detection): 在造成重大损害前识别可疑活动。

实时监控 (Real-Time Monitoring): 持续分析系统和网络活动。

取证分析 (Forensic Analysis): 提供攻击尝试的记录和报告。

安全策略执行 (Security Policy Enforcement): 帮助组织遵守安全法规。

劣势 (Disadvantages)

误报 (False Positives): 基于异常的 IDS 可能会将正常活动标记为威胁。

漏报 (False Negatives): 基于签名的 IDS 可能会错过新的、不断演变的威胁。

高资源消耗 (High Resource Consumption): 处理大量流量需要强大的计算能力。

无主动保护 (No Active Protection): IDS 仅负责检测和报警，**不阻止攻击**（这是 IPS 的功能）。

类型 (Types of IDS)

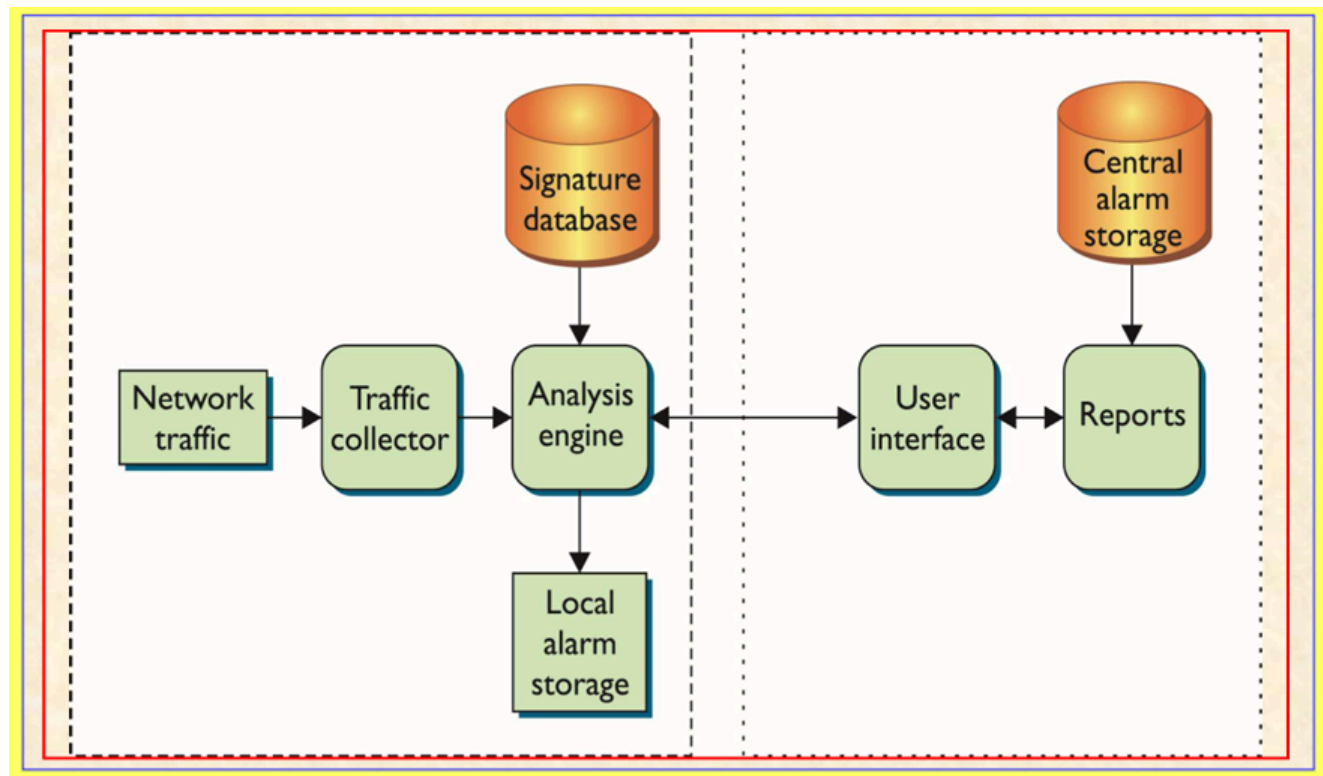
主要分为两类：

1. 基于主机的 IDS (Host-based IDS, HIDS)
2. 基于网络的 IDS (Network-based IDS, NIDS)

基于签名的 IDS (Signature-based): 严重依赖预定义的攻击和流量模式（称为签名）。

基于异常的 IDS (Anomaly-based / Heuristic): 监控活动并试图将其归类为“正常”或“异常”。

基于网络的 IDS (Network-Based IDS - NIDS)



功能： 解析网络流量的引擎。

工作原理： 除了捕获所有网络流量外，NIDS 还将流量与预分类的攻击签名集进行比较。

响应： 一旦在网络数据包中发现签名，就会启动保护措施，停止攻击并记录日志。

部署： 易于部署，无需对网络进行重大修改。

NIDS 通常包含以下组件：

网络流量 (Network traffic): 输入源。

流量收集器 (Traffic collector): 捕获数据。

分析引擎 (Analysis engine): 核心处理单元。

签名数据库 (Signature database): 存储已知攻击模式。

本地报警存储 (Local alarm storage) & 中央报警存储 (Central alarm storage)。

用户界面 (User interface) & 报告 (Reports)。

优势：

提供 NIDS 覆盖所需的系统较少。

部署、维护和升级成本通常较低。

可以查看所有网络流量，并能关联多个系统间的攻击。

劣势：

当流量被加密时效果不佳。

不了解主机本身的活动。

基于主机的 IDS (Host Based IDS - HIDS)

定义： 仅检查特定主机上的活动。

检查内容： 日志 (logs)、审计轨迹 (audit trails) 以及进出该主机的网络流量。

检查频率： 实时或定期进行。

登录失败。

在非正常时间登录。

权限升级 (Privilege escalation)。

添加新用户账户。

优势：

可以非常针对特定操作系统。

可以减少误报率。

可以检查数据解密后的内容。

可以非常针对特定应用程序。

可以确定警报将如何影响系统。

劣势：

必须处理想要监控的每个系统上的信息。

拥有和维护成本可能很高。

使用本地系统资源。

分类

被动 HIDS (Passive HIDS)： 观察活动，分析它，并生成警报。

主动 HIDS (Active HIDS)： 具有被动 HIDS 的所有功能，并且能够通过运行脚本或终止进程来对活动做出反应。

现代 HIDS (Modern HIDS)： 通常被称为**主机入侵防御系统 (HIPS)**，使用以下组件来预防攻击：

集成系统防火墙。

基于行为和签名的 IDS。

恶意软件检测和预防。

基于签名的 IDS (Signature-Based IDS)

也称为**基于知识的 IDS (knowledge-based IDS)**。

检查数据流量，寻找与预定义、预定攻击模式匹配的签名。

问题： 随着新攻击策略的识别，签名必须不断更新。

统计基于异常的 IDS (Statistical Anomaly-Based IDS)

也称为**基于行为的 IDS (behavior-based IDS)**。
从正常流量收集数据并建立基线 (baseline)。
一旦建立基线，定期采样网络活动，基于统计方法与基线进行比较。
如果活动超出基线参数（称为**剪切水平 clipping level**），IDS 会通知管理员。
优势：能够检测新型攻击，因为它寻找任何类型的异常活动。
劣势：可能无法检测微小变化，并且可能产生许多误报。

入侵防御系统 (Intrusion Prevention Systems - IPS)

定义：IPS 是一种主动的安全技术，能够**实时检测并阻止**恶意活动。
与仅检测威胁并生成警报的 IDS 不同，IPS 通过阻止恶意流量来**主动预防**攻击。
IPS 通常集成在下一代防火墙 (NGFWs) 中。

IDS 与 IPS 对比表

特性 (Feature)	入侵检测系统 (IDS)	入侵防御系统 (IPS)
功能 (Function)	检测并警报威胁	检测并 阻止 威胁
响应 (Response)	被动 (日志 & 警报)	主动 (实时预防攻击)
部署位置 (Placement)	监控网络或主机活动	在流量到达系统 之前 检查流量
用例 (Use Case)	适合取证分析和监控	适合实时安全策略执行
示例工具	Snort, Zeek, OSSEC	Palo Alto NGFW, Suricata, Cisco Firepower

蜜罐系统 (Honeypot System)

定义：一种**牺牲性**的计算机系统，旨在作为诱饵 (**decoy**) 吸引网络攻击。
它模仿黑客的目标，利用他们的入侵企图来获取有关网络犯罪分子的信息，了解他们的操作方式，或者将他们从其他目标转移开。

工作原理

蜜罐看起来像真实的计算机系统，拥有应用程序和数据，以此欺骗网络犯罪分子，使其认为这是一个合法的目标。
例子：蜜罐可以模仿公司的客户计费系统（犯罪分子频繁攻击的目标，用于盗取信用卡号）。一旦黑客进入，就可以被追踪，其行为可以被评估，从而为如何使真实网络更安全提供线索。通过故意构建安全漏洞，使蜜罐对攻击者具有吸引力。

局限性

蜜罐安全有其局限性，因为它**无法检测**合法系统中的安全漏洞。
并不总能识别攻击者。

区块链

计算机技术与网络架构的演变 (Evolution of Computer Technology)

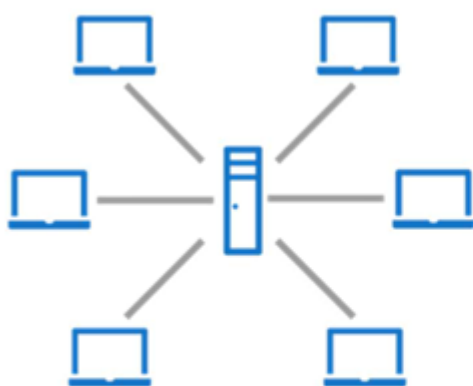
计算模式的演变

大型机 (Mainframe Computers): 集中式计算能力。所有计算能力、内存、数据存储和代码都 housed 在大型机中。用户通过“哑终端” (dumb terminals) 访问，仅用于输入输出，不存储或处理数据。

客户端-服务器 (Client-Server): 分布式计算能力。随着个人电脑和私有网络的出现，计算能力不仅 housed 在服务器端，也 housed 在客户端。这促生了关系数据库系统。

点对点 (Peer-to-Peer, P2P): 去中心化计算能力。最简单的形式是两个或多个 PC 连接并共享资源，无需单独的服务器计算机。P2P 网络通常被认为比集中式网络更安全，因为它们没有单点故障。

网络架构对比



SERVER-BASED



P2P-NETWORK

基于服务器 (Server-Based): 中心辐射型 (Hub-and-spoke) 结构，依赖中心节点。

P2P 网络 (P2P-Network): 网状结构 (Mesh)，节点间互联，去中心化。

分布式账本的历史 (Where Technological Revolution Starts)

5000多年前: 粘土板被用作集中式账本。

约 1494年: 意大利北部出现了复式记账法 (double-entry bookkeeping)，merchants 试图在条目间建立逻辑联系 (借方和贷方)。

1980s & 90s: 计算机系统接管了典型的集中式数字账本系统。

2008年: 中本聪 (Satoshi Nakamoto) 引入了第一种分布式账本技术，即现在的**区块链 (Blockchain)**。

定义: 分布式账本**ledger**是数据库的一种形式，由网络空间中的每个成员独立更新和持有。没有中央机构广播记录，相反，节点独立持有账本并独立构建它。

什么是区块链? (Introduction to Blockchain)

定义：区块链是一种去中心化和分布式的数字账本技术，以安全、不可变和透明的方式记录交易。它消除了对中央权威的需求，增强了信任和安全性。

关键特征 (Key Characteristics)：

去中心化 (Decentralization)：没有单一实体控制网络，降低了腐败和单点故障的风险。

透明度 (Transparency)：所有交易对参与者可见，增加了问责制。

不可篡改性 (Immutability)：一旦记录，交易不能被更改或删除，确保数据完整性。

安全性 (Security)：使用加密技术（如哈希和数字签名）确保交易真实性。

共识机制 (Consensus Mechanisms)：确保网络中的所有节点就交易的有效性达成一致。

结构 (Structure)：区块由交易数据组成，并通过加密方式链接形成链，使数据防篡改。

区块链系统的组成 (Blockchain is a system comprised of...)

交易 (Transactions)

不可变账本 (Immutable ledgers)

去中心化节点 (Decentralized peers)

加密 (Encryption processes)

共识机制 (Consensus mechanisms)

可选：智能合约 (Optional Smart Contracts)

1. **交易发起 (Transaction Initiation)：**用户发起交易（如发送加密货币或记录数据）。交易广播到去中心化的计算机网络（节点）。
2. **交易验证 (Transaction Verification)：**网络节点使用共识机制（如工作量证明 PoS）验证交易。检查预定义规则（如发送者是否有足够余额）。
3. **区块创建 (Block Creation)：**验证后的交易被分组到一个区块中。每个区块包含：交易列表、唯一标识符（哈希 Hash）、对前一个区块哈希的引用（形成链）。
4. **共识与区块添加 (Consensus & Block Addition)：**矿工（或权益人）解决复杂的加密谜题（如 PoW 或 stake coins）。一旦验证，新区块添加到区块链中。
5. **链的延续 (Chain Continuation)：**区块永久记录并链接到前一个区块。任何篡改都需要更改所有之前的区块，使区块链高度安全。
6. **完成与透明 (Completion & Transparency)：**交易确认，更新的区块链分发到所有节点。

不可篡改性 (Immutability)

随时间运作 (Functioning over time)：一旦交易写入区块链，无人能更改。如果要改，极其困难。

像用墨水书写：就像用墨水写的账本，错误只能通过添加新条目来解决，而不是修改旧条目。

哈希链接：每个区块包含前一个区块的哈希值（Hash）。如果 Block 10 的数据变了，它的 Hash 会变，导致 Block 11 中记录的 "Previous Hash" 不匹配，从而破坏整个链。

共识算法 (Consensus Algorithms in Blockchain)

共识算法是区块链网络中的所有节点就分布式账本的当前状态达成一致的程序。

工作量证明 (Proof of Work, PoW)：

节点等待解决复杂的数学谜题来验证区块，需要大量计算能力。

第一个解决谜题的节点获得添加下一个区块的权利（Bitcoin 使用此算法）。

权益证明 (Proof of Stake, PoS):

节点投入 (invest) 系统代币来验证区块，将其放在他们认为可以添加到链上的区块上。
赚取费用 (Ethereum 2.0 使用此算法)。

委托权益证明 (Delegated Proof of Stake, DPoS):

PoS 的更高效变体，代币持有者投票选出代表来验证交易。

燃烧证明 (Proof of Burn, PoB):

验证者将代币发送到无法到达的地址 (销毁)，以此获得验证区块和赚取特权的权利。

容量证明 (Proof of Capacity, PoC):

验证者投资硬盘空间，空间越多的节点越有机会被选中挖矿。

流逝时间证明 (Proof of Elapsed Time, PoET):

最公平且广泛用于许可型区块链。节点等待随机时间，第一个完成的节点获胜并添加区块。防止节点通过不断尝试获得优势 (Intel 开发, Hyperledger 使用)。

权威证明 (Proof of Authority, PoA):

基于区块链中受信任节点的声誉。被认为是私有区块链的有效机制 (Ethereum 联合创始人 Gavin Wood 于 2017 年概念化)。

拜占庭容错 (Byzantine Fault Tolerance, BFT):

即使存在恶意节点 (如 Hyperledger Fabric)，也能确保共识。

其他: 有向无环图 (DAG, 如 IOTA), 活动证明 (Proof of Activity), 权重证明 (Proof of Weight) 等。

智能合约 (Smart Contracts in Blockchain)

定义: 存储在区块链上的自执行程序，自动执行预定义的条款。它们消除了中介机构，降低了成本并提高了效率。

特点: 用户定义的自执行计算机程序，运行在区块链之上；管理数字资产的交换；应用于许多不同领域。

流行平台 (Popular Blockchain Platforms)

Ethereum: 语言 Solidity。最大的智能合约生态系统，DeFi, NFTs。

Solana: 语言 Rust, C, C++。高吞吐量，低交易费。

Binance Smart Chain: Solidity 兼容，比 Ethereum 更快更便宜。

Cardan (Cardano): 语言 Plutus (Haskell-based)。专注于安全性和形式验证。

Polkadot: 语言 Ink!, Rust。互操作性和跨链支持。

应用案例 (Use Cases)

金融 (DeFi): 自动化借贷、保险。

房地产: 产权转让、托管服务。

供应链: 货物追踪、自动化支付。

NFTs & 游戏: 所有权权利、游戏内资产。

投票系统: 防篡改投票和选举机制。

医疗: 患者数据管理、保险理赔。

优势与挑战

优势: 消除中介、减少欺诈风险、更快更高效的交易、节省成本、高度安全。

挑战与风险:

代码漏洞: 代码中的漏洞可能被利用。

不可变性风险: 一旦部署无法纠正错误。

可扩展性: 区块链网络性能有限。

法律问题: 法规不明确及法律可执行性问题。

区块链 vs. 数据库 (Differences Between Blockchains and Databases)

特性	区块链 (Blockchain)	传统数据库 (Database)
结构	分布式账本技术的一个特定子集，构建区块的 chronological chain (时间顺序链)。	通常是为集中式应用设计的，单个实体控制数据。
数据操作	只写 (Write-only): 新条目只能追加 (append) 到分类账末尾，链接到前一个区块的“哈希”。	CRUD: 数据可以轻易修改或删除 (Create, Read, Update, Delete)。
权限	没有管理员权限允许编辑或删除数据。每个新区块附加后，管理员无法更改。	通常有数据库管理员 (DBA) 可以更改数据的任何部分。
控制	去中心化，无单一控制点。	集中式，有控制器 (Controller)。

起源与历史 (Where It All Started)

1991年: Stuart Haber 和 W. Scott Stornetta 提出了一种加密保护的时间戳链文档，防止篡改。

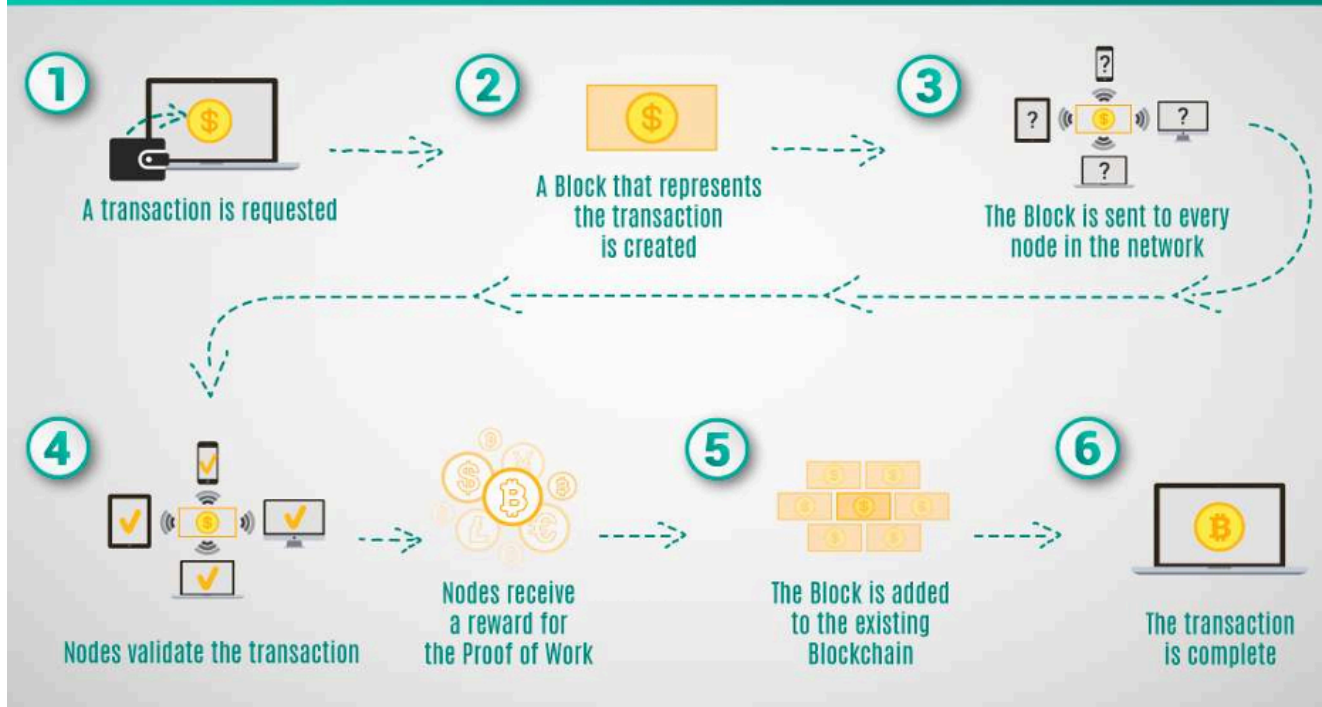
2008年: 中本聪 (Satoshi Nakamoto) 结合了密码学技术、工作量证明系统和去中心化网络，创造了第一个功能性区块链——**比特币 (Bitcoin)**。

比特币白皮书: 标题为《比特币：一种点对点的电子现金系统》(Bitcoin: A Peer-to-Peer Electronic Cash System)。

概念: 比特币被设计为去中心化的分类账，记录比特币交易，无需受信任的中央机构。

区块链的流程 (How Blockchain Technology Works)

HOW BLOCKCHAIN WORKS



步骤 1: 交易发起 (Transaction Initiation)

用户发起交易（例如：发送加密货币或记录数据）。

该交易被广播到去中心化的计算机网络（节点）。

User A ---> Sends Data/Transaction ---> Blockchain Network

步骤 2: 交易验证 (Transaction Verification)

网络节点使用共识机制（如：工作量证明 PoW、权益证明 PoS）验证交易。

交易根据预定义规则进行检查（例如：确保发送者有足够的余额）。

Nodes Verify Transactions



[Transaction Valid?] ---> Yes ---> Move to Next Step



No (Rejected)

步骤 3: 区块创建 (Block Creation)

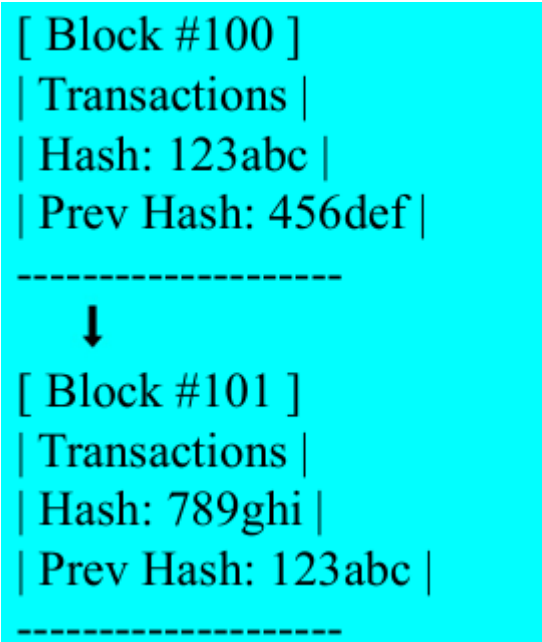
有效的交易被分组到一个区块中。

每个区块包含：

交易列表 (A list of transactions)

唯一标识符/哈希 (A unique identifier / hash)

对前一个区块哈希的引用（从而形成链） (A reference to the previous block's hash)



步骤 4: 共识与区块添加 (Consensus & Block Addition)

矿工（或验证者）解决复杂的加密谜题（工作量证明）或质押代币（权益证明）。一旦验证通过，新区块被添加到区块链中。

Validators ---> Solve Puzzle ---> Block Added to Blockchain

步骤 5: 链的延续与安全 (Chain Continuation & Security)

区块被永久记录并链接到之前的区块。任何篡改都需要更改所有之前的区块，这使得区块链高度安全。

[Block #99] <--> [Block #100] <--> [Block #101] (Immutable Chain)

步骤 6: 完成与透明 (Completion & Transparency)

交易被确认，更新的区块链分发到所有节点。该过程确保了透明度、安全性和去中心化。

Blockchain Updated ---> Distributed to All Nodes ---> Verified by Network

区块链的类型 (Types of Blockchains)

类型	描述	示例
公有链 (Public)	任何人都可以阅读、交易并参与共识过程。代码是开源的。	Bitcoin, Ethereum
私有链 (Private)	类似于公有链，但仅限于单个组织或团体。该团体决定参与者并维护分布式账本。可以限制读写权限。	Ripple
许可链 (Permissioned)	需要邀请才能加入和参与的网络。	-

类型	描述	示例
联盟链 (Consortium)	在联盟网络中，多家公司或组织协作组织共享的交易集。根据 IBM，联盟区块链是“理想”的，当所有参与者都需要被许可并且共同承担责任时。	R3, HyperLedger, Fabric
混合链 (Hybrid)	结合了公有链和私有链的特征。	XinFin Network

区块链的优势 (Benefits of Blockchain)

降低数据丢失风险 (Reduced Risk of Data Loss): 数据存储在台计算机上，可以快速轻松地检索。

更高的透明度 (Greater Transparency): 所有成员都可以访问数据，记录是不可更改的。

提高效率 (Improved Efficiency): 智能合约消除了批准交易的中介需求。

更高的安全性 (Greater Security): 交易被加密，所有新成员都会更新到新交易中。

区块链安全威胁 (Blockchain Security Threats)

网络钓鱼 (Phishing): 目标是被诱骗将其登录凭证交给诈骗者。

女巫攻击 (Sybil Attacks): 攻击者使用大量伪造的身份来欺骗网络并执行非法操作。

路由攻击 (Routing Attacks): 黑客拦截数据并提取货币或机密信息，而参与者不知情。

51% 攻击 (51% Attacks): 黑客控制超过 50% 的网络算力，从而可以操纵交易

电子交易

什么是货币？ (What is Money?)

货币不仅仅是现金，它具有三个核心功能：

交换媒介 (Medium of exchange): 用于购买物品。

计价单位 (Unit of account): 用于定价的核算单位。

价值储藏 (Store of value): 用于储蓄的价值储存手段。

核心公式：

$$\text{MONEY (货币)} = \text{VALUE (价值)} = \text{TRUST (信任)}$$

货币的演变 (The Evolution of Money)

早期商品货币 (Commodities):

在早期，人们使用商品作为支付方式。例如，墨西哥中部的人使用可可豆进行交易。

缺点： 商品的大小和保质期很重要，不便携带和储存。

贵金属 (Precious Metals):

人们开始使用金、银或铜作为货币和支付工具。

缺点： 金属硬币对于日常交易来说太重了，不便携带。

纸币 (Paper Money):

为了解决携带问题，纸币被发明。

最早记录的纸币使用据说是在公元 7 世纪的中国。

运作方式： 类似于现代银行。个人将黄金存入值得信赖的一方（现代称为银行），并获得一张

票据，证明其存入了多少黄金。持有票据的人可以兑换黄金。

法定货币 (Fiat Currency):

尽管纸币本身没有内在价值，但人们相信它值它所宣称的价值，并可以用它交换黄金、白银或硬币。

试图将货币与固定黄金标准挂钩的尝试持续了几个世纪，但为了需要灵活的汇率，自 20 世纪 70 年代初以来，世界已不再试图维持金本位。

定义：法定货币不像基于商品的货币那样由黄金或白银支持。相反，它由**国家政府**支持。

信任：对发行政府的信任现在是区分中央化货币体系中的钞票与其他纸张的唯一因素。

支付系统的类型 (Types of Payment Systems)

现金 (Cash):

由国家当局定义的法定货币，代表价值。

按交易次数计算，是最常见的支付形式。

可立即兑换成任何其他价值的形式，无需中介。

特点：便携，无需认证，提供即时购买力。**优势：**"免费"（无交易费），匿名，认知需求低。

局限性：容易丢失/被盗，限于小额交易，不提供任何浮动（float）。

支票转账 (Checking Transfer):

资金通过消费者签署的**汇票 (draft)** 或 **支票 (check)** 直接从消费者的支票账户转移到商家或其他个人。

按花费金额计算，是最常见的支付形式。

可用于小额和大型交易。

特点：不匿名，需要第三方干预（银行）。

风险：引入安全风险（伪造、止付），通常需要认证。

信用卡 (Credit Card):

代表一个向消费者**扩展信用 (extends credit)** 的账户，允许消费者向多个供应商进行支付。

信用卡协会：非营利协会（如 Visa, MasterCard），为发卡行设定标准。

发卡行：发行卡片并处理交易。

处理中心 (清算所)：处理账户和余额的验证。

储值 (Stored Value):

通过将资金存入账户创建的账户，资金可根据需要从中支付或提取。

例子：借记卡 (Debit cards)、礼品券、预付卡、智能卡。

借记卡：立即借记支票或其他活期存款账户。

点对点 (Peer-to-Peer)：如 PayPal 等支付系统。

累计余额 (Accumulating Balance):

累积 (accumulate) 支出并消费者定期支付的账户。

例子：公用事业账单、美国运通账户。

电子支付系统 (E-Payment Systems)

一种不使用支票或现金的支付系统。

信用支付系统 (Credit Payment System)

信用卡 (Credit Card): 使用信用卡进行在线支付, 无需使用现金。

电子钱包 (E-wallet): 一种预付账户形式, 存储用户的财务数据 (如借记卡和信用卡信息), 使在线交易更容易。

智能卡 (Smart card): 一种带有微处理器的塑料卡, 可以加载资金用于交易; 也称为芯片卡。

现金支付系统 (Cash Payment System)

直接借记 (Direct debit): 账户持有人指示银行从其在另一家机构的账户中收集特定金额的资金, 以电子方式支付商品或服务。

电子现金 (E-cash): 旧式纸质支票的数字版本。资金存储在客户的设备上, 并可进行在线交易。

储值卡 (Stored-value card): 具有一定金额资金的卡, 用于进行交易。典型的例子是礼品卡。

加密货币 (Cryptocurrencies)

定义: 一种数字货币, 使用加密技术来调节货币单位的生成并验证资金转移, 独立于中央银行运作 (如 Bitcoin, Ripple, Ethereum 等)。

电子支付的优势:

更有效和高效: 交易在几秒钟内完成 (一键点击)。

便利: 客户可以随时随地支付商品。

费用控制: 客户总是可以检查其虚拟账户, 查看交易历史。

电子支付的劣势:

欺诈: 电子商务欺诈正以每年 30% 的速度增长。如果消费者遵循安全规则, 问题不大, 但如果选择安全性不高的支付系统, 存在敏感数据泄露导致身份盗窃的风险。

缺乏匿名性: 部分消费者个人数据存储在支付系统数据库中 (加密货币除外)。

需要互联网接入: 如果互联网连接失败, 无法完成交易、登录在线账户等。

电子支付方案 (E-Payment Schemes)

定义: 电子支付方案是多方协议 (multi-party protocols)。

模型: 支付工具 modeled by electronic coin (电子硬币), 具有固定价值, 可以像传统货币工具一样交换。

参与方 (Parties include):

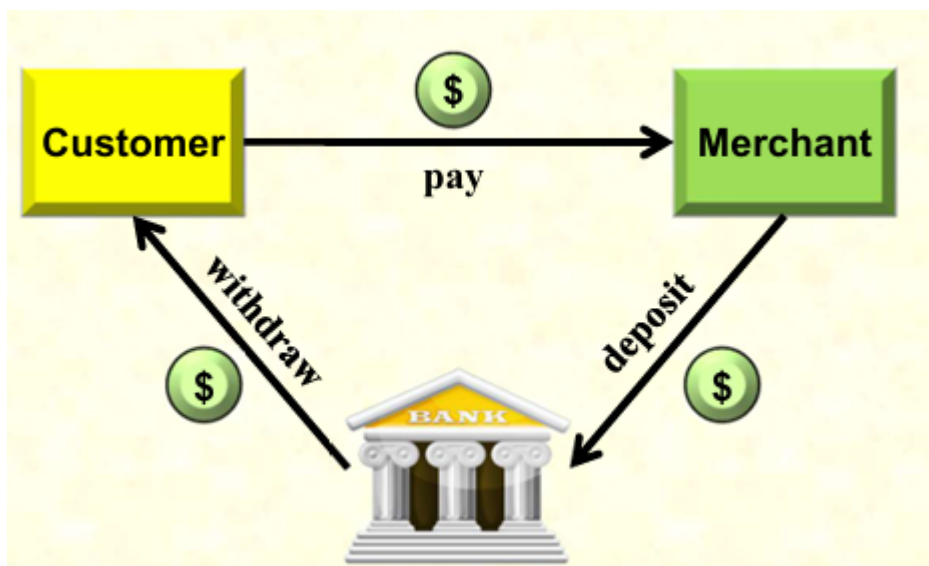
付款人 (Payer): 客户 (customer)。

收款人 (Payee): 商家 (merchant)。

银行 (Bank)。

监管机构 (Regulator)。

交易流程



电子支付方案中的交易通常包括：

1. 客户从银行**提取 (Withdrawal)** 硬币。
2. 客户向商家**支付 (Payment)** 硬币。
3. 商家将硬币**存入 (Deposit)** 银行。

方案类型

在线方案 (Online Scheme)： 银行参与支付交易。

离线方案 (Offline Scheme)： 银行不参与支付交易（通常用于电子现金，稍后批量结算）。

电子支付的目标 (E-Payment Goals)

1. **完整性 (Integrity)：**
 - 硬币不能被伪造 (Coins cannot be forged)。
 - 合法的交易必须被兑现 (Legitimate transactions are honored)。
2. **问责制 (Accountability)：**
 - 交易以后不能被否认 (Transactions cannot be later denied) —— 即不可抵赖性。
 - 纠纷可以有效地解决 (Disputes can be efficiently settled)。
3. **隐私 (Privacy)：**
 - 某些方的身份不向其他方透露 (The identity of some parties is not revealed)。
 - 硬币不能被追踪到付款人和/或收款人（数字现金特性） (Coins cannot be traced)。

带有数字签名的电子支付 (E-Payment with Digital Signature)

工作流程

1. **提取时签名：** 硬币在提取时由**银行进行数字签名**。
2. **验证：** 商家验证银行的签名。
3. **存款：** 银行兑现有效硬币的存款。

安全与隐私问题 (Security and Privacy Issues)

双重支付 (Double Spending): 客户可以复制硬币并进行双重支付（这是数字现金的主要挑战）。

隐私泄露: 银行了解客户和商家的每一笔交易。

在线信用卡交易 (Online Credit Card Transaction)

工作原理

处理方式与实体店购物非常相似。

主要区别: 在线商家无法看到或获取卡的物理印记（刷卡），也没有签名可用。

主要参与者:

消费者 (Consumer)

商家 (Merchant)

清算所 (Clearinghouse)

商家银行/收单行 (Merchant bank / Acquiring bank)

消费者发卡行 (Consumer's card issuing bank)

局限性 (Limitations)

安全性 (Security): 商家和消费者都无法被完全认证。

成本 (Cost): 对商家而言，费用约为购买价格的 **3.5%**，加上每笔交易 20-30 美分的费用。

社会公平 (Social Equity): 许多人无法获得信用卡（年轻人、其他无法负担或被视为高风险的成年人）。

处理费用示例 (Processing Charges)

以 \$100 的交易为例：

发卡行 (Issuer) 收取：\$2.50

授权网络 (Authorization Network) 收取：\$0.16

收单行 (Acquirer) 收取：\$1.34

商家 (Merchant) 最终收到：\$96 (扣除费用后)

安全连接 (SSL/TLS)

SSL 提供从互联网到商家服务器的安全连接。

流程：消费者购买 -> 商家软件联系清算所 -> 清算所验证账户并与发卡行结算 -> 发卡行贷记商家账户 -> 向消费者发出月度账单。

数字现金 (Digital Cash)

工作流程

1. **提取 (Withdrawal):** 银行从 Alice 的账户扣除 \$1，并对一个“空白硬币”进行“压印”(数字签名/验证签名)。
2. **封装:** Alice 将签名的空白硬币放入“数字信封”中。
3. **花费 (Spend):** Alice 将硬币支付给商家。

4. **兑换 (Redeem)**: 商家将硬币发送给银行。银行识别自己的“压印”(验证签名) 并贷记商家账户。

关键属性 (Key Properties)

安全 (Secure)

匿名 (Anonymous)

便携 (Portable)

可重用 (Reusable)

用户友好 (User-friendly)

两大难题 (Two Big Problems)

1. 如何保证匿名性?
2. 如何避免**双重支付 (Double Spending)**? (即同一笔钱被花两次)

比特币 (Bitcoin): 2009年推出, 似乎提供了正常现金的所有属性, 包括解决双重支付问题。

法币与数字货币 (Fiat and Digital Money)

法币 (Fiat Money):

拉丁语意为“让它被完成”。

美元、欧元等, 因发行国政府背书而有价值。

缺点: 中心化, 数量不受限制 (例如: 无限量化宽松 QE)。

数字货币 (Digital Money):

以数字形式存在的货币 (不同于实体的纸币和硬币)。

允许即时交易和无国界的所有权转移。

双重支付 (Double-spending):

数字现金方案中的潜在缺陷, 同一个数字代币可能被花费多次。

这是因为数字代币由可以复制或伪造的数字文件组成。

银行的解决方案: 保持计算机账本, 在**集中式计算机系统**上跟踪谁拥有什么。

数字支付的关键问题 (Digital Payment Issues)

必须解决的关键信任问题: 隐私、认证与授权、完整性、不可抵赖性。

决定广泛接受度的关键因素: 独立性、互操作性与便携性、安全性、匿名性、可分性、易用性、交易费用。

加密货币

定义: 一种基于互联网的交换媒介, 使用加密功能进行金融交易。

技术基础: 利用区块链技术实现去中心化、透明性和不可篡改性。

核心特征: 最重要的一点是不受任何中央机构控制。

交易方式: 通过私钥和公钥直接在两方之间发送。

优势: 处理费用极低, 可规避传统金融机构的高额费用。

现状: 已成为全球现象。

主要银行、会计师事务所、软件公司、政府及高等学府都在研究加密货币并发表相关文章。它引发了人们的想象，同时也带来了恐惧和困惑。

比特币 (Bitcoin)

简介

一种去中心化的数字货币，可以直接买卖和交换，无需像银行这样的中介。

使用**公共区块链技术**，允许个人和企业之间去中心化的价值转移。

动机：对金融机构的不信任以及交易成本。

主要担忧：交易安全性和双重支付。

特性：每一笔发生过的比特币交易都存在于公共账本上，任何人都可以访问，这使得交易难以逆转和伪造。

创始人

中本聪 (Satoshi Nakamoto)：被称为比特币之父。

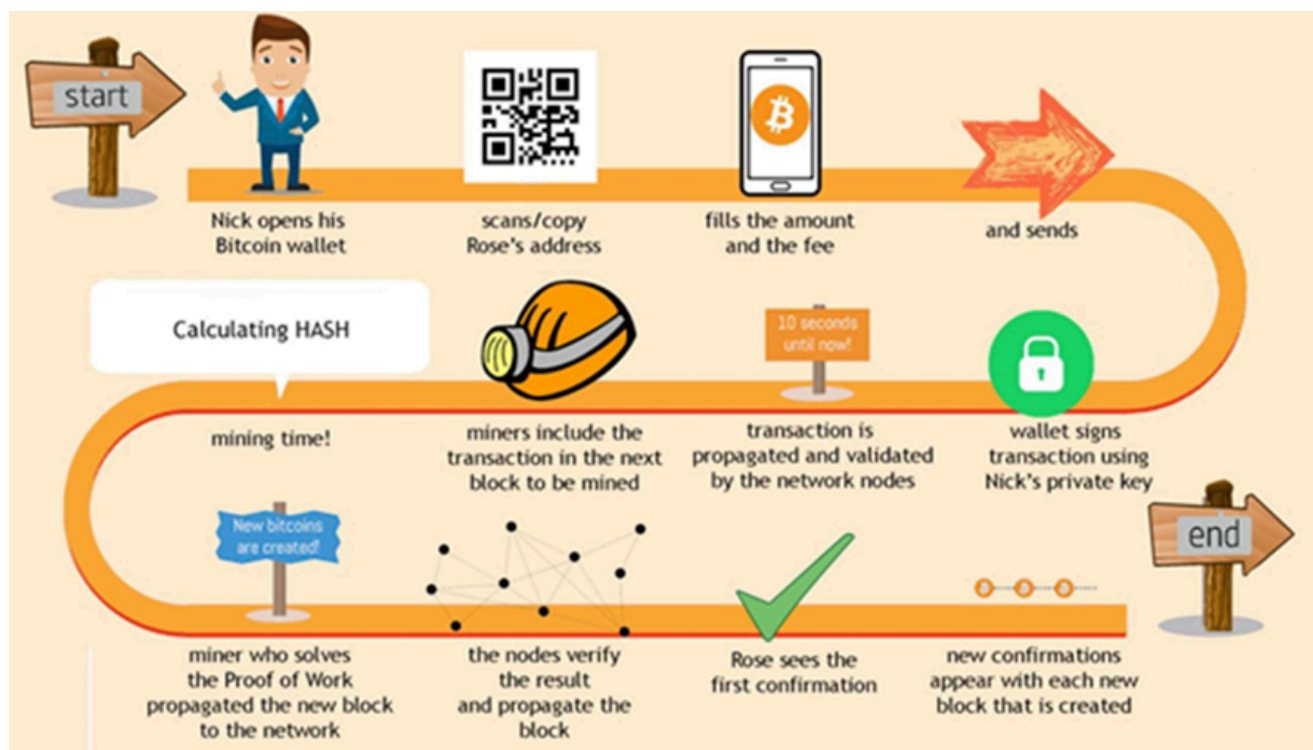
他在构建第一个加密货币时，必须找到一种无需第三方即可验证交易的方法。他通过创建**工作量证明 (Proof of Work)** 系统实现了这一点。

供应量

目前流通量超过 **1931 万枚**。

预设上限为 **2100 万枚**。

交易流程 (The Bitcoin Transaction Process)



比特币挖矿 (Bitcoin Mining)

原则：原则上每个人都可以成为矿工，因此加密货币需要一种机制来防止任何一方滥用它（创建大量对等节点并传播伪造交易）。

资格：中本聪设定规则，矿工需要投资一些计算机才有资格执行此任务。

工作量证明 (Proof-of-Work)：

在比特币中，他们必须找到一个**哈希 (hash)** —— 一种加密函数的产物，它将新区块与其前身连接起来。

基于 **SHA 256** 哈希算法。

这是矿工竞相解决的加密谜题的基础。

奖励：找到解决方案后，矿工可以构建一个区块并将其添加到区块链中。作为激励，他有权添加所谓的 **Coinbase 交易**，这赋予他特定数量的比特币。这是创造有效比特币的唯一方式。

比特币消耗的电力大约是英国的一半（根据图表数据）。

以太坊 (Ethereum)

简介

像比特币一样，以太坊是一个公共区块链平台，拥有自己的加密货币，称为 **以太币 (Ether, ETH)** 或 **Ethereum**，以及自己的编程语言，称为 **Solidity**。

用户可以在平台上创建、发布、货币化和使用应用程序，并使用 Ether 加密货币进行支付。

自称是“**世界可编程区块链 (The world's programmable blockchain)**”。它还包括智能合约。

于 2015 年 7 月由一小群区块链爱好者推出。

特点

速度：肯定比比特币快 —— 交易通常在几秒钟内结算，而不是几分钟。

代币创建：以太坊网络还允许创建其他加密货币或代币，使用与 Ether 相同的协议但分布在不同的区块链上（可以是公共的或私有的）。

共识机制转变：以太坊于 2020 年开始从 **POW (工作量证明)** 转向 **POS (权益证明)**，并于 2021 年完成这一转变

应用场景 (Apps on Ethereum)

金融 (Finance)

房地产 (Real Estate)

保险 (Insurance)

智能合约 (Smart Contracts)：例如“在以太坊上买房”，通过代码即法律 (Code as Law) 取代律师、经纪人和保险公司，实现去中介化。

瑞波币 (Ripple)

简介

Ripple 是 **XRP** 加密货币背后的公司和网络的名称。

2012 年推出 XRP，其目的是作为两种货币之间交换的**中间机制**。

其产品用于支付结算、资产交换和汇款系统，这些系统更像 **SWIFT**（一种供银行和金融中介机构使用的国际货币和安全转账服务）。

特点

预挖矿 (Pre-mined): XRP 是预 mined 的, 与比特币相比使用较少复杂的挖矿方法。

共识机制: Ripple 网络不使用区块链挖矿概念, 而是使用**独特的分布式共识机制**, 通过进行**投票 (poll)** 来验证交易, 参与节点验证交易的真实性。

供应量: 大约 **1000 亿 (100 Billion)** XRP 被预 mined, 已经计算了500亿了
法币进入 Ripple -> Ripple 网络 (Gateways, XRP) -> 法币流出 Ripple。

加密货币总结 (Cryptocurrencies: Summary)

定义: 一种使用密码学来保护和验证交易以及控制新单位创建的数字货币或虚拟货币。

主要优势:

去中心化 (Decentralization): 消除了对中介的需求。

安全性 (Security): 利用密码学保障安全和隐私。

更快更便宜的交易: 消除了中介, 可全天候 (24/7) 处理。

无国界交易 (Borderless transactions): 使世界各地的各方都能发送和接收付款。

主要劣势:

波动性 (Volatility): 价值可能高度波动。

缺乏监管 (Lack of regulation): 在 largely unregulated space 中运作, 解决纠纷具有挑战性。

缺乏接受度 (Lack of acceptance): 尚未被广泛接受, 限制了其实用性。

金融的演变 (The Evolution of Finance)

早期银行系统

中世纪意大利: 建立了第一个银行系统。

词源: 意大利人坐在长凳 (bench) 上进行商业交易。意大利语中的 "Banco" 指的是长凳, 后来演变成了 "Bank" (银行)。

从易货到银行:

易货系统 (Barter system): 人们交换已有的货物。

金币作为交易工具: 人们意识到需要一种通用的商业工具。

金匠 (Goldsmiths): 商人需要安全的地方存放金币。金匠提供保险库, 这就是**安全存款 (safe deposits)** 概念的开始。

现代银行的诞生:

当钱闲置在保险库时, 金匠开始将其借出并收取利息。

他们还将部分利润分给存款人, 作为存入更多金币的激励。这促成了现代银行的诞生。

现代发展

圣乔治银行 (Bank of St. George): 位于意大利, 成立于 1407 年, 是世界上最古老的特许银行。

数字化: 整个银行流程现在已局限于计算机和手机等小型媒介中。只需打开电脑或手机, 即可立即转账、申请信用卡和贷款。

去中心化金融 (DeFi)

定义

DeFi 指的是利用去中心化技术（如区块链）来提供金融服务和产品。

包括借贷、交易、保险等。

为传统金融提供了替代方案，提供更易获取、透明和安全的金融服务。

DeFi 的优势 (Benefits of DeFi)

去中心化：在去中心化网络上运行，消除了对中介的需求，增强了交易安全性。

可访问性 (Accessibility)：为无法获得传统金融服务的人（如发展中国家或没有传统银行关系的人）提供金融服务。

透明度 (Transparency)：在公共账本上运行，提供比传统金融更大的透明度和问责制。

安全性 (Security)：在安全的区块链网络上运行，降低了欺诈和盗窃的风险。

DeFi 的风险 (Risks of DeFi)

波动性 (Volatility)：DeFi 服务通常建立在高度波动的加密资产上，增加了投资风险。

技术不成熟 (Immature Technology)：DeFi 技术尚不成熟，尚未在长时期内经过充分的压力测试。资金可能会丢失或面临风险。

扩展性风险 (Scaling Risk)：当前的 DeFi 平台使用共识方法，交易速度较慢。

例子：以太坊（DeFi 的主要技术）每秒可处理 15 笔交易，而 Visa 可处理 65,000 笔。

智能合约在 DeFi 中的作用 (Role of Smart Contracts in DeFi)

自动执行 (Automated Execution)：允许复杂的金融操作在满足条件时自动执行，无需人工干预（例如：如果借款人未能在截止日期前还款，借贷协议自动释放抵押品）。

无需信任的环境 (Trustless Environment)：用户无需依赖中央权威或中介。底层代码 governs 交易，确保所有方遵守条款。

透明度和安全性：智能合约部署在公共区块链上，所有参与者都可以检查代码。这最大限度地减少了欺诈风险，并创建了所有交易的可审计记录。

互操作性 (Interoperability)：智能合约可以相互交互，创建复杂的金融协议，实现自动化做市、去中心化交易所和流动性池等功能。

无中央中介：取代了银行、清算所或其他受信任机构的作用。

区块链技术与商业应用 (Blockchain Technology and Business Applications)

让区块链在商业中落地 (Making Blockchain Real for Business)

商业网络、财富与市场：

参与者包括客户、供应商、银行、合作伙伴。

跨越地理和监管边界。

财富是通过商业网络中的商品和服务流动以及交易和合同产生的。

市场是这一过程的核心（公共市场如水果市场，或私人市场如供应链融资）。

资产转移与价值构建 (Transferring Assets, Building Value)

资产 (Asset): 任何能够被拥有或控制以产生价值的东西。

有形资产 (Tangible): 如房子。

无形资产 (Intangible):

金融类：如债券。

知识产权类：如专利。

数字类：如音乐。

现金：也是一种资产（具有匿名性）。

账本是关键 (Ledgers are Key)

账本是企业的记录系统。

企业将拥有多个账本用于其参与的多个商业网络。

交易 (Transaction): 资产的转入或转出。

合同 (Contract): 交易发生的条件。

当前问题：今天的资产转移流程可能是低效、昂贵且脆弱的（各方拥有独立的记录，如 Party A, Party B, Bank, Auditor 等，数据不互通）。

解决方案：共享、复制、许可的账本 (Shared, replicated, permissioned ledger)。

带来：共识 (Consensus)、溯源 (Provenance)、不可篡改性 (Immutability)、终局性 (Finality)。

商业区块链的核心要素

1. **共享账本 (Shared Ledger):** 仅追加 (Append-only) 的分布式系统，跨商业网络共享。
2. **智能合约 (Smart Contract):** 嵌入在交易数据库中的商业条款，随交易执行。
3. **隐私 (Privacy):** 确保适当的可见性；交易是安全、经过认证和可验证的。
4. **共识 (Consensus):** 所有方同意网络验证的交易。

区块链带来的好处 (Blockchain Benefits)

节省时间：交易时间从几天缩短至近乎即时。

消除成本：去除中介及其相关开销。

降低风险：防止篡改、欺诈和网络犯罪。

增加信任：通过共享流程和记录保存。

具体行业应用 (Block Chain Technology Applications)

银行与金融：比特币，取代现有支付系统。

网络安全：数据无法被修改。

供应链：许可型区块链，用于信任、效率、管理。

物联网 (IoT): 集中式数据库消除中央通信（三星和 IBM 正在开发）。

保险：信任管理、数据验证、智能合约等。

交通：打车应用（无需第三方，电子钱包支付）。

云存储：安全、管理、效率。

投票：注册与验证、计票。

医疗保健：安全存储和共享敏感数据。

消除中介：从任何商业、政府、房地产甚至慈善机构中移除第三方。

自主电子商务：“事物的协作”，意味着大规模的机器对机器 (machine-to-machine) 协作。